



SYCONIA

The Beauty of the Inward Experience.

PREMIUM ADULT MEDIA DISCOVERY PLATFORM — PROJECT SPECIFICATION

Consolidated Project Specification

Version 1.0.2 — Documentation Baseline

Date 2026-09-03 · Owner / Developer credit: Roshan

Compiled verbatim from the 24-document specification suite

Table of Contents

ES	Executive Summary (from PRD.md)	3
1	Product Requirements — Master PRD	5
2	Product Requirements — Advanced Specification	15
3	Architecture	20
4	UX/UI System — Design System & Brand	26
5	UX/UI System — Gestures & Interaction	30
6	Screen Specifications	35
7	Workflows & Navigation	42
8	Database	46
9	API	53
10	Security	59
11	Performance	63
12	SEO	65
13	Accessibility	68
14	Testing	71
15	CI/CD	74
16	Deployment	77
17	Error & Recovery States	79
18	Operations — SOP	82
19	Pre-Release Checklist	85
20	Agent Instructions & Governance	88
22	Legal & Compliance	92
23	Documentation Index & Changelog	94
24	README & Changelog	96

EXECUTIVE SUMMARY

Executive Summary & Product Scope

Source: PRD.md §1, §3.1, §17 — verbatim extraction

Executive Summary (verbatim from PRD.md §1)

1. Executive summary

SYCONIA (pronounced sy-COHN-ee-uh, from syconium, the enclosed fig structure) is a premium, dark-themed, **adult video discovery and streaming platform**. The product differentiates itself from conventional "tube" sites through an editorial, cinematic, discreet brand experience — "The Beauty of the Inward Experience."

The platform does **not** produce, host, upload, or store any video files. All playback is delivered through **official embed players and public APIs of approved third-party sources** (adapter architecture, see [API.md](#) (see §)). SYCONIA stores only normalized metadata (title, duration, thumbnail URL, embed reference, taxonomy) in PostgreSQL and renders a premium discovery, search, and watching experience around it.

Core product pillars:

1. **Discreet premium identity** — the SYCONIA brand system (Night Emerald / Obsidian Black / Ostiole Gold / Champagne Gold / Alabaster) applied with editorial restraint.
2. **Frictionless access** — no accounts, no login, no signup, no payments, no premium tiers. An anonymous 18+ age gate is the only barrier.
3. **Fast discovery** — trending rails, semantic search with autocomplete, curated categories and tags, infinite-scroll feeds.
4. **Excellent playback UX** — a branded shell around third-party embed players: gestures, keyboard shortcuts, buffering/source-failure handling, privacy/discretion features.
5. **Operator-grade admin panel** — metadata cache management, taxonomy governance, source health, DMCA/takedown workflow, audit log.

Implementation status: **the repository currently contains brand assets and this documentation suite only**. Every application feature below is **[REQUIRED]** unless explicitly marked otherwise. No feature may be described as existing until verified in code.

Product Scope (verbatim from PRD.md §3.1)

3.1 In scope **[REQUIRED]**

- Native **Android application** (Kotlin/Compose, Material 3): age gate, home/discovery, search, categories, tags, watch experience, in-app legal; plus a **backend service** (API, admin console, legal/contact web surface, ingestion) — v1.1.0 platform baseline.
- Video playback via approved third-party embed players only (never proxied or downloaded).
- Metadata ingestion pipeline (adapters + normalization + PostgreSQL cache) for approved sources.
- Taxonomy system: admin-managed categories, tags, and source→local mapping rules.
- Anonymous, privacy-preserving first-party analytics (trending, admin dashboards).
- Admin panel (authenticated) with full operations tooling and audit log.
- Dark/night theme only; responsive 320px → 1920px+; HTTPS only.
- Android performance/stability budgets + backend API SLOs, WCAG 2.2 AA principles via Android accessibility, App Links/share URLs, web-surface discoverability (SEO scope-reduced — SEO.md v1.1.0), CI/CD (dual track), E2E tests, pre-release gates.

Conflicts Register (verbatim from PRD.md §17)

17. Conflicts register (mandated)

ID	Conflict	Resolution (normative)
C-1	Instruction block: "every image/logo/icon must be explicitly adult-themed; replace with genuine adult titles/descriptions" vs brand guidelines (premium, non-explicit identity; "visual language should communicate the concept without requiring explicit imagery") and the no-mock-data law.	Brand guidelines are the branding source of truth (per project mandate). Site identity (logo, icons, UI) stays non-explicit SYCONIA. Explicit imagery exists only as source-provided content thumbnails fetched at runtime through the pipeline — never authored, generated, or hardcoded in this repository. No synthetic "sample adult titles" are written anywhere; the catalog renders live source metadata or designed empty states.
C-2	Brand guidelines PDF §5 "Corporate Decoy Architecture" (present a false mainstream business identity to auditors/processors) vs master spec §17 Brand Safety ("never use branding to misrepresent the nature of the business...") and law.	The Decoy strategy is rejected . Legal/business-facing descriptions must be truthful. Discretion in product UX is legitimate; deception of institutions is not. See docs/LEGAL-COMPLIANCE.md §3.
C-3	Brand guidelines PDF describes creator dashboard, sextech divisions, corporate holding layers — vs product scope (§3.2: no creator features, no payments).	Out of scope for this platform. The PDF's visual identity applies; its unrelated business-unit narratives do not.

PART 01

Product Requirements — Master PRD

Source document: PRD.md · v1.0.2 · 2026-09-03

SYCONIA — Product Requirements Document (Master PRD)

Field	Value
Project	SYCONIA — premium adult media discovery & streaming platform
Document	PRD.md (master product requirements)
Version	1.1.0 — Android Platform Migration (web implementation baseline superseded)
Date	2026-09-03
Product owner	Roshan (developer & credit holder)
Status legend	[EXISTING] verified present in repository · [REQUIRED] must be implemented · [PROPOSED] approved future phase · [CONFLICT] documented conflict, see §17

Companion documents: [PRD2.md](#) (see §) (advanced specification), [SCREENS.md](#) (see §), [UX-FLOWS.md](#) (see §), [DESIGN-SYSTEM.md](#) (see §), [ARCHITECTURE.md](#) (see §).

1. Executive summary

SYCONIA (pronounced sy-COHN-ee-uh, from syconium, the enclosed fig structure) is a premium, dark-themed, **adult video discovery and streaming platform**. The product differentiates itself from conventional "tube" sites through an editorial, cinematic, discreet brand experience — "The Beauty of the Inward Experience."

The platform does **not** produce, host, upload, or store any video files. All playback is delivered through **official embed players and public APIs of approved third-party sources** (adapter architecture, see [API.md](#) (see §)). SYCONIA stores only normalized metadata (title, duration, thumbnail URL, embed reference, taxonomy) in PostgreSQL and renders a premium discovery, search, and watching experience around it.

Core product pillars:

1. **Discreet premium identity** — the SYCONIA brand system (Night Emerald / Obsidian Black / Ostiole Gold / Champagne Gold / Alabaster) applied with editorial restraint.
2. **Frictionless access** — no accounts, no login, no signup, no payments, no premium tiers. An anonymous 18+ age gate is the only barrier.
3. **Fast discovery** — trending rails, semantic search with autocomplete, curated categories and tags, infinite-scroll feeds.
4. **Excellent playback UX** — a branded shell around third-party embed players: gestures, keyboard shortcuts, buffering/source-failure handling, privacy/discretion features.
5. **Operator-grade admin panel** — metadata cache management, taxonomy governance, source health, DMCA/takedown workflow, audit log.

Implementation status: **the repository currently contains brand assets and this documentation suite only**. Every application feature below is [REQUIRED] unless explicitly marked otherwise. No feature may be described as existing until verified in code.

2. Brand foundation (summary — normative detail in DESIGN-SYSTEM.md)

- Name: **SYCONIA** (official spelling; never "Syconia Media", "Syconia Technologies" in product UI).

- Tagline: The Beauty of the Inward Experience. Secondary narrative: Where Intimacy Blooms.
- Concept: The Inward Bloom — outside: restraint, elegance, mystery; inside: discovery, beauty, intimacy.
- Palette: Night Emerald `#012A21`, Obsidian Black `#09090B`, Ostiole Gold `#C5A059`, Champagne Gold `#E6D3A0`, Alabaster `#FAF9F6`.
- Logo: official emblem + wordmark assets supplied in `/branding/` (primary, symbol-only, monochrome light, favicon 16–32px, app icon 512px, watermark 128px @20% opacity). The logo must never be recreated as an approximation while official assets exist.
- Clear space: 4× the diameter of the central ostiole dot on all sides.
- Voice: intelligent, confident, concise, sophisticated, human, editorial. No clickbait, no vulgar promotional language.
- Source of truth for branding: `/uploads/syconia-brand-guidelines.pdf` (v1.0, Sept 2026) — **except** its "Corporate Decoy" section, which is rejected; see §17 conflict C-2 and `docs/LEGAL-COMPLIANCE.md` (see §).

3. Product scope

3.1 In scope [REQUIRED]

- Native **Android application** (Kotlin/Compose, Material 3): age gate, home/discovery, search, categories, tags, watch experience, in-app legal; plus a **backend service** (API, admin console, legal/contact web surface, ingestion) — v1.1.0 platform baseline.
- Video playback via approved third-party embed players only (never proxied or downloaded).
- Metadata ingestion pipeline (adapters + normalization + PostgreSQL cache) for approved sources.
- Taxonomy system: admin-managed categories, tags, and source→local mapping rules.
- Anonymous, privacy-preserving first-party analytics (trending, admin dashboards).
- Admin panel (authenticated) with full operations tooling and audit log.
- Dark/night theme only; responsive 320px → 1920px+; HTTPS only.
- Android performance/stability budgets + backend API SLOs, WCAG 2.2 AA principles via Android accessibility, App Links/share URLs, web-surface discoverability (SEO scope-reduced — SEO.md v1.1.0), CI/CD (dual track), E2E tests, pre-release gates.

3.2 Explicitly out of scope (product decisions, permanent for v1)

- ✗ User registration, login, signup, email/password, Google/social login — **none**.
- ✗ Payments, subscriptions, premium tiers, paywalls, billing — **none**.
- ✗ Creator studio, uploader, studio pages, creator analytics — **none**.
- ✗ Public developer API — **none** (internal API only).
- ✗ Local video file storage, transcoding, downloading, or stream proxying.
- ✗ Comments, messaging, follows, social features.
- ✗ Light theme (dark/night only; light theme is a [PROPOSED] future token-level capability, never a v1 screen).

3.3 [PROPOSED] phase-2 candidates (not in v1 scope, pre-approved direction)

- On-device (localStorage) watch history and favorites with zero server sync.
- Collections/curated playlists (non-premium).
- (retired with the web client — v1.1.0 platform migration; see F-21).
- Optional jurisdiction-aware age-verification provider hook (see docs/LEGAL-COMPLIANCE.md).
- Seasonal campaign theming via design tokens (no component changes).

4. Personas

Persona	Device	Needs	Success looks like
The Discreet Viewer	Android phone, evening		

Persona	Device	Needs	Success looks like
		Fast, private, tasteful experience; no traces; no popups	Age gate once; instant playback; blur-until-tap discretion mode on thumbnails; history-less browsing
The Binge Browser	Android phone/tablet (+ external keyboard where available)	Long sessions, dense grids	Instant search, dense grids, smooth infinite scroll without jank
The Operator (Admin/Roshan)	Desktop (backend admin console — web)	Keep catalog fresh, sources healthy, takedowns processed	Dashboard with source health; one-screen takedown action; full audit trail

5. Legal & compliance requirements (normative detail: docs/LEGAL-COMPLIANCE.md)

- **Age gate** **[REQUIRED]** — 18+ self-certification interstitial before any content renders; remembered per device (cookie + localStorage, 12 months). Server-enforced: content APIs reject requests without the age-verified cookie.
- **Source legality** — only sources offering official embed/API programs may be enabled; each source's terms must be verified and recorded in the admin Sources screen before activation. No scraping that violates a source's terms; no circumvention of source controls.
- **Takedown workflow** **[REQUIRED]** — public report/dispute path on every watch page; DMCA designated-agent page; admin takedown queue with SLA; hidden entries remain suppressed and are re-blocked on re-sync.
- **2257 / content provenance** — SYCONIA stores no media and produces no content; watch pages display provenance ("provided by \<source>") and link to the source's own compliance/2257 statement where available.
- **Prohibited content policy** — zero tolerance policy documented and enforced operationally (admin blocks + source reporting); no content that is unlawful, involves minors, or is non-consensual, per the prohibited-content policy in docs/LEGAL-COMPLIANCE.md.
- **Truthful representation** — business/legal descriptions (company registration, processors, footers) must accurately describe the service. The brand-guidelines "Corporate Decoy" strategy is explicitly rejected (conflict C-2, §17).
- **Privacy** — no accounts, minimal first-party analytics, no third-party trackers, IPs truncated/never stored in full, DNT respected. See [SECURITY.md](#) (see §) §12.

6. Feature catalogue

ID	Feature	Status	Epic
F-01	18+ Age gate (overlay + server enforcement)	[REQUIRED]	Access
F-02	Global chrome: header, search bar, hamburger drawer, back arrow, footer	[REQUIRED]	Navigation
F-03	Home / discovery rails (Trending Now, New, Most Watched, Rising)	[REQUIRED]	Discovery
F-04	Search: full-text, typo-tolerant, autocomplete, zero-query trends	[REQUIRED]	Discovery
F-05	Categories: index + detail pages, admin CRUD, mapping rules	[REQUIRED]	Taxonomy
F-06	Tags: index + detail pages, admin CRUD	[REQUIRED]	Taxonomy
F-07	Watch page: branded shell, embed player, metadata, provenance, related rail	[REQUIRED]	Playback
F-08	Player interaction model (gestures, keyboard, buffering, failure, fallback)	[REQUIRED]	Playback
F-09	Report / takedown request entry point	[REQUIRED]	Compliance
F-10	Legal pages: Terms, Privacy, DMCA, 2257 statement, Cookies, About, Contact	[REQUIRED]	Compliance
F-11	Ingestion pipeline: adapters, normalization, sync scheduler, availability checks	[REQUIRED]	Platform

ID	Feature	Status	Epic
F-12	Anonymous analytics (watch events, search queries, daily rollups)	[REQUIRED]	Platform
F-13	Admin panel: auth, dashboard, videos, categories, tags, sources, mappings, takedowns, settings, audit log	[REQUIRED]	Operations
F-14	State system: loading skeletons, empty, error, offline states everywhere	[REQUIRED]	Quality
F-15	Accessibility (WCAG 2.2 AA), reduced motion, keyboard operability	[REQUIRED]	Quality
F-16	Discoverability: Android App Links + share URLs + OG share pages; legal-surface SEO (scope-reduced v1.1.0 — SEO.md)	[REQUIRED]	Growth
F-17	Performance budgets & Core Web Vitals enforcement	[REQUIRED]	Quality
F-18	CI/CD pipeline with quality gates (incl. no-placeholder-code gate)	[REQUIRED]	Engineering
F-19	On-device favorites & watch history	[PROPOSED]	Discovery
F-20	Collections / curated playlists	[PROPOSED]	Discovery
F-21	~~PWA offline shell~~ — retired (platform-specific, v1.1.0) ; Android offline behavior is an architecture concern (honest offline states; any offline caching decided per D-014)	RETIRED	Platform

7. Major feature specifications

Each feature below follows the full mandated template. Screen-level layouts live in [SCREENS.md](#) (see §); flows in [UX-FLOWS.md](#) (see §).

7.1 F-01 — Age Gate

- **Purpose:** legal access control; establish the discreet, intentional tone of the brand from the first pixel.
- **User value:** one-tap, remembered confirmation; adult users never see the barrier again on that device.
- **Preconditions:** none (first visit, or expired/absent `sy_age_ok` cookie).
- **Entry points:** any route; the overlay renders above the app before content hydrates. Direct deep-links preserve the target URL through the gate.
- **UI/UX behavior:** full-screen Obsidian overlay with centered symbol-only emblem, serif headline ("You must be 18+ to enter"), two buttons (Enter / Leave), link to Terms. Content beneath is not rendered (server-checked cookie; no content API responses without it).
- **User actions:** "I am 18 or older — Enter"; "Leave site" (redirects to a neutral external page); view Terms.
- **System response:** Enter → sets `sy_age_ok=1` HttpOnly cookie (12 months) + localStorage mirror, logs an anonymous `age_ack` event, reveals app with a fade-in; Leave → `window.location` to neutral page; no content ever shipped to the client before Enter.
- **Conditional logic:** cookie present & valid → skip entirely (server-side, zero flash). Cookie malformed → treat as absent.
- **Validation:** none beyond the affirmation itself; server trusts only the signed cookie, never client state.
- **Loading/empty/error:** overlay is static and instant; if Terms fetch fails, inline retry link.
- **Accessibility:** focus trapped in overlay; buttons are real `<button>`s; ESC does not dismiss; announced as a dialog (`role="alertdialog"`); contrast AA on all text.
- **Responsive:** identical centered layout 320px→1920px; buttons stack below 420px; emblem scales via `clamp()`.
- **Security:** HttpOnly + Secure + SameSite=Lax cookie; prevents content API access without it (middleware); no PII collected.
- **Performance:** zero JS beyond the minimal gate island (~<10KB); no images except emblem SVG/PNG (≤8KB).
- **Analytics:** `age_ack` event (count only, no identifiers).
- **Dependencies:** global middleware [REQUIRED].

- **Acceptance criteria:** (1) With no cookie, no route returns content HTML. (2) After Enter, all routes accessible. (3) Cookie expiry re-triggers gate. (4) Keyboard-only users can pass. (5) E2E proves content APIs 403 without the cookie.

7.2 F-02 — Global chrome (header, hamburger drawer, back arrow)

- **Purpose:** consistent, quiet navigation across all public screens.
- **User value:** predictable orientation; one-gesture access to everything; safe, reversible navigation.
- **Preconditions:** age gate passed.
- **Entry points:** every public page.
- **UI/UX behavior:** sticky translucent header (restrained glass: blur 12px, Obsidian @ 72% opacity): left — back arrow on pages deeper than home (top-left, per platform convention) and hamburger (three-line) button; center/left-of-actions — SYCONIA wordmark (symbol-only below 480px); right — search icon (expands inline on mobile), theme is fixed dark. Hamburger opens the left slide-in drawer: Discover, Trending, New, Categories (expandable), Tags, About, Legal links, developer credit "Crafted by Roshan".
- **User actions:** tap back (history-back if entry exists, else route to parent), open/close drawer (tap, ESC, swipe-left to close on touch, focus-return to hamburger), navigate to any drawer destination, focus search.
- **System response:** drawer slides in 260ms with scrim; body scroll locked; route changes close drawer first, then navigate with page transition (fade/slide per DESIGN-SYSTEM §9); back arrow behavior defined per screen in SCREENS.md.
- **Conditional logic:** back arrow hidden on Home; drawer active-section highlighting; search icon becomes inline field on mobile (header height preserved).
- **Validation:** n/a. **Loading:** drawer content static-instant; nav prefetch on hover/intent.
- **Empty/error:** if prefetch of a nav target fails, navigation proceeds and the target page renders its own error state (ERROR-STATES.md).
- **Accessibility:** hamburger is `aria-expanded / aria-controls`; drawer is a labelled dialog with focus trap; ESC closes; back arrow has `aria-label="Back"`; skip-to-content link first.
- **Responsive:** ≥ 1024 px optional persistent sidebar [PROPOSED]; drawer default on all sizes in v1 (consistent mobile-first identity).
- **Security:** no tokens in drawer; links are internal routes only (rel enforcement).
- **Performance:** header shell server-rendered; drawer client island, motion on transform/opacity only; respects `prefers-reduced-motion`.
- **Analytics:** `nav_drawer_open`, `nav_back_used`, destination taps.
- **Dependencies:** design tokens, motion library (`motion/react`).
- **Acceptance criteria:** drawer opens/closes ≤ 16 ms input latency; focus never lost; all routes reachable from drawer in ≤ 2 taps; E2E covers open→navigate→back on mobile & desktop viewports.

7.3 F-03 — Home / Discovery

- **Purpose:** the storefront: instant, cinematic entry into the catalog.
- **User value:** zero-thought content discovery; a beautiful, calm grid instead of aggressive tube-site clutter.
- **Preconditions:** age gate passed; catalog populated (otherwise curated empty state, see ERROR-STATES.md).
- **Entry points:** / (default), drawer "Discover", logo tap, back-arrow fallthrough.
- **UI/UX behavior:** editorial hero (serif headline, featured item with blurred-until-hover/press thumbnail treatment), then rails: Trending Now · New Releases · Most Watched (7d) · Rising; each rail horizontally scrollable on mobile, grid-integrated on desktop; rail headers link to full listings. VideoCard: 16:9 thumbnail (source-provided, proxied via next/image allowlist), duration badge, title (2-line clamp), source badge, relative publish time. Hover (pointer: fine): subtle scale 1.02 + preview scrub if source provides preview media [PROPOSED].
- **User actions:** scroll (infinite within rails where applicable), open a video, open a rail listing, search, open drawer.

- **System response:** skeleton-first SSR stream; cards stagger-fade in (motion); tapping a card → watch route with image-dominant transition; rail "View all" → category/sorted listing.
- **Conditional logic:** if Trending has < N items (cold catalog), rail falls back to Most Watched 30d, then New; hero suppressed if no qualified item; availability-checked items only (stale entries pruned or hidden by pipeline).
- **Validation:** rail queries bounded (page size, max offset); client never sends arbitrary query text to rail endpoints.
- **Loading state:** skeletons matching exact card geometry (no layout shift, CLS < 0.02).
- **Empty state:** brand-consistent editorial empty state with search prompt (ERROR-STATES.md E-02).
- **Error state:** rail-level error → inline retry chip; page-level error → ERROR-STATES.md E-01.
- **Offline:** cached shell + banner (ERROR-STATES.md E-05).
- **Accessibility:** all cards are single focusable links with descriptive names (title + duration + source); rails are `aria-labelledby` regions; horizontal scroll keyboard-operable (arrow keys on focused rail group).
- **Responsive:** 2 cols @320-479, 3 @480-767, 4 @768-1279, 5 @1280-1535, 6 @≥1536; hero full-bleed on mobile.
- **Security:** thumbnails proxied through allowlisted image optimization; no third-party scripts from sources.
- **Performance:** LCP element is hero thumbnail (priority-loaded); rails lazy below fold; ISR with tag-based revalidation (PERFORMANCE.md).
- **Analytics:** rail impressions (IntersectionObserver, batched), card clicks with rail context.
- **Dependencies:** F-11 pipeline, F-12 analytics, tokens.
- **Acceptance criteria:** home interactive < 2.0s on 4G mid-range Android; zero layout shift; every visible card opens a valid watch page or is not shown; E2E passes for anonymous cold-start.

7.4 F-04 — Search

- **Purpose:** fastest path from intent to content.
- **User value:** instant, typo-tolerant, suggestion-rich search without account friction.
- **Preconditions:** age gate passed.
- **Entry points:** header search icon/field; drawer "Search"; `/search`; watch page related-tags.
- **UI/UX behavior:** header field expands (desktop persistent field, mobile overlay sheet); debounced (180ms) autocomplete dropdown: trending queries (zero input), title suggestions with thumbnails, matching categories/tags (badged); submit → `/search?q=`. Results page: filter bar (category, tag, source, duration buckets, orientation-free neutral filters only), sort (Relevance, Newest, Longest, Most watched), infinite scroll + explicit pagination for accessibility ("Load more" always available), result count.
- **User actions:** type, select suggestion, run raw query, apply/remove filters, change sort, paginate, clear.
- **System response:** suggestions ranked (prefix > fuzzy > trending); results server-rendered for first page; subsequent pages via cursor API; filters reflected in URL (`?q=&cat=&tag=&src=&dur=&sort=`) — shareable, back-button-safe.
- **Conditional logic:** empty query → redirect to trending listing; query of a category/tag name → offer direct link chip at top; zero results → empty state with relaxed-match attempt (trigram similarity) and trending alternatives (E-03).
- **Validation:** query length 1-120 chars (enforced server-side); filter values validated against enums; invalid → sanitized to defaults with notice.
- **Loading:** input keeps value; dropdown skeleton lines; results page SSR + streamed skeletons for above-fold.
- **Empty/error/recovery:** per ERROR-STATES.md E-03/E-04.
- **Accessibility:** combobox pattern (`role="combobox"` + listbox) with full arrow-key operation and live region announcement of result count; each filter is a labelled control; sort is a `radiogroup` menu.
- **Responsive:** mobile full-screen search sheet; filters collapse into bottom drawer "Filters (n)".
- **Security:** query parameterized (never string-concatenated SQL — Drizzle + tsvector/trigram parameter binding); rate limited (60 req/min/IP for suggest; see SECURITY.md §10); output escaped by React; no regex on user input.

- **Performance:** suggest p95 < 120ms (indexed, cached 30s); results TTFB < 300ms; autocomplete payloads capped (8 items).
- **Analytics:** `search_submit` (query string stored in `search_queries` for trending, retention 90d), filter usage, zero-result rate (quality KPI).
- **Dependencies:** tsvector + pg_trgm indexes (DATABASE.md §4), F-12.
- **Acceptance criteria:** typo queries return relevant results; keyboard-only full journey passes; URL round-trips state exactly; E2E covers zero-result and filter paths.

7.5 F-07/F-08 — Watch page & player interaction model

- **Purpose:** the core experience: a branded, controllable, private viewing session around third-party embeds.
- **User value:** cinematic presentation, fast and predictable controls, graceful failures, discretion.
- **Preconditions:** age gate passed; video record exists and is `available`.
- **Entry points:** any VideoCard, direct URL `/watch/[slug]`, external backlinks.
- **UI/UX behavior:** top: player stage (16:9, letterboxed, Obsidian matte) inside a branded shell; branded chrome overlays (play affordance, loading ostiole pulse, error overlays) where the embed allows; below: title, meta row (source badge "Provided by X" linking to provenance, publish date, view count, report button), tag chips, description (collapsed 3 lines), then Related rail (same-category then same-tag then trending fill). SYCONIA watermark (128px emblem @20% opacity) anchored bottom-right of the stage, non-interactive.
- **Player interaction model (full spec: GESTURES.md):** because playback is inside a third-party iframe, SYCONIA provides (a) the shell-level interactions it fully controls — keyboard shortcuts where the embed exposes an API, gesture layer for taps/swipes on the stage overlay when the embed permits passthrough, orientation handling, fullscreen delegation via the Fullscreen API on the shell — and (b) documented, honest fallbacks where the embed consumes its own input (native embed controls remain usable; SYCONIA shortcuts then apply to shell functions only: fullscreen, theater, related, report). Each approved adapter declares its `interaction_capability` set; the shell renders only supported controls. **Playback, seeking, volume and captions otherwise defer to the source player's own official control set;** SYCONIA never injects into or scripts the embed's internals.
- **User actions:** play/pause (embed), fullscreen (shell), theater mode (shell), open-at-source, copy link, report, tag navigation, related navigation, back arrow.
- **System response:** watch event beacon (anonymous, throttled: start, 25/50/75% milestones, end); related rail contextual to taxonomy; report opens modal (F-09).
- **Conditional logic:** embed refuses to load (timeout 8s / `onError`) → failure overlay with (1) retry, (2) alternate embed variant if adapter provides one, (3) open at source, (4) report problem; video marked `degraded` for pipeline re-check. Unavailable video → removed from listings within one sync cycle; direct URL renders E-06 removed state with related suggestions.
- **Validation:** slug format; report form (reason enum, optional contact email validated, 1000-char max, rate limited).
- **Loading:** ostiole pulse indicator (brand loading), stage dims; metadata skeletons.
- **Empty:** no related items → rail hidden (no empty stub).
- **Error/recovery:** per above and ERROR-STATES.md E-04/E-07.
- **Accessibility:** stage is a labelled region; keyboard: F fullscreen, T theater, ESC exits; report modal focus-trapped; watermark `aria-hidden`; all controls ≥44px touch targets; prefers-reduced-motion disables pulse (static emblem).
- **Responsive:** stage fluid; theater mode widens (rail/column collapse); mobile: metadata stacked, related rail horizontal.
- **Security/discretion:** `sandbox` and `referrerpolicy` attributes on iframe; fullscreen allow only; no source scripts on our origin; URLs validated against source allowlist at render; report form CSRF-protected.
- **Performance:** stage reserved space (zero CLS); embed lazy-initialized after intent (tap-to-load poster on mobile data-saver `[PROPOSED]`); below-fold content streamed.
- **Analytics:** watch milestones, drop-off quartiles (aggregate), report submissions.

- **Dependencies:** adapters (API.md §6), tokens, motion.
- **Acceptance criteria:** no unhandled iframe errors visible to user; every failure path offers ≥ 2 next actions; keyboard-only viewing session possible (shell functions + native embed a11y); autoplay never fires with sound (policy §GESTURES.md autoplay).

7.6 F-11 — Ingestion pipeline (adapters + normalization)

- **Purpose:** keep the PostgreSQL catalog fresh, deduplicated, normalized, and legally sourced.
- **User value:** breadth and freshness of catalog without SYCONIA hosting media.
- **Preconditions:** source enabled in admin after terms verification (docs/LEGAL-COMPLIANCE.md).
- **Behavior:** server-side scheduler (cron) runs per-source sync jobs → adapter fetches via official API/feed → normalize to canonical Video DTO (API.md §6.3) → upsert (unique `source_id + source_video_id`) → apply mapping rules → taxonomy attach → availability probe → prune/disable stale. Failures quarantined per-source (never cross-source); `sync_runs` records stats/errors for admin.
- **Validation:** DTO schema-validated (Zod) at boundary; unknown fields preserved in `metadata jsonb` but never rendered without sanitization; titles/durations bounds-checked.
- **Security:** SSRF controls — adapters may only call preconfigured hosts (SECURITY.md §8); timeouts 10s; retries with jitter (max 2); circuit breaker per source.
- **Performance:** incremental syncs (since-token), bounded page sizes, off-peak windows, DB batch upserts.
- **Observability:** success rate, items added/updated, p95 fetch latency, breaker state — all on admin dashboard.
- **Acceptance criteria:** re-running a sync is idempotent; a failing source never blocks others; takedown-blocked entries never resurface.

7.7 F-13 — Admin panel (authenticated operations suite)

- **Purpose:** full operational control: catalog, taxonomy, sources, compliance, settings, audit.
- **User value (operator):** safe, fast, accountable operations without database access.
- **Preconditions:** admin account (env-seeded, argon2-hashed) — the **only** authentication in the product, scoped to `/admin`.
- **Screens:** Login, Dashboard (KPIs, source health, sync runs), Videos (search/filter/hide/refresh/re-map), Categories, Tags, Sources (enable/disable, terms-verified flag, keys), Mapping rules (source term → local taxonomy), Takedowns (queue, actions, DMCA log), Settings (age-gate copy, feature flags, retention), Audit log. Full specs in SCREENS.md §A.
- **Security:** HttpOnly session cookie, argon2, brute-force lockout (5 fails → 15min), all mutations audited, IP-bound optional, CSP-strict, noindex + `X-Robots-Tag`.
- **Acceptance criteria:** every mutation has an audit row; takedown hide is effective on public site within 60s (cache invalidation); sessions expire (8h idle / 24h absolute).

7.8 F-10 — Legal pages [REQUIRED]

Terms of Service, Privacy Policy (truthful: no accounts, what is stored, retention), DMCA/Copyright (designated agent, process, SLA), 2257 Provenance statement, Cookie Notice (first-party only), About, Contact (report/abuse/legal channels). Content requirements and review workflow in docs/LEGAL-COMPLIANCE.md; copy tone per DESIGN-SYSTEM §12.

8. Functional requirements (selection — full traceability in TESTING.md)

- **FR-1** Every public content endpoint and page must refuse service without a valid age cookie. (F-01)
- **FR-2** Navigation must include: top-left back arrow on non-root pages, three-line hamburger opening the primary drawer, header search on every page. (F-02)
- **FR-3** All lists paginate via opaque cursors; no unbounded queries. (F-03/04)
- **FR-4** Search must support fuzzy matching, autocomplete ≤ 8 suggestions, and URL-round-trippable filters. (F-04)
- **FR-5** Watch pages must never reference a media file; playback only via the source's official embed URL stored at ingestion. (F-07)

- **FR-6** Every watch page must expose Report and Open-at-Source actions and provenance text. (F-07/F-09)
- **FR-7** Admin mutations must be auditable and reversible (soft-delete semantics). (F-13)
- **FR-8** Takedown-blocked content must never reappear through any public route or sync. (F-09/F-11)
- **FR-9** The site must function with JavaScript-enhanced, progressively-rendered pages; interactive islands degrade gracefully. (Quality)
- **FR-10** Zero placeholder/mock/demo data in any environment — including empty catalogs, which render designed empty states, never fake content. (Engineering law; enforced by CI gate G-7, CI-CD.md §4)

9. Non-functional requirements

Area	Requirement	Verbose spec
Performance	LCP < 2.0s (mobile 4G), INP < 200ms, CLS < 0.02, TTFB < 300ms	PERFORMANCE.md (see §)
Accessibility	WCAG 2.2 AA; keyboard-complete; reduced-motion	ACCESSIBILITY.md (see §)
Security	Headers, CSP, rate limits, SSRF controls, secrets mgmt	SECURITY.md (see §)
SEO	Canonicals, sitemaps, robots, structured data	SEO.md (see §)
Stability	Error boundaries per region; graceful degradation; SLO 99.9%	ARCHITECTURE.md (see §) §12
Privacy	No accounts; truncated IPs; DNT; 90-day raw-event retention	SECURITY.md (see §) §12
Compatibility	Chrome, Firefox, Safari (desktop+mobile), Edge; 320px→1920px+	TESTING.md (see §)

10. Analytics & observability requirements

First-party only. Events: `age_ack`, `page_view`, `rail_impression`, `card_open`, `search_submit`, `watch_start/`
`quartile/end`, `report_open/submit`, `player_error` (with source + code, no PII), `nav_*`. Pipeline → `watch_events/`
`search_queries` → daily rollups → admin dashboards. No third-party analytics, no fingerprinting, no cross-site tracking. Structured logs with request IDs; alerting thresholds in PRD2.md §9.

11. Constraints & dependencies

- **Android (v1.1.0):** Kotlin + Jetpack Compose + Material 3, Clean Architecture/MVVM-UDF, Coroutines/Flow, Hilt, Navigation Compose; Retrofit/OkHttp/kotlinx-serialization, Coil, DataStore (decisions D-010...D-016).
Backend: Node 20+, TypeScript 5 strict, Next.js (backend-only role), PostgreSQL 16+, Drizzle ORM.
- Approved brand assets in `/branding/` (from `/uploads/`) are the only permitted logo sources.
- External dependency: availability & terms of chosen sources (risk register PRD2.md §11).
- Deployment: backend on Vercel + Neon (primary) or Docker/VPS (alternative); Android via internal APK/testing (distribution decision M5-T006) — DEPLOYMENT.md.

12. Release plan

Milestone	Contents	Exit gate
M0	Docs baseline (this suite) + repo hygiene	PRE-RELEASE §1–2
M1	Tokens, chrome, age gate, routing, legal pages	E2E smoke + a11y audit
M2	Pipeline + one approved source + home/search/taxonomy	Catalog E2E + perf budget
M3	Watch page + player shell + related + report	Player matrix (GESTURES.md §9)
M4	Admin suite + analytics rollups	Ops runbook dry run
M5	Hardening: perf, SEO, security checklist, pre-release	Full PRE-RELEASE.md PASS

13. Acceptance criteria (product-level)

1. A first-time visitor cannot reach content without the age gate; a returning visitor never sees it twice on the same device.

2. Any video reachable in the UI plays via its source embed or presents a compliant failure/recovery path.
3. Search → filter → watch → back → related loop is completable keyboard-only on 360px viewport.
4. Admin can hide any video and it disappears from all public surfaces within 60 seconds.
5. No route, in any environment, renders mock/demo content or placeholder media.
6. All CI gates (CI-CD.md §4) green on the release commit; PRE-RELEASE.md fully PASS.

14. Success metrics (post-launch)

- Search zero-result rate < 8%; suggest p95 < 120ms.
- Watch-page engagement: ≥60% of sessions reach a quartile milestone.
- Report SLA: takedowns actioned < 48h (target 24h).
- CWV: 75th-percentile pass on all three vitals in field data.

15. Risks (top 5 — full register in PRD2.md §11)

1. Source terms change / API retirement → adapter redundancy (≥2 sources) + admin kill-switch.
2. Regulatory age-verification mandates in target markets → configurable AV hook [PROPOSED].
3. Payment/hosting policy exposure (adult category) → truthful representation, compliant host selection (DEPLOYMENT.md §2).
4. Catalog cold-start → curated taxonomy-first empty states; pipeline seeding.
5. SEO volatility for adult content → diversified discovery (direct, social-safe share links with neutral preview [PROPOSED]).

16. Document contribution & maintenance

Owned by Roshan. Any feature change updates: this PRD → SCREENS.md/UX-FLOWS.md → TESTING.md matrix → PRE-RELEASE items. Docs version in lockstep via CHANGELOG.md.

17. Conflicts register (mandated)

ID	Conflict	Resolution (normative)
C-1	Instruction block: "every image/logo/icon must be explicitly adult-themed; replace with genuine adult titles/descriptions" vs brand guidelines (premium, non-explicit identity; "visual language should communicate the concept without requiring explicit imagery") and the no-mock-data law.	Brand guidelines are the branding source of truth (per project mandate). Site identity (logo, icons, UI) stays non-explicit SYCONIA. Explicit imagery exists only as source-provided content thumbnails fetched at runtime through the pipeline — never authored, generated, or hardcoded in this repository. No synthetic "sample adult titles" are written anywhere; the catalog renders live source metadata or designed empty states.
C-2	Brand guidelines PDF §5 "Corporate Decoy Architecture" (present a false mainstream business identity to auditors/processors) vs master spec §17 Brand Safety ("never use branding to misrepresent the nature of the business...") and law.	The Decoy strategy is rejected . Legal/business-facing descriptions must be truthful. Discretion in product UX is legitimate; deception of institutions is not. See docs/LEGAL-COMPLIANCE.md §3.
C-3	Brand guidelines PDF describes creator dashboard, sextech divisions, corporate holding layers — vs product scope (§3.2: no creator features, no payments).	Out of scope for this platform. The PDF's visual identity applies; its unrelated business-unit narratives do not.

PART 02

Product Requirements — Advanced Specification

Source document: PRD2.md · v1.0.2 · 2026-09-03

SYCONIA — Advanced Product Specification (v1.1.0 — platform-neutral data/behavior spec)

Platform mapping: client-side behaviors (cursors, cache TTLs, race policies, session) are consumed by the **Android repository/UseCase layer** (replacing TanStack Query); `sy_sid` = app anonymous session id (same lifecycle); beacons flush on app backgrounding. All math, contracts and policies unchanged.

Field	Value
Document	PRD2.md — advanced specification complementing <code>PRD.md</code> (see §)
Version	1.0.2 — Gap-Audit Patch · Date: 2026-09-03
Status	All mechanisms described here are <code>[REQUIRED]</code> for v1 unless marked <code>[PROPOSED]</code>

1. Purpose

PRD.md defines what SYCONIA is and who it serves. This document defines how the product behaves in the dark corners: ranking math, pagination semantics, cache lifetimes, adapter contracts, governance, observability, capacity, and risk. It is the bridge between product intent and `ARCHITECTURE.md` (see §)/`API.md` (see §).

2. Interaction deep-specifications (product-level)

2.1 Feed semantics

- **Rail order (Home):** `Trending Now` → `New Releases` → `Most Watched (7d)` → `Rising`. A rail is rendered only if ≥ 4 items qualify; otherwise it is replaced by the next eligible rail (never a stub).
- **Infinite scroll contract:** first page SSR (12 items/page on mobile grid, 24 on desktop); subsequent pages via cursor. Trigger at 800px from end; prefetch 1 page ahead when `saveData` is false. An explicit “Load more” button always exists as keyboard/mobile fallback and moves focus to the first new item (`aria-live` announcement: “12 more videos loaded”).
- **End of feed:** footer strip “You’ve reached the end” with two suggestions (Trending, Categories) — never an abrupt void.
- **Hero eligibility (normative):** `is_available = true` AND `is_hidden = false` AND `trending_score` within global top 10 AND proxied thumbnail verified (proxy 200 at render) AND title length 10-120 chars. The first item in that order is the hero; if none qualifies, the hero is suppressed and rails move up (no fallback fake hero).

2.2 Sorting semantics (normative)

Sort	Definition
Relevance (search default)	<code>tsvector rank ts_rank_cd</code> × trigram similarity tiebreak × availability recency boost (×1.1 if <code>last_seen_at</code> within 48h)
Newest	<code>published_at</code> DESC NULLS LAST, tiebreak <code>first_seen_at</code> DESC
Longest	<code>duration_seconds</code> DESC (filter: duration bucket applied independently)
Most watched	<code>views_7d</code> DESC from rollups, tiebreak <code>views_total</code> DESC

Sort	Definition
Trending (default listing)	decayed velocity — §3.1
Rising	$\text{views_24h} / \max(\text{views_7d}, 1)$ ratio, min threshold 50 views/24h

2.3 URL state contract (search/listings)

- Every filter/sort/page state lives in destination state + deep-link arguments (pattern `?q= &cat= &tag= &src= &dur= &sort= &cursor=` retained for share URLs). System back must restore state and scroll position (saved-state + lazy-list first-visible-item restoration; verified in E2E).
- Canonical URLs exclude cursor/page parameters (SEO.md §4).

2.4 Discretion behaviors

- Thumbnail treatment: posters render with a subtle brand-consistent dim/blur (8px, 40% opacity veil) until hover (pointer: fine) or first tap-release (touch); a settings toggle “Discreet thumbnails: on/off” persists in localStorage only — [REQUIRED] (privacy UX, zero server state).
- History hygiene: watch pages set `document.title` to the neutral base brand title on `visibilitychange` hidden (tab-mask), and offer “Clear session traces” (clears localStorage session id + beacons queue) in the footer — [REQUIRED].
- Referrer hygiene: all external links (source, provenance) use `rel="nofollow noopener noreferrer"`; Referrer-Policy `strict-origin-when-cross-origin` sitewide (SECURITY.md §4).

2.5 Related-rail composition (normative — G-05 resolution)

Ordered candidate pool for a watch page `V`: 1. **Bucket A — same primary category**: videos sharing `V`'s first category, ranked `trending_score` DESC. 2. **Bucket B — shared tags**: videos sharing ≥ 1 tag with `V` (excluding Bucket A), ranked `shared_tag_count` DESC, `trending_score` DESC. 3. **Bucket C — trending backfill**: global trending, ranked `trending_score` DESC. Global exclusions across all buckets: `V` itself, `is_hidden`, `is_available=false`, blocked entries, sources currently disabled. Dedupe by `id`. Rail = first 6 of the merged pool (A then B then C); rail rendered only if ≥ 4 items — else hidden (no stub). Continuation (`More / relatedCursor`) walks the identical pool with the stable composite key (`bucket, shared_tag_count, trending_score, id`) — deterministic across requests (API §4.2).

2.6 View-count semantics (normative — G-06 resolution)

- A **view** = one distinct (`session_id, video_id, calendar day`) with ≥ 1 quartile milestone (`q25|q50|q75|end`) — deduped in aggregation (`COUNT(DISTINCT session_id)` per video/day where event IN quartiles), so replays and beacon duplicates never double-count.
- `views_24h / views_7d`: rolling sums of daily distinct-session counts (jobs, DATABASE §2.2). `views_total`: cumulative sum maintained by the nightly rollup. `WatchDTO.viewCount = views_total`.
- Display rounding (watch page + admin): $<1000 \text{ exact} \cdot 1,000\text{--}999,999 \rightarrow X.Xk \cdot \geq 1,000,000 \rightarrow X.XM$.

2.7 Stale-request / race / cancellation policy (normative — G-08 resolution)

- Every query/filter change produces a new repository request key $\rightarrow$ automatic request supersession; in-flight coroutines are **cancelled** on key change; responses arriving for abandoned keys are discarded (last-write-wins collection).
- Suggest endpoint: each request carries a client `seq`; responses with `seq < latest rendered seq` are dropped (out-of-order guard).
- Duplicate/idempotent beacons: no cancellation (safe by §2.6 aggregation dedupe).
- Mutations (report/contact): single-flight — submit button disabled while in-flight; duplicate submits impossible; retries only after network-class failure with unchanged payload.

2.8 Filter semantics under empty results (normative — G-27 resolution)

The zero-result relaxation chain (§3.3) applies to the text query `q` **only**. Filters and sort are **never auto-relaxed or auto-removed**. A filtered query yielding zero items renders **E-02b** (ERROR-STATES) with an

explicit **Clear filters** action; the response may include a `notice: "filters_cleared_suggestion"` hint but the server never silently changes the client's filter state.

3. Ranking & analytics mathematics

3.1 Trending score

$\text{trending_score} = (w_{24} \cdot V_{24h} + w_7 \cdot V_{7d} / 7 + w_q \cdot Q) \cdot \text{freshness} \cdot \text{availability}$ - V_{24h} , V_{7d} = distinct anonymous sessions with ≥ 1 quartile milestone, from rollups. - Q = completion quality = mean of quartile reached (0.25–1.0). - $\text{freshness} = \exp(-\lambda \cdot \text{age_days})$, $\lambda = 0.08$ ($\approx$ 8.5-day half-life tuning window, admin-tunable via Settings). - Weights (default): $w_{24}=0.5$, $w_7=0.3$, $w_q=0.2$. Recomputed hourly into `daily_video_stats.trending_score`.

3.2 Suggestion ranking (autocomplete)

1. Prefix matches on title (tsvector `prefix:*`), 2. trigram similarity ≥ 0.32 on title, 3. trending queries matching the prefix, 4. exact category/tag name matches (surfaced as typed chips). Interleaved with the ordering above; 8-item cap; each item carries its result-count when known.

3.3 Zero-result recovery

If strict query yields 0: relax in order — (a) trigram similarity ≥ 0.25 , (b) drop lowest-specificity token, (c) tag/category fuzzy. If still 0, render E-03 (ERROR-STATES.md) with trending; the failed query is logged with `relaxed=1` for taxonomy gap analysis (admin Tags screen surfaces gaps weekly).

3.4 Rollup & retention

Raw `watch_events`, `interaction_events` and `search_queries` aggregate nightly into `daily_video_stats` / `daily_search_stats` / daily event-type aggregates; raw rows purged at 90 days (Settings-tunable 30–180); rollups retained indefinitely (aggregate, non-identifying). The hourly trending job also maintains `videos.views_24h` / `videos.views_7d` (DATABASE §2.2). Purge job is idempotent and audited.

4. Cursor pagination specification

- Cursor = Base64URL({sortKey, id}), signed with HMAC (server secret) to prevent forgery/tamper (403 on invalid signature).
- Sort keys: `trending` $\rightarrow$ (score,id), `new` $\rightarrow$ (published_at,id), `views` $\rightarrow$ (views_7d,id), `relevance` $\rightarrow$ (rank not cursorable $\rightarrow$ page-token window by query hash, max 10 pages deep then force-refine UX).
- Page sizes: grid 24 (desktop)/12 (mobile) — size is server-decided from viewport hint, clamped 6–48; client cannot set arbitrary size.
- Empty/short pages return `nextCursor: null` when exhausted; duplicate-guard by `id` set on client.

5. Cache TTL matrix (single source of truth; referenced by ARCHITECTURE.md §9)

Layer	Key	TTL	Invalidation
CDN/ISR	Home	120s	tag <code>home</code> on sync/purge
CDN/ISR	Category/Tag listing p.1	300s	tag <code>taxonomy:{id}</code>
CDN/ISR	Watch page shell	600s	tag <code>video:{id}</code> , <code>video:hide</code>
Route handler	<code>/api/videos list</code>	30s	none (short)
Route handler	<code>suggest</code>	30s	none
Adapter	source fetch	source-defined (min 300s)	breaker
DB	rollup tables	hourly job	job
Client (app repository cache)	lists	staleTime 60s, memory 5m	cursor-keyed
Images	thumbnails	30d immutable	URL-hash changes

6. Adapter architecture contract (summary — full API in API.md §6)

- Canonical NormalizedVideo DTO: { sourceSlug, sourceVideoId, title(≤300), description(≤5000|null), durationSeconds(30–28800|null), thumbUrl, thumbUrls[], previewUrl|null, embed{type: iframe|player-api, url, allowFullscreen, capabilitySet[]}, sourceCategories[], sourceTags[], publishedAt|null, sourceRating|null }.
- capabilitySet enumerates what the shell may control per source: fullscreen-delegation, keyboard-passthrough, tap-overlay, preview-media, captions-signal, speed-signal. The player shell renders **only** controls whose capability the adapter declares — this is the honesty mechanism that prevents promising interactions a source cannot honor (GESTURES.md §2).
- Boundary rules: every field Zod-validated; URLs must match the source's allowlisted host patterns (scheme https, host suffix match, no userinfo, no port other than 443); text passed through a character-normalization + length clamp; anything failing validation is dropped field-wise (never whole-batch), logged as normalization_drift for admin review.
- Circuit breaker: 5 consecutive failures or >30% failure over 50 calls → OPEN 10min → HALF-OPEN probe; state visible on admin Sources screen.

7. Taxonomy governance

- Local taxonomy is closed-world: only admin-created categories/tags exist; source terms map through mapping_rules (pattern → local id, priority, is_regex). Unmapped terms count as unmapped_hits surfaced in admin for weekly triage — this is how the catalog stays browse-quality without free-text taxonomy drift.
- Category requirements: slug unique, name 2–48 chars, description ≤280 chars, hero optional (brand-styled), sort_order, is_visible.
- Merge/split: admin actions are soft (alias table), never destructive; audit-logged; CDN tags purged.

8. Feature flags & settings (system_settings)

age_gate_copy_variant, discreet_thumbs_default, trending_weights, retention_days, source_enable:{slug}, maintenance_mode, suggest_enabled, infinite_scroll_enabled. All readable in admin Settings; all typed and validated; all changes audited. Kill-switches must act within one cache window (≤120s).

9. Observability & SLOs

- SLOs: API p95 < 300ms (list), < 120ms (suggest); page TTFB p95 < 400ms; pipeline success ≥ 99%/source/week; uptime 99.9%.
- Dashboards (admin): traffic (sessions, views), funnel (impression→open→quartile), search health (zero-result %, suggest p95), source health (sync success, breaker state, freshness lag hours), error budget burn.
- Alerts: breaker OPEN > 30min; sync failure 3 consecutive; error-rate > 2%/15min; takedown queue > 20 or oldest > 36h; disk/connections > 80%.
- Log schema: {ts, level, requestId, route, source?, code, ms} — no PII, no full IPs (truncated /24 IPv4, /48 IPv6), no query strings from watch pages in access logs.

10. Capacity model (initial)

- Assumptions: 50k videos, 100k events/day. Hot tables indexed (DATABASE.md §5); rollups keep aggregates O(days). Connection pool 10–20 (pooler). ISR + CDN absorb ≥ 90% of reads. Burst: rate limits protect DB (SECURITY.md §10); queue beacons client-side on 429 with jittered retry.

11. Risk register (FMEA-style)

#	Failure mode	Effect	Sev	Mitigation	Detection
R1	Source API retired/terms change	Catalog shrink	High	2+ approved sources; admin kill-switch; adapter isolation	sync failures, breaker
R2		Watch failure	Med		

#	Failure mode	Effect	Sev	Mitigation	Detection
	Source embed breaks for a video			capability-aware fallback chain E-04; degraded flag; prune	player_error events
R3	DB saturation	Site slowness	High	pooling, caching, rate limits, rollups	p95 alerts
R4	Takedown SLA breach	Legal exposure	High	queue alerts; hide-first workflow	admin queue age
R5	Age gate bypass via direct API	Compliance gap	High	middleware on /api + signed cookie	pen test + logs
R6	SEO deindex wave	Traffic loss	Med	diversified discovery; compliant markup	GSC-style monitoring
R7	CSP/iframe regression	Broken playback	Med	E2E iframe matrix; CSP report-only first	E2E + reports
R8	Placeholder code shipped	Brand/trust damage	High	CI gate G-7 (CI-CD.md §4)	CI

12. Roadmap (post-v1, [PROPOSED])

1. On-device history/favorites (F-19) · 2. Collections (F-20) · 3. PWA offline shell (F-21) · 4. Optional AV provider hook · 5. Seasonal token themes · 6. Additional sources via adapter SDK · 7. Localization (i18n) groundwork.

13. Traceability

Every mechanism here maps to: API endpoints (API.md §4–5), indexes (DATABASE.md §5), tests (TESTING.md §7 matrix rows T-*), and gates (CI-CD.md §4). A PR that changes §2–§8 must update the paired rows in those documents in the same commit (enforced by reviewer checklist, SOP.md §6).

PART 03

Architecture

Source document: ARCHITECTURE.md · v1.0.2 · 2026-09-03

SYCONIA — Technical Architecture

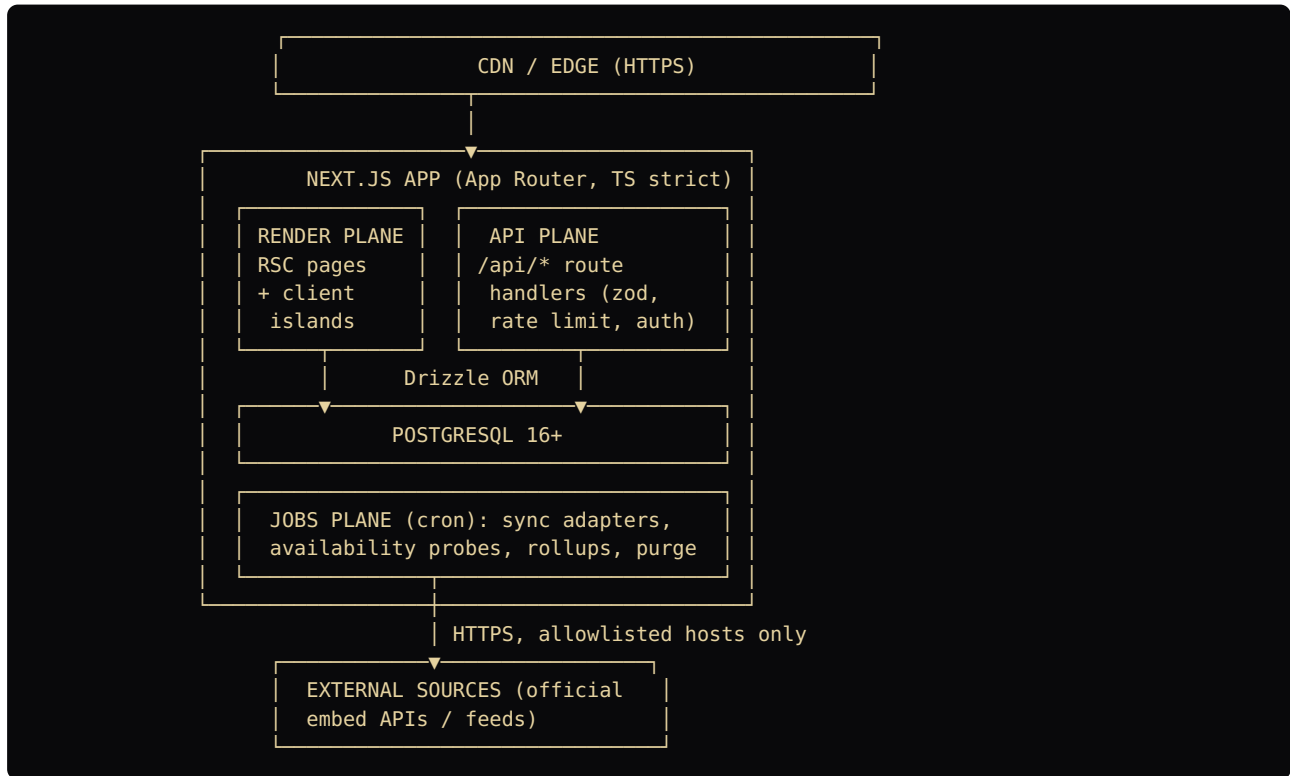
Field	Value
Document	ARCHITECTURE.md · v1.1.0 · 2026-09-03 (Android platform migration)
Status	Target architecture. No application code exists yet in this repository — every element below is [REQUIRED] unless marked [EXISTING] (brand assets) or [PROPOSED] .

0. Architecture style — client/server (v1.1.0)

SYCONIA v1.1.0 uses a **client/server architecture**:

- **Android client (Kotlin + Jetpack Compose + Material 3)** — the public product surface: discovery, search, taxonomy, watch experience. Clean Architecture layers (ui → domain → data), MVVM + Unidirectional Data Flow, Coroutines/Flow, Hilt DI, Navigation Compose. Playback via a hardened WebView embed shell (official source embeds only — D-013). No media storage, no accounts.
- **Backend service (Node.js + TypeScript)** — the retained server plane: public JSON API (API.md §4), admin web console + admin API (§5), minimal legal/contact/share web surface, ingestion jobs, PostgreSQL 16+ via Drizzle ORM. It hosts **no public discovery web UI** (retired with the web client).
- **PostgreSQL 16+** — backend-only. Never embedded in the app.





2. Technology stack (locked)

Client (Android) — locked

Layer	Choice	Rationale
Language	Kotlin (JVM; strategy: pin current stable at scaffold — D-016)	Coroutines-native, null-safety, Compose
UI	Jetpack Compose + Material 3 (BOM pinned at scaffold)	Declarative UI; M3 themed from SYCONIA tokens (DESIGN-SYSTEM §13) — no generic Material demo look
Architecture	Clean Architecture + MVVM/UDF	UI → ViewModel → UseCase → Repository → DataSources; domain free of Android UI deps
Async	Coroutines + Flow	Structured concurrency; StateFlow state exposure
DI	Hilt	Standard Android DI; compile-time graph validation
Navigation	Navigation Compose	Destinations, deep links (App Links), predictive back
Networking	Retrofit 2 + OkHttp + kotlinx-serialization (D-011)	Contract-first against API.md; TLS/network-security-config
Imaging	Coil (D-012)	Compose-native, allowlisted hosts
Playback	WebView embed shell (hardened, D-013)	Official source embeds are iframe/JS — WebView is the honest mechanism; capability chrome in Compose
Persistence	DataStore (prefs/session); Room only where a task justifies it with evidence (D-014)	No local media ever
Fonts	Bundled OFL Fraunces + Inter variable TTFs (from branding/fonts)	Licensing + brand typography; Compose font scaling
Min/target SDK	minSdk 26; targetSdk = Play-current at release (D-016)	Device coverage vs API level

Backend (service) — retained from v1.0.2

Layer	Choice	Rationale
Runtime	Node.js 20+ / TypeScript 5 (strict)	Retained server plane
Framework	Next.js (backend-only role) — API handlers, admin console, legal/contact web surface, share/OG pages; no public discovery web UI (D-010)	Preserves DATABASE/API/admin specs verbatim; least invention
Database / ORM	PostgreSQL 16+ · Drizzle ORM + drizzle-kit	Backend concern only — never in the app
Validation	Zod at every boundary	Unchanged
Jobs	Platform cron → job endpoints (registry §5)	Unchanged
Hosting	Vercel + Neon (primary) / Docker + VPS (alt)	DEPLOYMENT.md (B-003 unchanged)

Prohibited: React/web code in the Android client; Android framework imports in domain layer; `Composable` → `Retrofit/Room` calls; untyped escapes; hard-coded brand colors outside the theme; libraries added without a recorded decision.

3. Repository layout (target — v1.1.0)

```
/ # repo root – all project .md specs (this suite)
/branding/ # [EXISTING] official brand assets (copied from /uploads)
  syconia-primary-logo.png, syconia-symbol-only.png, syconia-monochrome-light.png,
  syconia-app-icon.png, syconia-favicon.png, syconia-brand-guidelines.pdf
/docs/ # DOCUMENTATION-INDEX.md, LEGAL-COMPLIANCE.md, generated PDF
/.skills/ui-ux-pro-max/ # [EXISTING] cloned UI/UX Pro Max design skill (dev aid; git-ignored)
/android # [REQUIRED] native Android client (Gradle multi-module)
  app/ # MainActivity, navigation graph, Hilt app, build variants
  core/common/ # result types, dispatchers, errors → E-state mapping
  core/designsystem/ # SyconiaTheme (M3 from tokens), typography, icons, components
  core/model/ # shared plain models (no framework deps)
  core/network/ # Retrofit/OkHttp/kotlinx-serialization, DTOs, API services
  core/security/ # network config, WebView hardening, secure prefs, keystore use
  core/ui/ # shared composables: states (loading/empty/error/offline), chrome
data/repository/ # repository implementations (remote + cache mappers)
data/local/ # DataStore (session/age/settings); Room ONLY if task-justified
domain/ # use cases + repository contracts + domain models (pure Kotlin)
  feature/home|search|categories|tags|watch|settings|legal # feature modules (UI+ViewModel)
/backend # [REQUIRED] retained server plane (Next.js backend-only role)
  /app/api/* # API.md handlers (public §4 + admin §5)
  /app/admin/* # admin web console (A-01..A-10, noindex, auth-guarded)
  /app/(legal)/* # legal/contact web + /watch/[slug] OG share pages
  /lib # db (drizzle), adapters/, auth/, rate-limit/, cache/, validation/
  /drizzle # migrations + schema
  /scripts # jobs registry, ci/no-placeholder-gate.sh
/branding, /docs, /.ai # unchanged
/.skills # git-ignored dev aid (unchanged)

Dependency direction (enforced by module graph + convention plugins + review):
`feature/* → core/* → domain ← data/*` – UI never touches Retrofit/Room/DTOs; domain has no Android UI i
```

4. Delivery strategy (v1.1.0) — API endpoints & web surfaces

Android client: all public surfaces are in-app destinations (Navigation Compose — SCREENS.md destination map); data arrives via the JSON API with repository-layer caching (TTL matrix PRD2 §5); UI states per ERROR-STATES taxonomy (loading/empty/error/offline) rendered in Compose. Age gate is a first-run in-app gate persisted in DataStore (FR-1 preserved client-side; server still enforces age affirmation for its web surfaces and API — SECURITY §6A).

Backend web surfaces (remaining): | Surface | Strategy | Cache | Reason | |---|---|---|---| | `/api/*` (API.md §4/§5) | HTTP handlers | 30s micro-cache where safe (PRD2 §5) | Data plane for app + admin | | `/legal/*`, `/about`, `/contact` | Static | CDN | Compliance surfaces (SEO §6 indexing decision unchanged) | | `/watch/[slug]` | Minimal OG/share-preview page (noindex; OG tags + "Open in app" + open-at-source) | tag `video:{id}` | Share URLs & OG previews for shared links (SEO §1 v1.1.0) | | `/admin/**` | Dynamic SSR, `noindex`, auth-guarded | private | Ops console |

Error handling: API error envelopes (API.md §3); app renders E-states; player failures isolated to the stage region (ERROR-STATES.md).

5. Backend/server architecture

- **API plane** = backend HTTP handlers under `/app/api` (Next.js in backend-only role — D-010), thin controllers: parse (Zod) → authorize (age cookie / admin session) → rate-limit → service (`/lib/services`) → respond. No business logic in handlers.
- **Services layer:** `catalogService` (list/get/related), `searchService`, `taxonomyService`, `ingestService`, `analyticsService`, `takedownService`, `adminService`. Pure functions over Drizzle — unit-testable without HTTP.
- **Jobs plane** (canonical registry — single source of truth): `scripts/jobs/*` invoked by platform cron (Vercel Cron / GitHub Actions / system crontab on VPS): `sync-sources` (per-source, isolated), `probe-availability`, `rollup-daily`, `purge-expired`, `refresh-trending`, `mapping-backfill` (on-demand after mapping-rule create/update — UX-FLOWS §9), `sitemap-refresh` (post-sync — CI-CD §7). All idempotent, all write `sync_runs / audit_log` rows, all kill-switchable via `system_settings`.
- **Backend middleware:** ① age-affirmation enforcement for web surfaces + API (PRD FR-1; Android app passes the affirmed-age attestation header — SECURITY §6A), ② security headers on web surfaces (SECURITY.md §4), ③ admin session redirect, ④ request-id injection. (No browser middleware exists in the Android client; its concerns map to in-app gates + network config.)

6. Adapter architecture (external sources)

- `/lib/adapters/<sourceSlug>/` — one module per approved source exporting: `manifest` (host allowlist, rate budget, capability set), `fetchPage(cursor)`, `fetchItem(id)`, `normalize(raw): NormalizedVideo`, `probe(item): availability`. Registry pattern: `adapters/index.ts` resolves slug → module; adding a source = code-reviewed module + admin enable (never runtime-registered).
- **SSRF hard seam:** the outbound HTTP client (single wrapper in `/lib/adapters/http.ts`) refuses any URL whose host is not in that adapter's manifest allowlist; DNS resolved and re-checked (against private CIDRs) before connect; timeouts 10s; response size cap 5MB; no redirects across hosts. (SECURITY.md §8.)
- Normalization per PRD2 §6; anything unknown is quarantined to `metadata jsonb`, never rendered unsanitized.
- **Embed rendering:** server components validate `embed.url` against the source manifest before emitting the iframe; attributes locked: `sandbox="allow-scripts allow-same-origin allow-presentation"`, `allowfullscreen`, `referrerpolicy="strict-origin-when-cross-origin"`, `loading="lazy"`. No third-party `<script>` ever loads on our origin.

7. Data flow — watch session

1. Watch destination renders from API data (repository cache) with reserved 16:9 stage → 2. WebView embed shell initializes per adapter capability set → 3. anonymous app session id (`sy_sid` equivalent: UUID v4 held in DataStore, never a cookie — same lifecycle) ties beacons → 4. quartile beacons POST `/api/events/watch` (batched; flushed on app backgrounding) → 5. rollups nightly. No PII anywhere in the chain. **`sy_sid` lifecycle (normative):** 30-day expiry from issuance, **no renewal** (a fresh `sy_sid` is minted after expiry — continuity of analytics is deliberately sacrificed for privacy); rotated immediately by the “Clear session traces” control (UX-FLOWS §14).

8. Caching architecture

Layered: CDN for web surfaces (tag purge via `revalidateTag`) → API micro-cache → Drizzle prepared statements → **app repository-layer cache (replaces TanStack Query; TTLs from PRD2 §5 applied client-side)**. TTLs and invalidation events: single source of truth in PRD2 §5. Invariant: **admin hide/takedown purges `video:{id}` + listing tags and is effective ≤60s end-to-end** (E2E-verified).

9. Rate limiting & abuse controls

Sliding-window counters (Upstash Redis on Vercel path; Postgres-backed fallback on VPS path) keyed by truncated IP + route class: `suggest` 60/min, `search` 30/min, `events` 120/min, `report` 5/hour, admin login 5/15min then lockout. 429 + `Retry-After`; client backs off with jitter. Full policy: SECURITY.md §10.

10. Validation strategy

Zod schemas shared by client forms and server handlers (single definition in `/lib/validation`). Defense in depth: HTML sanitize (server) for any source text rendered as HTML (we render as text nodes by default — React escaping — plus a strict sanitizer for the rare rich field), URL validation at adapter boundary and again at render boundary (double-check).

11. Logging, monitoring, error boundaries

- Structured JSON logs, one line per request: `{ts, level, requestId, route, status, ms, source?, code?}`. No PII, no full IPs (truncation rule PRD2 §9). Log levels: `error` (page failure, adapter hard failure), `warn` (breaker half-open, rate-limit hits, normalization drift), `info` (sync summaries), `debug` (dev only, stripped in prod).
- Uptime/health: `/api/health` (liveness: process) and `/api/ready` (readiness: DB ping + breaker states). External uptime monitor pings 60s **[REQUIRED]**; on-call alert channel documented in SOP.md §9.
- Client error reporting: Android uncaught-error handler → beacon to `/api/events/client-error` (throttled 5/session, no stack in URL, sampled; web surface keeps its equivalent onerror beacon).

12. Environment configuration

All configuration via environment variables validated at boot by `/lib/env.ts` (Zod; process exits on invalid — fail-closed):

Var	Purpose
<code>DATABASE_URL</code> , <code>DATABASE_POOL_URL</code>	Postgres (direct/pooled)
<code>AGE_SECRET</code> , <code>CURSOR_SECRET</code> , <code>SESSION_SECRET</code>	HMAC signing keys (age cookie, cursors, admin sessions)
<code>ADMIN_USERNAME</code> , <code>ADMIN_PASSWORD_HASH</code> (argon2)	Admin bootstrap credential
<code>CRON_SECRET</code>	Job endpoint auth
<code>SOURCE_<SLUG>_KEY</code>	Per-source API keys (only for sources requiring them)
<code>SITE_URL</code> , <code>SITE_NAME=SYCONIA</code>	Canonical/SEO
<code>LOG_LEVEL</code> , <code>RATE_LIMIT_*</code>	Ops tuning

No secret ever reaches client bundles (`server-only` imports; CI secret-scan gate G-6).

13. Deployment & CI/CD seams

Build pipeline, environments (preview/staging/prod), migration policy (drizzle-kit generate → review → apply in deploy), rollback: **CI-CD.md** (see §) and **DEPLOYMENT.md** (see §). HTTPS terminated at platform edge (HSTS enforced); no plaintext listener anywhere.

14. Build vs buy decisions

Need	Decision	Why
Search	Postgres tsvector + pg_trgm	No extra service at this catalog scale; upgrade path to external search engine noted [PROPOSED] >200k items
Rate limiting	Upstash Redis (Vercel) / PG table (VPS)	Managed simplicity vs self-host parity
Thumbnails proxy	backend image proxy with allowlist (<code>next/image</code> retained server-side; Android consumes proxied URLs via Coil)	Optimization + SSRF-safe, no media storage (caches transforms only — never source video/media)
Analytics	First-party pipeline (F-12)	Privacy posture + zero third-party script risk

15. Architectural invariants (audited per release)

1. No media file storage anywhere in the system (static analysis gate G-7 also greps for mp4/m3u8 writes).
2. No content renders before the in-app age gate (and no web surface serves content without age affirmation).
3. No third-party scripts on our origin; the app loads third-party scripts only inside the sandboxed player WebView (D-013).
4. All external egress via the allowlisted adapter client.
5. All admin mutations audited.
6. Tokens are the only color source.
7. No placeholder/mock data (G-7).
8. Every feature ships with its four states (loading/empty/error/offline).

PART 04

UX/UI System — Design System & Brand

Source document: DESIGN-SYSTEM.md · v1.0.2 · 2026-09-03

SYCONIA — Design System & Brand Implementation

Field	Value
Document	DESIGN-SYSTEM.md · v1.1.0 · 2026-09-03 (Android platform migration)
Branding source of truth	/branding/syconia-brand-guidelines.pdf (v1.0, Sept 2026) + /branding/ assets — [EXISTING]
Conflicts	PDF §5 "Corporate Decoy" rejected (PRD §17 C-2); unrelated business units out of scope (C-3)

1. Brand foundation (locked)

- **Name/spelling:** SYCONIA (all-caps in display contexts; body prose may use "SYCONIA" only — no alternate company names in UI).
- **Pronunciation:** sy-COHN-ee-uh. **Etymology:** syconium (Greek sykon, fig) — the enclosed bloom. **Concept:** The Inward Bloom. **Tagline:** The Beauty of the Inward Experience. **Secondary:** Where Intimacy Blooms.
- **Position:** Quiet Luxury + Cinematic Technology + Editorial Media. Forbidden: neon, tube-site clichés, generic SaaS, excessive gradients/glass/gold, clutter, vulgarity.
- **Logo geometry (from guidelines):** mirrored S-curves forming a symmetrical vessel/urn silhouette; refined negative space; central ostiole dot; minimal line work; mathematically mirrored Béziers.

2. Official asset inventory [EXISTING] (in /branding/, copied from /uploads/)

File	Role	Spec
syconia-primary-logo.png	Primary emblem + wordmark	2160×2148; Night Emerald bg, Ostiole Gold emblem, custom wordmark
syconia-symbol-only.png	Symbol-only	1635×1626; Obsidian bg; favicon/avatar/watermark basis
syconia-monochrome-light.png	Monochrome light	1635×1626; for light/Alabaster contexts & print
syconia-app-icon.png	App icon	512×512; golden border, 3D-luster monogram
syconia-favicon.png	Favicon	32×32 (line-weight thickened for legibility; 16px audit passed per guidelines)
syconia-brand-guidelines.pdf	Normative brand reference	6 pages

Watermark variant (128px, 6pt refined lines, 20% opacity) is derived from the symbol-only asset by scale + opacity only — no redraw. **Rule: never recreate the logo as hand-written CSS/SVG approximation while these assets exist; use official files (or exact exports of them).** Dark/light/mono variants map 1:1 to the files above.

3. Logo usage rules

- Never: stretch, rotate, recolor (beyond supplied variants), alter geometry, add shadows/neon, crop the wordmark, place on low-contrast backgrounds, combine with unapproved marks, shrink the full logo below 96px width (use symbol-only below that; favicon contexts always symbol-only).

- **Clear space:** $\geq 4\times$ the ostiole dot's diameter on all sides — enforced via layout tokens (`--space-logo-clear`).
- Placement: header (wordmark), drawer header (symbol + wordmark), favicon/app icon, player watermark bottom-right (never center, never over native controls), admin sidebar (symbol-only 28px), 404/error art (line-art rendering of symbol [REQUIRED]: a monochrome stroke export of the official asset, not a redraw).
- Loading indicator: the ostiole dot pulse (§10) — the dot is the brand's "alive" signal.

4. Color tokens (the only color source)

Brand primitives | Token | Hex | Role | |---|---|---| | `--color-brand-emerald` | `#012A21` | Primary backdrop band, hero washes, emerald surfaces | | `--color-brand-obsidian` | `#09090B` | App background (dark theme is the only theme) | | `--color-brand-gold` | `#C5A059` | Ostiole Gold — accents, active states, emblem line | | `--color-brand-champagne` | `#E6D3A0` | Champagne Gold — wordmark, secondary accents, focus ring | | `--color-brand-alabaster` | `#FAF9F6` | Primary text on dark, editorial highlights |

Semantic tokens (dark theme, canonical values) | Token | Value | Contrast on Obsidian | Use |
|---|---|---|---| | `--color-background` | `#09090B` | — | Page | | `--color-surface` | `#121214` (Obsidian +6% lightness, same hue) | — | Cards, table rows | | `--color-surface-elevated` | `#1A1A1E` | — | Modals, dropdowns, drawer | | `--color-surface-emerald` | `#012A21` | — | Hero bands, category cards | | `--color-text-primary` | `#FAF9F6` | 18.9:1 | Body/titles | | `--color-text-secondary` | `#B9B7B0` (Alabaster 72% on Obsidian) | 9.9:1 | Meta, captions | | `--color-text-tertiary` | `#8A8880` | 5.6:1 | Disabled, fine print ($\geq 14\text{px}$ only) | | `--color-border` | `#26262B` | — | Hairlines, dividers | | `--color-accent` | `#C5A059` | 8.1:1 | Active nav, links, highlights | | `--color-accent-strong` | `#E6D3A0` | 13.4:1 | Focus ring, emphasis text | | `--color-success` | `#4EC9A0` | 9.6:1 | Positive status (emerald-harmonized) | | `--color-warning` | `#E3B341` | 10.2:1 | Caution, SLA amber | | `--color-error` | `#F08A84` | 8.2:1 | Errors, destructive (soft coral; never pure red glow) | | `--color-focus` | `#E6D3A0` | — | 2px ring + 2px Obsidian offset | | `--color-scrim` | `rgba(9,9,11,0.56)` | — | Overlays | | `--color-glass` | `rgba(9,9,11,0.72)` | — | Header/drawer/player chrome (blur 12px) |

Rules: derived neutrals are lightness steps of the brand hues only — no new hues. Status colors are functional-only and visually harmonized (desaturated toward the palette). **All ratios above are computed per the WCAG relative-luminance formula against Obsidian #09090B and are re-verified by unit test (TESTING §6); they are normative for conformance.** Branding-source discrepancy **B-1 (documented per PRD §17 policy)**: the brand-guidelines PDF's own contrast figures — Ostiole Gold "3.2:1", Night Emerald "12.8:1", Champagne "2.1:1", Obsidian "19.5:1" (all vs white) — do not match computed WCAG values (2.46:1, 15.5:1, 1.48:1, 19.9:1 respectively). The guidelines remain the aesthetic authority; the computed math governs conformance. **Gold-as-text law (corrected)**: on Obsidian — the only v1 theme — Ostiole Gold computes 8.1:1 and Champagne 13.4:1, so **both pass WCAG AA for normal-size text on dark surfaces** and may be used for text accents, links, labels and emphasis; body copy nevertheless remains Alabaster/secondary as an editorial-hierarchy rule (brand restraint, not contrast necessity). On light surfaces (Alabaster print/letterhead contexts) gold fails (2.46:1 vs white) and is restricted to large or decorative use only. No other colors may appear anywhere; CI gate greps for raw hex outside the token file (CI-CD §4 G-8).

5. Typography

- **Primary (editorial serif): Fraunces** (SIL OFL 1.1) — licensed, bundled in the app (`branding/fonts/`, Compose `FontFamily`; variable axes pinned per D-008/AG-013). Chosen as the legally-safe embodiment of the guidelines' direction (which names proprietary Canela/Ogg as examples, never bundled).
- **Secondary (sans): Inter** (SIL OFL 1.1) — guidelines-shortlisted; bundled the same way. Font scaling: all type respects Android user font-scale (sp units; no fixed-px text); min body 16sp.
- **Scale (fluid, clamp between mobile/desktop)**: `display clamp(34px,6vw,64px)/1.05 serif · h1 clamp(26px,4vw,40px)/1.15 serif · h2 clamp(20px,3vw,28px)/1.25 serif · h3 18px/1.4 sans-semibold · body 16px/1.7 sans · meta 13px/1.5 sans · overline 12px/0.12em uppercase sans-medium · data 13px tabular-nums sans.`
- **Usage:** serif = hero headlines, section titles, editorial/legal page titles, major numbers; sans = everything else (nav, buttons, forms, tables, metadata, admin). Wordmark remains the official asset (not typeset).

- **Rules:** min body 16px; 70–80ch measure; no font weights below 400 for text; `text-wrap: balance` on headings.

6. Spacing, radii, elevation, borders

- **Spacing:** 8px base (`--space-1:4px` ... `--space-8:64px`; section rhythm 64/96/128). Grid gutter 16/24 by viewport.
- **Radii:** `--radius-sm:6px` (chips, inputs) · `--radius-md:10px` (cards) · `--radius-lg:16px` (modals/sheets) · `--radius-full` (pills, avatars). **No random rounded cards** — radius maps to component class, not mood.
- **Elevation (subtle depth, shadows only, no glows):** `--elevation-1: 0 1px 2px rgba(0,0,0,.5)` · `--elevation-2: 0 8px 24px rgba(0,0,0,.45)` (drawer/modal) · `--elevation-3: 0 16px 48px rgba(0,0,0,.55)` (fullscreen overlays). No colored shadows, no neon.
- **Glassmorphism (restrained — three surfaces only):** header on scroll, drawer, player chrome: `background: var(--color-glass); backdrop-filter: blur(12px)`. Nowhere else.
- **Borders:** 1px hairlines (`--color-border`); gold hairline reserved for active nav rail + focus ring only.

7. Iconography

UI icons (v1.1.0 — D-015): Material Symbols/Icons (Outlined, thin/regular weight class ≈1.5–2px stroke, 20/24dp default) for UI icons — the Android-continuous embodiment of the v1.0.2 lucide line-icon principle; tint follows `LocalContentColor`. `ICON-SYSTEM.md` maps every specced surface to a Material Symbol name. Brand symbols exclusively from `/branding/` (logo ≠ UI icon). No emoji, no Unicode-substitute icons, no mixed styles. Custom icons prohibited except line-art exports of the official emblem. Icon+label always for destructive/ambiguous actions.

8. Responsive/adaptive system (v1.1.0 — window-size classes; CSS breakpoints retired)

Mapping (documented transition): compact <600dp (was <480/768) → medium 600–839dp (was 768/1024) → expanded ≥840dp (was 1280/1440+); audits additionally at 320dp-class small phones and foldables/tablets postures. Layout laws: compact = single-column, bottom navigation pattern, symbol-only brand; medium = 2–3 column grids, rail navigation option; expanded = up to 6-column grids (SCREENS S-02), permanent nav rail, two-pane where specced. Invariants: touch targets ≥48dp (ACCESSIBILITY §7); wordmark swaps to symbol-only on compact; hero/media maintain 16:9; all motion transform/opacity only; no fixed pixel assumptions — dp/sp + window-size classes.

9. Motion specification (v1.1.0 — implemented with Compose animation APIs; spec values unchanged)

Transition	Spec
Page/route	opacity 0→1 (180ms, ease-out) + translateY 8→0
Drawer	translateX −100%→0, 260ms, <code>cubic-bezier(0.22,1,0.36,1)</code> ; scrim fade 200ms
Modal/sheet	scale .96→1 + fade (200ms); sheet translateY 100%→0 (280ms)
Card hover/focus	scale 1→1.02 (180ms) + veil opacity 0.4→0
Card→watch	shared-element thumbnail expand (280ms) — reduced-motion: fade
Skeleton shimmer	1.6s linear loop, translateX gradient sweep
Ostiole loader	dot scale 1→1.12 + opacity pulse, 1.2s alternating (the brand loading signal)
Toast	slide-up + fade in 200ms; auto-dismiss 4s (pause on hover/focus)
Stagger lists	children 40ms apart, cap 12 animated nodes
Reduced motion	

Transition	Spec
	<code>prefers-reduced-motion: reduce</code> → durations 0, transitions opacity-only ≤100ms, no shimmer/pulse loops, loader = static emblem

Performance law: animate **only** `transform/opacity`; no layout-triggering properties; no infinite animations besides loader (which pauses off-screen); `will-change` applied transiently.

10. Component inventory (design-system primitives — all inherit tokens)

Button (primary gold / secondary ghost / destructive / sizes sm-md-lg; loading state with ostiole dot) · IconButton · Input (with hint/error slots) · Select · Textarea · Checkbox · Radio · Switch · Badge (status/count/source) · Tooltip (focus+hover, 300ms delay, ESC-dismiss) · Dropdown · Modal · Drawer · BottomSheet (≤767px) · Tabs · Card · Avatar (admin) · Skeleton (text/card/grid/stage shapes) · Toast · Alert · Pagination (Load-more + numbered) · Breadcrumb · Navigation (header/drawer/footer) · SearchBar (combobox) · FilterBar · VideoCard · CategoryCard · TagChip · EmptyState · LoadingState · ErrorState · OfflineBanner · ProvenanceChip · DurationBadge · MetaRow · ShortcutsOverlay · PlayerShell (stage/chrome/watermark/poster/failure ladder) · AdminTable (sort/pagination/row-actions) · KpiCard · StateChip · ConfirmDialog · AuditDiff. Each primitive spec'd with: anatomy, states (default/hover/active/focus/disabled/loading), sizes, a11y contract, token mapping, and Storybook entry [REQUIRED] (TESTING §5).

11. Imagery direction

Cinematic composition, deep shadows, controlled highlights, sophisticated framing, restrained treatment. Content thumbnails are **source-provided media** delivered through the image proxy (never authored, never explicit-branded UI art). UI illustration = line-art emblem + typographic compositions only. Category hero defaults: token-palette abstract (emerald/obsidian gradient meshes — generated locally, deterministic, no external art).

12. Voice & copy (samples are tone, not content)

- Empty state: “The gallery is being curated.” (serif) + one sans action line.
- 404: “Lost in the bloom.” / “The page you seek doesn’t exist — or has drifted beyond the garden.”
- Offline: “You’re offline. Previously visited pages remain available.”
- Buttons: specific verbs (“Enter”, “Watch”, “Retry”, “Report”, “Copy link”). No exclamation marks, no clickbait, no vulgar phrasing, no corporate filler.
- Microcopy ≤ 8 words for actions; explanations ≤ 2 sentences.

13. Theming architecture (v1.1.0 — Material 3)

Tokens live in `branding/design-tokens.json` (source of truth) → compiled into **one Compose theme** (`core/designsystem/SyconiaTheme`): SYCONIA tokens → M3 `ColorScheme` (dark-only v1: background Obsidian, surface #121214, surfaceVariant/elevated #1A1A1E, primary Ostiole Gold, secondary Champagne, onPrimary/onSecondary Obsidian or Alabaster per computed contrast, error #F08A84...), `Typography` (Fraunces/Inter mapped to M3 slots per §5 scale), `Shapes` (6/10/16dp per §6), dimensions/spacing scale, and component defaults — all overriding generic Material demo styling. Themes = token value swaps only; `theme-night` (default/only v1); seasonal/light remain [PROPOSED]. The backend admin console consumes the same token values via its CSS layer. No other theming hooks exist in v1.

14. Brand quality gate (audit before any release — PRE-RELEASE §9)

☐ Logo fidelity (official assets only) ☐ clear-space rule honored ☐ no logo below 96px (wordmark) ☐ brand-color fidelity (raw hex only in tokens file) ☐ typography consistency (2 families only) ☐ gold-as-accent law ☐ component/token compliance ☐ favicon/app-icon correct ☐ glass limited to 3 surfaces ☐ motion transform/opacity only ☐ reduced-motion honored ☐ loading ostiole present ☐ empty/error states branded ☐ no SaaS-generic nor tube-site styling anywhere ☐ watermark placement correct ☐ SEO uses official spelling.

PART 05

UX/UI System — Gestures & Interaction

Source document: GESTURES.md · v1.0.2 · 2026-09-03

SYCONIA — Gesture & Interaction Specification (v1.1.0 — Compose/touch semantics)

Platform mapping: pointer events → Compose `pointerInput` detect APIs; mouse/touch rows unify as touch unless a pointer-type distinction matters; keyboard shortcuts (§5) apply to external/hardware keyboards* (tablets, Chromebooks where supported) — all functionality remains touch-reachable (§7 law); web `touch-action` rules → Compose gesture exclusion/system gesture exclusion zones at screen edges (never intercept Android system back/home gestures). Player WebView gestures: delegated capabilities only (capability model unchanged); double-tap seek etc. remain `player_api`-gated. Content unchanged in intent and constraints.

Field	Value
Document	GESTURES.md · v1.1.0 · 2026-09-03 (Android platform migration) · [REQUIRED] target behavior

1. Guiding principles

- Honesty about embeds.** Playback runs inside third-party official embed players (iframe). SYCONIA controls the shell unconditionally, and controls playback only when the adapter's `capabilitySet` declares delegation (PRD2 §6). The UI never renders a control a source cannot honor.
- No media manipulation.** Gestures translate to official player APIs or shell actions only; SYCONIA never intercepts, re-hosts, or scripts embed internals.
- Privacy-first defaults.** Muted-only autoplay, discreet thumbnails, no hover previews when `saveData` / reduced-motion is on.
- Platform parity with documented divergence.** iOS Safari restrictions are listed, not hidden (§7).

2. Capability model (normative)

Capability flag	Unlocks
<code>fullscreen-delegation</code>	Shell fullscreen via Fullscreen API wrapping the stage
<code>tap-overlay</code>	Tap-to-toggle overlay chrome on the stage
<code>keyboard-passthrough</code>	Player-native keyboard shortcuts remain active while stage focused
<code>preview-media</code>	Hover/press animated previews in cards (source-provided media only)
<code>captions-signal</code>	Shell shows a captions availability hint linking to native control
<code>speed-signal</code>	Shell shows speed availability hint linking to native control

Default (any source, always ours): fullscreen toggle, theater mode, report, share, open-at-source, watermark, loading/error states. Source players always keep their own native controls visible within the iframe.

3. Video-player touch interactions

Gesture	Result	Condition
Single tap on stage		<code>tap-overlay</code> or native

Gesture	Result	Condition
	Toggle source-player controls (native) + our corner overlay	
Double-tap left/right third	Seek −10s / +10s with ripple indicator	player_api sources only; otherwise no-op (native player handles its own)
Double-tap center	Toggle play/pause	same
Vertical drag (stage, right half)	Volume slider overlay (native when delegated only)	player_api
Horizontal drag on stage	Scrub preview with time bubble (native when delegated only)	player_api
Two-finger horizontal swipe	Next/prev related item — disabled by default (accidental-loss risk); enable in drawer settings [PROPOSED]	—
Swipe down (in fullscreen)	Exit fullscreen (120ms)	shell
Swipe down (mini-player, mobile)	Dismiss mini-player	[PROPOSED]
Long-press (600ms)	2× speed while held, with chip “2×” (native when delegated only)	player_api
Pinch	No action (intentionally disabled to protect playback)	—
Edge swipe right (mobile)	History back — only from left 24px edge and never from the stage	global

Touch rules: 44×44 minimum targets; 8px movement threshold before a gesture counts (tap vs swipe); gestures never fire while a modal is open; touch-action correctly set per region (stage: none; rails: pan-x; pages: auto).

4. Mouse / pointer interactions

Input	Result
Hover card	Veil lifts, scale 1.02 (180ms), optional preview (capability + fine pointer + saveData=false)
Click card	Open watch
Click stage	Native player behavior + our overlay
Double-click stage	Fullscreen (shell)
Hover overlay buttons	Gold underline grow (120ms)
Wheel on rails	Horizontal translate (desktop convenience, 64px/tick, momentum-free)
Right-click	Native context menu allowed (no blocking); watermark is non-removable part of stage backdrop, not the media
Text selection	Allowed on metadata; disabled on stage only
Cursor	pointer on affordances; hidden after 2s idle in fullscreen

5. Keyboard shortcuts (global + player)

Key	Context	Action
/	anywhere (public)	Focus search

Key	Context	Action
<code>?</code>	anywhere	Shortcuts overlay (this table, contextual)
<code>ESC</code>	any overlay	Close topmost (drawer/modal/search sheet); in fullscreen exit FS first
<code>Tab / Shift+Tab</code>	everywhere	Cycle focus (visual order, visible ring)
<code>Enter / Space</code>	focused card/button	Activate (Space never scrolls when target is a control)
<code>F</code>	watch	Toggle fullscreen (shell)
<code>T</code>	watch	Toggle theater mode
<code>M</code>	watch	Mute toggle — delegated sources only; otherwise focuses the native player region
<code>←/→</code> (5s), <code>J/L</code> (10s), <code>K/Space</code> play-pause, <code>0–9</code> seek-to-%, <code>↑/↓</code> volume, <code>C</code> captions, <code>Shift+.</code> / <code>Shift+,</code> speed	watch	Deferred to source player (<code>keyboard-passthrough</code>): our shell documents and yields these to the embed; where passthrough is blocked by the iframe, the shortcuts overlay marks them “source player” — no emulation is faked
<code>[/]</code>	listings	Move between filter chips (roving focus)

Rules: shortcuts never fire while typing in a field; all are discoverable via `?` overlay; player-region shortcuts require stage focus (outlined on focus); arrow-key scrolling of rail groups when group focused.

6. Playback state behaviors

- **Play/pause:** user-initiated always; embed-native. Shell play affordance (poster) triggers first init.
- **Seek/scrub:** native control bar inside embed; delegated sources get our overlay seek (\$3).
- **Volume/mute:** native; delegated sources mirror state into shell icon (if signal provided).
- **Fullscreen:** shell-level Fullscreen API on the stage wrapper (works even for pure iframes); Safari `<video>`-native webkit fallback belongs to the source player — documented divergence (\$7).
- **Playback speed / captions:** where supported by the source player's own UI; shell surfaces a hint chip only (`speed-signal` / `captions-signal`). No fake controls.
- **Buffering:** embed shows its native spinner; our ostiole pulse shows before embed init and during shell-level retries; buffering $\geq 8s$ offers a gentle “Still loading — Open at source?” chip (dismissable).
- **Autoplay policy:** never on page load. After first user play in a session, subsequent watch-page navigations may autoplay muted (sessionStorage flag) — never unmuted, never before interaction; disabled when `saveData` is true.
- **Orientation (mobile):** rotating device while stage active: if fullscreen already on $\rightarrow$ OS handles; else show one-time chip “Rotate for fullscreen” (tappable, rememberable). No forced landscape lock (respect user control).
- **Mobile browser behavior:** iOS: fullscreen = source-player behavior (webkit) — shell theater mode offered as alternative; inline playback per source policy. Android Chrome: shell fullscreen works; media session notification belongs to source player. Backgrounding the tab pauses embeds natively; we also unload embeds after 30min backgrounded (battery/discretion).
- **Source failure:** E-07 ladder (Retry $\rightarrow$ Alternate embed variant if provided $\rightarrow$ Open at source $\rightarrow$ Report); `player_error` beacon; item flagged `degraded` for probe job.
- **Fallback source:** some sources expose multiple embed endpoints; adapter may supply an ordered `embedFallbacks[]`; the ladder tries each once (8s timeout), then resolves to failure overlay — total failure UX never exceeds 3 user-visible steps.
- **Unsupported/geo-blocked source:** `probe` marks `geo`; UI shows “This selection isn’t available in your region” + Related (no external workaround links — deliberate policy).

- **Privacy/discretion in player:** watermark 128px @20% opacity bottom-right (brand asset, `aria-hidden`); neutral clipboard/title behaviors (UX-FLOWS §14); no history API writes beyond our routes; referrer hygiene on all external links.

6.9 Player state machine (normative)

State	Meaning	UI
POSTER	stage rendered, embed not initialized	poster + play affordance (our chrome)
INITIALIZING	user tapped play; embed loading	ostiole pulse; timeout budget 8s
READY	embed loaded, capable controls bound	capability chrome visible
PLAYING / PAUSED / BUFFERING	native embed states (mirrored only when capability signal exists)	native + our corner overlay
ENDED	playback finished	native end state; related rail emphasis
SOURCE_ERROR	embed error/timeout after init	E-07 ladder
GEO_BLOCKED	probe/ geo	E-08
REMOVED	item hidden/taken down while watching	E-06 notice + exits
UNAUTHORIZED_SOURCE	source disabled/breaker OPEN mid-session	E-18 chip + stage to E-07 ladder
OFFLINE	network lost during session	E-05 inline in stage; embed pauses natively

Valid transitions: POSTER→INITIALIZING→READY→{PLAYING≠PAUSED, BUFFERING≠READY, →ENDED} · READY/PLAYING/PAUSED/BUFFERING→{SOURCE_ERROR, GEO_BLOCKED, REMOVED, UNAUTHORIZED_SOURCE, OFFLINE} · any error state →INITIALIZING (Retry) or →POSTER (alternate variant/back) · OFFLINE→READY (auto on online + retry). **Invalid transitions (must be prevented in code):** POSTER→{PLAYING, ENDED, any error} (no playback claims before init) · INITIALIZING→ENDED · ENDED→PLAYING (replay must pass →READY) · any error state →PLAYING/PAUSED directly (healing only via INITIALIZING) · POSTER→POSTER re-entry without route change. No state may render fabricated playback (FR-10); every error state offers ≥2 exits (E-07 ladder).

7. Documented platform divergences (honest limitations)

Platform	Divergence
iOS Safari	No Fullscreen API on iframes → theater mode substitute; native player controls govern; volume gestures n/a (hardware)
iOS Safari	100vh instability → stage uses dvh with fallback; tested at S-02/S-07
Android Chrome	Media-session notification from source player; back-button exits FS before route (history guard)
Firefox desktop	Picture-in-Picture belongs to source player; not re-implemented
Safari desktop	Wheel-volume n/a; ? : overlay notes it

8. Non-player gestures (site-wide)

- Pull-to-refresh on listings [PROPOSED] (default off to protect scroll anchors).
- Swipe-dismiss: toasts, filter chips, mobile bottom sheets (downward, 25% threshold).
- Long-press card (touch): context sheet (Copy link / Report / Hide locally [PROPOSED]).
- Drawer: edge-swipe open (rightward from left 24px), swipe-left close, scrim tap close.
- Overscroll: chained at document level only; rails use `overscroll-behavior: contain`.
- Haptics: **none in v1** — browser vibration APIs are inconsistently implemented and untrusted for this context; no gesture triggers vibration. (Deliberate policy, not an omission.)

9. Player interaction acceptance matrix (test basis — TESTING §7 T-40...T-48)

Every capability flag × {tap, double-tap, drag, long-press, keyboard F/T/ESC, fullscreen enter/exit, buffering chip, failure ladder, geo block, autoplay policy, rotate chip, background unload} × {Chromium, Firefox, iOS Safari (manual/BrowserStack), Android Chrome} — expected results per §3-§7; divergence rows assert the documented divergence, not an idealized one.

10. Formal state-machine appendix (normative)

A. Age gate — states: `UNVERIFIED` (any route, content withheld server-side) → `VERIFIED` (Enter; cookie 12 months) | `EXITED` (Leave site → external neutral page; terminal — no return transition in-session).

`VERIFIED`→`UNVERIFIED` only via cookie expiry/deletion/Clear-session-traces. Invalid: `UNVERIFIED`→ anything content-bearing; `EXITED`→`VERIFIED` without a fresh visit.

B. Takedown (`takedown_requests.status`) — `new` → `under_review` → `actioned` | `rejected` | `escalated`; `escalated` → `under_review` | `actioned`; auto-hide on arrival applies to reasons {copyright, underage, nc} while remaining `new` (visibility is a separate videos flag, not a status). Invalid: `actioned`|`rejected` → any (terminal; re-open = new request referencing the record); `new` → `actioned` without a review pass is blocked by the UI contract (A-08 resolve modal requires an action + notes).

C. External source / circuit breaker — per source: `disabled` → `enabled` (requires `terms_verified_at`, API §5.1 gate) · breaker: `closed` → `open` (5 consecutive failures or >30% of 50) → `half_open` (10 min) → `closed` (probe success) | `open` (probe failure, timer resets). `enabled` ↔ `disabled` is orthogonal to breaker state (disabling an open breaker keeps its state until the re-enable probe). Invalid: `half_open` → `closed` without a probe; `disabled` → `open` (no traffic flows while disabled).

D. Network (client) — `online` ⇌ `offline` (`online/offline` events) · `online+queue` → `flushing` → `online` (beacon/mutation queue drains with jitter, cap 50, drop-oldest) · any region render state may carry the offline banner independently. Invalid: `offline` → `flushing` (never flush while offline); auto `online` recovery never replays route navigation (visible-region refresh + toast only).

PART 06

Screen Specifications

Source document: SCREENS.md · v1.0.2 · 2026-09-03

SYCONIA — Screen Specifications (v1.1.0 — destinations)

Platform mapping: every former URL route is an **Android destination** in the Navigation Compose graph; the URL patterns survive as **App Links/deep-link patterns** (share URLs continue to resolve on the backend's minimal web surface). **Route:** lines below read as **Destination (+deep-link pattern):**. Viewport references map to window-size classes (DESIGN-SYSTEM §8). Chrome semantics: header→top bar, drawer→modal navigation drawer, back arrow→system back (predictive back enabled), footer→drawer/legal section + settings screen. Product behavior per screen is unchanged.

Field	Value
Document	SCREENS.md · v1.1.0 · 2026-09-03 (Android platform migration)
Status	All screens [REQUIRED] (no UI code exists yet). Layouts reference DESIGN-SYSTEM.md tokens; flows reference UX-FLOWS.md; states reference ERROR-STATES.md.
Viewports	Mobile 320–479 · Phablet 480–767 · Tablet 768–1023 · Desktop 1024–1535 · Wide ≥1536 (design tokens scale fluidly; all layouts are mobile-first)

Standard per-screen guarantees (apply to every screen below unless overridden): top-left **back arrow** on any non-root page (behavior: `history.back()` when an in-app entry exists, else route to the logical parent, else Home; `aria-label="Back"`; hidden on Home); **three-line hamburger** always visible left of (or replacing) the back arrow, opening the global drawer (S-00); header search present on every public screen; every async region implements the four states (skeleton / empty / error / offline) per ERROR-STATES.md; every interactive element ≥44×44px, visible focus ring (`--color-focus`), and full keyboard operation; page transitions: fade 180ms + 8px slide-up (reduced-motion: instant); toasts bottom-center (mobile) / bottom-right (desktop), 4s, dismissible, `role="status"`.

S-00 — Global chrome (header, drawer, footer, overlays)

- **URL/Route:** every public route (`(public)` layout).
- **Purpose:** orientation, navigation, search access, brand presence, legal footing.
- **Desktop layout:** sticky header 64px: [hamburger | back-arrow*] [wordmark] ... [search field 320px] [theme-neutral icons: shortcuts “?”]. Footer 3 columns (Discover links / Legal links / brand statement + “Crafted by Roshan” + © 2026 SYCONIA).
- **Tablet layout:** header 60px, search collapses to icon → expands overlay field.
- **Mobile layout:** header 56px: [hamburger] [back-arrow*] [symbol-only emblem centered] [search icon]. Footer single column, accorded legal.
- **Hamburger menu:** three-line icon (2px strokes, 18×14px, gold on hover) → drawer slides from left (width 88vw max 320px, 260ms cubic-bezier(0.22,1,0.36,1)), Obsidian @96% + 12px blur (the only glass surface besides player chrome), scrim 40%. Contents (order): Search field → DISCOVER (Home, Trending, New, Rising) → BROWSE (Categories >, Tags >, expandable groups) → INFORMATION (About, Contact) → LEGAL (Terms, Privacy, DMCA, 2257, Cookies) → footer: session controls (Discreet thumbnails toggle, Clear session traces) + credit. Active route highlighted (Ostiole Gold 2px left rail). Close: X button, scrim tap, ESC, swipe-left; focus returns to hamburger.
- **Navigation hierarchy:** 3 levels max: drawer → listing → detail; watch page is always depth-2 from something.

- **Notifications:** global toast region + drawer badge dot when a `[PROPOSED]` system notice exists (v1: only error/offline toasts).
- **Keyboard:** `/` focuses search; `?` opens shortcuts overlay; ESC closes topmost layer; tab order visual order; skip-link “Skip to content” first.
- **Touch:** swipe-right from left edge (24px) opens drawer on mobile; swipe-left closes; drawer items 48px tall.
- **Transitions:** drawer slide; header background opacity 72%→96% on scroll >8px; hide-on-scroll-down/show-on-up on mobile (8px threshold, never while drawer/search open).
- **Accessibility:** all landmarks (`header/nav/main/footer`), `aria-current="page"` on active nav, drawer `role="dialog" aria-modal`, focus trap, `inert` background.
- **Offline:** header shows persistent slim banner “Offline — showing cached pages” (E-05).

S-01 — Age Gate

- **URL/Route:** interstitial overlay over target route (no separate URL; deep-link preserved).
- **Purpose:** 18+ legal access control (PRD F-01); first brand impression.
- **Layouts (all viewports — identical centered composition):** Obsidian full-screen; symbol-only emblem (breathing 4s scale 1→1.03 loop — disabled under reduced-motion); serif headline “A private world awaits.”; sub-copy “You must be 18 or older to enter SYCONIA.”; body “By entering you confirm your age and agree to our Terms.”; primary button **I am 18 or older — Enter** (Ostiole Gold fill, Obsidian text) / secondary **Leave site** (ghost) / text link Terms of Service.
- **Behavior:** server-rendered when age cookie absent — content never ships. Enter → set cookie+localStorage, fade-out 240ms, reveal app, route intact. Leave → fixed neutral redirect target `https://www.wikipedia.org` (configurable via `AGE_LEAVE_URL`; must be a non-adult, neutral page — never an adult or competitor property). Terms link opens in new tab (the only pre-gate action).
- **Keyboard:** focus moves into dialog on load; Enter key activates focused control; trap enforced.
- **Touch:** large targets (56px buttons), no hover dependencies.
- **Error:** none possible client-side (static); Terms load failure → inline “Open Terms in a new tab” retry link.
- **Responsive breakpoints:** emblem `clamp(96px, 18vw, 160px)`; buttons full-width $\leq 420\text{px}$, inline $\geq 421\text{px}$.
- **A11y:** `role="alertdialog"` labelled “Age verification”; contrast: Alabaster text on Obsidian (19.5:1), button Obsidian-on-Gold ($\geq 4.5:1$ verified in DESIGN-SYSTEM §5).

S-02 — Home / Discovery

- **URL/Route:** `/`
- **Purpose:** storefront; instant cinematic discovery (PRD F-03).
- **Desktop layout:** 12-col grid, max-w 1440. Hero: editorial split — left: serif headline + featured meta + CTA “Watch”; right: featured thumbnail (blurred until hover). Below: full-width rails as rows of 6 cards; rail header (serif 20px + “View all →”).
- **Tablet:** hero stacks (media above, text below); rails 4-across, horizontally scrollable with edge-fade.
- **Mobile:** hero 16:9 media with bottom gradient + overlay text; rails: horizontal scroll-snap rows of 1.4-card-width cards; pull-to-refresh `[PROPOSED]`.
- **Cards/grids:** VideoCard (DESIGN-SYSTEM §13): 16:9 thumb, duration badge bottom-right (Obsidian 80% pill, Alabaster mono digits), title 2-line clamp, source badge, relative time. Grid columns: 2/3/4/5/6 per viewport class. Hover (fine pointer): scale 1.02, veil lifts, title underlines; focus-visible: same via keyboard.
- **Buttons/menus:** rail overflow menu (`⋮`): “Hide this video” (local-only hide list `[PROPOSED]`), “Copy link”, “Report” — bottom sheet on mobile, dropdown on desktop.
- **Notifications:** toast on copy-link success.
- **Sorting:** rails have fixed semantics (PRD2 §2.2); “View all” targets pre-sorted listings.
- **Pagination:** rails are bounded (24 items); “View all” pages use infinite scroll + Load more (S-03 pattern).
- **Loading:** hero + first rail SSR; below-fold rails stream with exact-geometry skeletons (card-shaped, shimmer 1.6s, staggered reveal 40ms/card).

- **Empty (cold catalog):** editorial empty state E-02: emblem line-art, serif “The gallery is being curated.”, CTA to Categories.
- **Error:** rail-level retry chip; page-level E-01 after 2 failed retries.
- **Offline:** cached shell + banner; rails show last-good data with stale timestamp.
- **Keyboard:** cards tabbable in DOM order; rail group arrow-key scroll; Enter opens.
- **Touch:** horizontal swipe rails with scroll-snap; tap opens (first tap on veiled thumb lifts veil only on `discreet_thumbs=on`).
- **Transitions:** card→watch: shared-element thumbnail expand (motion layout, 280ms; reduced-motion: fade).
- **Analytics:** `rail_impression`, `card_open{rail}`, hero CTA.

S-03 — Search Results

- **URL/Route:** `/search?q=&cat=&tag=&src=&dur=&sort=`
- **Purpose:** intent → content matching (PRD F-04).
- **Header/search:** sticky sub-header with the query in an editable field (re-submit updates URL); result count + active filter chips (removable).
- **Desktop layout:** left FilterBar (240px): Category (list, counts), Tags (top 20 + search-in-tags), Source, Duration buckets; main: sort bar (Relevance/Newest/Longest/Most watched — segmented control) + 4-col grid.
- **Tablet:** FilterBar collapses to “Filters (n)” button → right sheet.
- **Mobile:** full-screen filter bottom sheet; grid 2-col; sort bar horizontal-scroll chips.
- **Autocomplete (in header field, all screens):** combobox dropdown — grouped: Queries (trending/typed), Titles (thumb+title), Categories, Tags (chips); 8 max; keyboard navigable; submit on Enter/select.
- **Pagination:** infinite scroll + Load more (PRD2 §2.1), cursor-based, announcements “12 more videos loaded”.
- **Loading:** field keeps text; grid skeleton 12 cards; filters reflect instantly (client state) with server confirmation.
- **Empty:** E-03 — “Nothing matched ‘{q}’.” + relaxed-match attempt results if any + Trending rail + “Try:” suggestion chips.
- **Error:** E-04 pattern with query preserved in field.
- **Offline:** banner + cached results if any.
- **Keyboard:** `/` focuses search from anywhere; ESC clears; results grid arrow-key 2D traversal `[PROPOSED]` (v1: tab order).
- **Touch:** pull-down on grid focuses search field; chips swipe-dismissible.
- **Transitions:** dropdown 140ms fade+slide 4px; filter apply → grid cross-fade 200ms (no full-page flash).
- **URL contract:** full state round-trip; back/forward restores state + scroll (UX-FLOWS §4).

S-04 — Categories Index

- **URL/Route:** `/categories`
- **Purpose:** browse the curated taxonomy.
- **Desktop:** 4-col editorial cards: brand-styled hero (optional per category; default = generated Obsidian/emerald abstract from token palette — never explicit art), serif category name, one-line description, video count.
- **Tablet:** 3-col → 2-col. **Mobile:** 2-col → 1-col list with 64px thumbs.
- **Search:** header search (categories suggested inline when name matches).
- **Sorting:** admin-defined `sort_order` (curated, not user-sorted); A-Z toggle available.
- **States:** skeleton grid; empty (no visible categories) → E-02 variant; error/offline standards.
- **Keyboard/touch/all transitions:** whole card is one link; staggered fade-in; counts in `aria-label` (“Drama — 1,240 videos”).
- **Back arrow:** → Home (or history).

S-05 — Category Detail

- **URL/Route:** `/categories/[slug]`
- **Purpose:** focused listing within one taxonomy node.
- **Layouts:** hero band (name, description, count, curated hero) + grid identical to S-03 main area; FilterBar reduced to Duration + Sort (category fixed).
- **Sorting:** full sort set (PRD2 §2.2). **Pagination:** infinite + Load more.
- **Sub-navigation:** breadcrumb Home / Categories / {Name} (aria-labelled, schema.org BreadcrumbList).
- **States:** as S-03; cold-empty category → E-02 variant “This gallery is being curated — explore Trending”; **filtered-empty** (duration filter/sort yields zero while the category has items) → E-02b “No videos match the current filters” + **Clear filters** (filters are never auto-relaxed — PRD2 §2.8).
- **Keyboard/touch:** grid tab order; pull-to-refresh [PROPOSED].
- **Back arrow:** → `/categories` (or history).
- **Transitions:** shared hero from index card [PROPOSED]; standard otherwise.

S-06 — Tags (index + detail)

- **URL/Route:** `/tags`, `/tags/[slug]`
- **Purpose:** long-tail discovery; SEO surface.
- **Index layout:** search-in-tags field (server-backed: GET `/api/tags?q=` prefix filter, API §4.6 — not a client-only filter) + featured tags (pill row) + alphabetical section list with counts (desktop 3-col, mobile 1-col with sticky letter headers); list is cursor-paginated (48/page) with letter-section headers computed client-side per loaded page.
- **Detail layout:** compact header (tag chip + count) + S-03 grid minus category filter; related-tags row (co-occurrence top-8).
- **Sorting/Pagination/States:** as S-05. **Back arrow:** index → Home; detail → `/tags`.
- **Keyboard:** letters jump sections (typeahead on list).

S-07 — Watch / Player

- **URL/Route:** `/watch/[slug]`
- **Purpose:** the core experience (PRD F-07/F-08; full interaction model in GESTURES.md).
- **Desktop layout:** player stage centered (max-w 1280, 16:9, letterboxed, Obsidian matte, SYCONIA watermark 128px @20% bottom-right); below: two-column — left: title block, meta row, tags, description; right (rail): Related (vertical list 6 + “More”); theater mode collapses to single column with stage at 92vw.
- **Tablet:** single column; related below metadata.
- **Mobile:** stage sticky-top on scroll-down (collapsed 16:9 mini-player [PROPOSED]); metadata stacked; related horizontal snap row.
- **Stage chrome (ours):** before-init poster (thumb + centered Ostiole play affordance); loading ostiole pulse; capability-driven control bar **only if** adapter declares `player_api` delegation — otherwise native source controls + our corner overlay: [fullscreen] [theater] [open-at-source] [report] [watermark].
- **Meta row:** provenance chip “Provided by {source}” (→ source page, `nofollow noopener`), publish date, view count (approx, formatted), **Report** button (opens S-07R modal: reason select, details textarea, optional email, **hidden honeypot field website** — visually hidden, `tabindex=-1`, `aria-hidden`; if filled, the submission is silently accepted-and-dropped server-side, SECURITY §10 — submit → toast “Reference TKN-XXXXXX recorded”).
- **Tags:** chips → tag detail. **Description:** collapsed 3 lines + “More”.
- **Related:** same category → same tags → trending fill (PRD2); card = compact VideoCard.
- **Menus/buttons:** share (copy link, neutral preview note), report, open-at-source (external icon).
- **Notifications:** player failure overlay E-07 ladder (Retry → Alternate → Open at source → Report); source-wide degradation chip.
- **Loading:** stage reserves exact 16:9 (zero CLS); metadata skeletons (title bar 60%, meta row, 3 tag chips).

- **Empty:** video hidden/unavailable → E-06 (404 status for hidden/removed; 200 for temporarily unavailable — API.md §4.2) with related suggestions (never a dead end).
- **Offline:** stage disabled with E-05 inline + cached metadata.
- **Keyboard:** F fullscreen · T theater · ESC exit fullscreen/close overlays · M mute if delegated · player-native keys otherwise (GESTURES §5).
- **Touch:** tap stage toggles controls (source player) / our overlay buttons 44px; double-tap far-left/right seek ±10s if delegated; swipe-down on fullscreen exits (GESTURES §3).
- **Orientation:** rotating to landscape in fullscreen-eligible state offers fullscreen (system-backed; iOS falls back to source player behavior — documented divergence, GESTURES §7).
- **Transitions:** entrance: stage fade + metadata slide-up 240ms; related cards stagger.
- **Theater persistence:** theater mode persists for the browser session only (`sessionStorage` key `sy_theater`); never persisted across sessions or synced to the URL.
- **No-JS fallback (`<noscript>` , FR-9):** metadata (title, tags, description, provenance) renders server-side without JavaScript; the stage shows a branded static panel “JavaScript is required to play this video.” with a plain `<a>` **Open at source** link (works without JS); no fabricated player chrome.
- **A11y:** stage `role="region" aria-label`; report modal dialog (focus trap, ESC, labelled); watermark `aria-hidden`; autoplay muted-only (policy GESTURES §6).
- **Security:** iframe sandbox/allowlist (ARCHITECTURE §6); report CSRF; no media on our origin.
- **Analytics:** `watch_start` , quartiles, `player_error{source,code}` , `report_open/submit` , related CTR.

S-08 — Legal / informational pages

- **URL/Route:** `/legal/terms` , `/legal/privacy` , `/legal/dmca` , `/legal/2257` , `/legal/cookies` , `/about` , `/contact`
- **Purpose:** compliance surfaces with real, reviewed copy (content requirements: docs/LEGAL-COMPLIANCE.md; no lorem, no stubs — copy is a M1 deliverable with legal review).
- **Layout (all viewports — single readable column, max-w 720):** serif H1 + effective date; prose in sans 16–17px/1.7; section anchors sidebar on desktop (sticky TOC); last-updated stamp.
- **Contact:** structured channels (abuse, legal/DMCA, privacy, general) as definition list + form (subject enum, message ≤2000, email optional) → `/api/report` -style handler with rate limit.
- **States:** static pages (no skeletons needed); form has validation, inline errors, success panel with reference code.
- **Back arrow:** → Home. **Keyboard/a11y:** standard prose semantics; anchors focusable; TOC `nav` labelled.
- **SEO: decision (SEO.md §1/§6): all legal/info pages are indexable with canonical** — Terms, Privacy, DMCA, 2257, Cookies, About, Contact (compliance surfaces; standard practice); no “optional noindex” ambiguity remains.

S-09 — 404 Not Found

- **URL/Route:** any unmatched path (`not-found.tsx`).
- **Purpose:** graceful dead-end recovery.
- **Layout (all viewports):** centered emblem line-art, serif “Lost in the bloom.”, copy “The page you seek doesn’t exist — or has drifted beyond the garden.”, buttons: Home / Search; below: 8 trending cards.
- **Behavior:** keeps header chrome; logs `nav_404{path}` (aggregate); suggest-corrected slug when trigram-close match exists (“Did you mean /watch/...?” chip).
- **A11y/keyboard/transitions:** as standard; no auto-redirect (user-controlled).

S-10 — Global error (500)

- **URL/Route:** `error.tsx` / `global-error.tsx` fallbacks.
- **Layout:** same composition as S-09 with copy “Something interrupted the moment.” + Retry (revalidates route) + Home; error digest shown small (correlates with `requestId` log).
- **Behavior:** boundary-scoped (only failed region where possible); retry preserves form inputs where safe; `client-error` beacon with digest.

S-11 — Offline / connection lost

- **URL/Route:** `/offline` + inline banners.
- **Layout:** emblem, “You’re offline.”, copy “Previously visited pages remain available.”, list of last-visited cached routes (from client history), Retry connection button (listens `online` event).
- **Behavior:** service-worker-free in v1 (banner-based); automatic recovery toast “Back online” + refresh of visible data.

Admin panel (`/admin` — authenticated, noindex, P2)

Common admin shell: left sidebar nav (collapses to icons ≤ 1024 px, bottom tab bar on mobile), top bar (section title, admin identity, logout), data tables (dense, sans, 13–14px) with column sort, server-driven pagination (numbered, 25/page — cursor under the hood), global search per section, action confirmation modals for destructive ops, every table row action audited. Admin theme: same tokens; surfaces `--color-surface` on Obsidian; semantic status colors per DESIGN-SYSTEM §6. **Admin empty-state rule (all tables/dashboards):** honest zeros and “No records match the current filters” states — never fabricated, demo, or illustrative data; a fresh install shows real zeroes with “Awaiting first sync” status (A-02), and empty filter results offer a “Clear filters” action.

A-01 — Admin Login

- **Route:** `/admin/login`. Centered card: username, password (show/hide), submit; lockout messaging after 4 failures (“Final attempt before a 15-minute lock”); rate limit 5/15min; session 8h idle/24h absolute; audit `auth.login/auth.fail`. Ally: errors `aria-live`, caps-lock hint, autocomplete attributes. Back arrow: none (root of admin).

A-02 — Admin Dashboard

- **Route:** `/admin`. KPI cards (Sessions 24h, Watches 24h, Search zero-result %, Takedown queue age); Source health table (state chip closed/open/half-open, last sync, freshness lag); recent `sync_runs`; quick actions (Run sync, Review queue). Data: 30s cache; refresh button; sparkline `[PROPOSED]`. Empty (no data yet): honest zeros + “Awaiting first sync” status — never fabricated numbers.

A-03 — Admin Videos

- **Route:** `/admin/videos`. Filters: text (title/slug), source, category/tag, visibility (visible/hidden/hidden-reason), availability; columns: thumb (64px), title, source, duration, published, views, flags, actions. Row actions: Hide (reason modal: admin/policy), Unhide, Resync, View public, Copy slug. Bulk: none in v1 (deliberate safety). Drawer detail: full metadata, mapping trace (which rules attached taxonomy), sync history, takedown history. Pagination numbered; states standard; audit on every mutation.

A-04 — Admin Categories · A-05 — Admin Tags

- **Routes:** `/admin/categories`, `/admin/tags`. CRUD tables (create modal: name/slug auto-suggest/description/sort/visible; edit inline-safe; delete = soft-hide + confirm; tags support merge flow with alias preview and re-mapped counts). Validation mirrors DATABASE §2.3/2.4; audit `category.*`, `tag.*`.

A-06 — Admin Sources & Adapters

- **Route:** `/admin/sources`. Cards per source: manifest summary (hosts, capabilities), enable/disable (requires `terms_verified_at` set — UI blocks otherwise with explanatory panel + reference URL field), breaker state with manual reset, last sync stats, “Run sync now”. Danger zone: disable source (reversible). Audit `source.update`.

A-07 — Admin Mapping Rules

- **Route:** `/admin/mappings`. Table: source, direction (category/tag), pattern, target, priority, active, hits. Create/edit modal with regex tester (sample-match preview against recent unmapped terms); toggle active; delete. Unmapped-terms panel: top unmapped source terms with one-click “Create rule →” targeting. Audit `mapping.*`.

A-08 — Admin Takedowns & Blocks

- **Route:** `/admin/takedowns`. Queue table: status filter (new/under_review/actioned/rejected/escalated), age (SLA color: amber >24h, red >36h), reason, reporter contact, claimed URL, video thumb. Resolve modal: action (hide + block video / block source-wide pattern / report-to-source note / reject with rationale), notes; auto-purge CDN tags; writes `blocked_entries` when blocking. Tabs: Requests / Blocks (manage suppression records). Audit `takedown.resolve`, `block.*`.

A-09 — Admin Settings

- **Route:** `/admin/settings`. Typed form groups: Age gate copy variant; Discreet thumbnails default; Trending weights (validated 0–1, sum hint); Retention days (30–180); Maintenance mode (+ message, timed); Feature flags (suggest, infinite scroll); Danger zone: trigger rollup, purge caches. All writes audited; kill-switches effective ≤120s.

A-10 — Admin Audit Log

- **Route:** `/admin/audit`. Read-only table: time, admin, action (whitelist API.md §8), entity, diff (expandable JSON view), requestId. Filters: admin, action, entity, date range. Export CSV (rate-limited). No edit/delete path in UI or API (append-only DB grant).

Cross-screen interaction matrix (normative summary)

Interaction	Behavior (all screens)
Back arrow	Top-left; history-back → parent → Home; hidden on Home
Hamburger	Always available; drawer per S-00
Route transition	180ms fade + 8px slide; reduced-motion: none
Toasts	Bottom-center (m)/bottom-right (d); 4s; dismissible; never stacked >3
Modals	Centered (d) / bottom-sheet (m ≤767px); scrim 40%; focus trap; ESC
Skeletons	Exact target geometry; shimmer 1.6s; ≤3 per region
Empty states	Branded (emblem line-art + serif line + one CTA); never blank
Error states	Code-correlated digest + Retry + safe exit; E-XX catalogue
Offline	Persistent slim banner + per-region inline fallbacks
Focus	2px Ostiole ring + 2px Obsidian offset, always visible
Touch targets	≥44×44px (controls), ≥48px (nav rows)
Text scale	Usable to 200% zoom; no horizontal scroll (WCAG 1.4.10)

Responsive breakpoints (canonical — shared with DESIGN-SYSTEM §8)

320 · 480 · 768 · 1024 · 1280 · 1440 · 1920+ (px, min-width); fluid type/spacing between steps; grids per S-02; images `sizes`-correct; no horizontal overflow at any width (tested at 320, 375, 390, 430, 768, 1024, 1280, 1440, 1920 — TESTING §8).

PART 07

Workflows & Navigation

Source document: UX-FLOWS.md · v1.0.2 · 2026-09-03

SYCONIA — UX Flows (v1.1.0 — behaviors unchanged; Android semantics)

Platform mapping: browser-back → **system back** (predictive back); tab-title masking → **app-label masking** + **FLAG_SECURE discretion** (exact behavior at M3-T009, UX §14 intent preserved: nothing on-screen identifies content after leaving the watch surface); localStorage hints → DataStore; "pages" → destinations. All flow content below is product-spec unchanged.

Field	Value
Document	UX-FLOWS.md · v1.1.0 · 2026-09-03 (Android platform migration) · [REQUIRED] target behavior

Screens: **SCREENS.md** (see §) · Interaction physics: **GESTURES.md** (see §) · States: **ERROR-STATES.md** (see §)

1. Information architecture (site map)

```

Age Gate — Home /
  | Search /search?q=...
  | Categories /categories — /categories/[slug]
  | Tags /tags — /tags/[slug]
  | Watch /watch/[slug] (terminal-content node)
  | Info: /about /contact
  | Legal: /legal/{terms|privacy|dmca|2257|cookies}
  | System: /offline · 404 · error
Admin (separate tree): /admin/login → /admin/{dashboard|videos|categories|tags|
                        sources|mappings|takedowns|settings|audit}

```

Depth rule: any content is ≤3 taps from Home (drawer → listing → watch). Watch pages cross-link only sideways (related/tags) — never deeper.

2. Global navigation rules

- Back arrow (top-left):** visible on every non-root page. Resolution order: (a) in-app history entry exists → `history.back()`; (b) else static parent (search→home, watch→referring listing if passed via state, else home; category detail→index; tag detail→index; legal→home; admin sections→/admin); (c) else Home. Never traps the user; never exits the site.
- Hamburger drawer:** available on every page (including watch — pauses nothing, overlays only). Opens S-00 drawer; selecting a destination: drawer closes (200ms) → route transition. If leaving a watch page with active playback: playback stops (shell unloads embed) — deliberate, privacy-first.
- Logo tap:** Home. **Browser back/forward:** full URL-state restoration incl. filters + scroll (S-03).
- Header search:** `/` focuses; ESC blurs; mobile opens overlay sheet.

3. Flow F1 — First visit (cold start)

```

Arrive (any URL) → Age Gate (S-01, content withheld server-side)
├ "Enter" → set sy_age_ok + sy_sid → fade to target route
│   └ route exists → normal render (skeleton→content)
│   └ route gone/404 → S-09 + trending + did-you-mean
└ "Leave" → neutral external page (no content ever rendered)

```

Rules: deep-link survives the gate exactly (no redirect to home); `age_ack` event; nothing about the target page (title/thumbnail) leaks before Enter.

4. Flow F2 — Directed search (intent known)

```

Focus search (icon or "/") → type (debounce 180ms)
├ suggestions > select title → /watch/[slug]
├ suggestions > select category/tag chip → /categories/[slug] | /tags/[slug]
└ Enter → /search?q=...
    ├── results → grid; refine via FilterBar (URL updates live)
    │   └ open card → F4 watch
    ├── zero results → E-03: relaxed matches (if any) + trending + suggestion chips
    └ error → E-04 (retry preserves query)
Back arrow at every step returns to the previous state exactly (URL contract PRD2 §2.3).

```

5. Flow F3 — Serendipitous browse (intent unknown)

```

Home → rail scroll (horizontal snap) → card tap → Watch
│   └ "View all" → listing → card → Watch
Drawer → Trending/New/Rising/Categories/Tags → listing → card → Watch

```

Loop rule: after a watch session ends (or ESC exits fullscreen), the Related rail is the primary continuation; back arrow returns to the originating listing at previous scroll position.

6. Flow F4 — Watch session (happy path)

```

Card tap → /watch/[slug]
1. Stage reserved (16:9, zero CLS); poster + play affordance
2. Tap ▶ → embed initializes (capability set drives chrome, GESTURES §2)
3. View: milestones beacon (start/q25/q50/q75/end)
4. Sideways exits:
   ├── Related card → new watch (replace, history stack +1)
   ├── Tag chip → /tags/[slug]
   ├── Share → copy link (neutral clipboard title)
   ├── Open at source → new tab, nofollow noopener noreferrer
   └ Back arrow → originating listing (scroll restored)
5. Failure at any point → E-07 ladder (Retry → Alternate → Open at source → Report)

```

7. Flow F5 — Report / takedown (compliance)

```

Watch page > Report → modal (reason enum, details ≤1000, optional email)
├ reason ∈ {copyright, underage, nc} → on submit: item auto-hidden pending review
│   └ + CDN purge ≤60s + toast "TKN-XXXXXX recorded" + queue alert to admin
├ reason ∈ {broken, wrong_meta} → queued to maintenance; item stays visible
└ validation error → inline field errors; submit disabled until valid
Admin side (A-08): queue → review (provenance + claim) → resolve:
  hide+block video | block source-wide pattern | note report-to-source | reject+rationale
→ audit row + (if blocked) FR-8 sticky suppression on future syncs

```

8. Flow F6 — Error & recovery (universal ladder)

Any region fails $\rightarrow$ region-scoped error (E-04/E-07/E-01)

1. Auto-retry: 1x silent (network-class only, 800ms)
2. Manual Retry button → preserves all user state (query, form inputs, scroll anchor)
3. Secondary path: related/parent content is always offered (never a dead end)
4. Digest/reference surfaced for support correlation

Offline → E-05 banner + cached content; auto “Back online” toast + visible-data refresh.

9. Flow F7 – Admin: session

```
/admin/login → credentials → (ok) session cookie → /admin
```

- └ (fail) shake + error; 4th fail warning; 5th → 15-min lock (audit)

Idle 8h / 24h absolute → redirect to login, deep-link preserved post-auth.

```
Logout → session destroyed; drawer/back disabled into /admin (auth wall).
```

10. Flow F8 — Admin: source enablement (legal gate)

Sources (A-06) → "Enable source"

- terms not verified → blocked panel: requires reference URL + date + operator

```
confirmation (checkbox: "Terms reviewed; embedding/aggregation permitted")
```

```
└─ verified → enable → audit → optional "Run sync now" → sync runs visible
```

11. Flow F9 — Admin: taxonomy gap triage (weekly rhythm)

Mappings (A-07) → Unmapped panel (top source terms by hit count)

→ "Create rule" (target existing category/tag or quick-create)

→ apply retroactively (backfill job) → counts refresh → audit

12. Flow F10 – Moderation sweep (daily rhythm)

Dashboard (A-02) → queue-age alert if any >24h → Takedowns (A-08)

→ oldest first → resolve per F5 → verify public absence (row action "View public" → 404)

13. Navigation state machine (back-arrow semantics table)

Screen	Back target (no history)	Notes
Home	— (arrow hidden)	—
Search	Home	Query preserved in URL
Category detail	/categories	—
Tag detail	/tags	—
Watch	Referring listing (state) else Home	Scroll restored
Legal/info	Home	—
404/error/offline	Home	Via buttons (no auto-redirect)
Admin sections	/admin	Login wall guards all
Admin login	— (arrow hidden)	—

14. Session & privacy micro-flows

- Discreet thumbnails toggle (drawer footer): persists localStorage only; takes effect instantly (veil class toggle, no reload).

- Clear session traces (drawer footer): wipes `sy_sid` + queued beacons + local hide-list → new session id; confirmation toast.
- Tab-mask: on `visibilitychange→hidden` from any watch page, `document.title` = “SYCONIA — The Beauty of the Inward Experience”; restored on focus.

15. Analytics checkpoints per flow

F1 `age_ack` · F2 `search_submit`, `suggest_select{type}`, `filter_apply` · F3 `rail_impression`, `card_open{rail}` · F4 `watch_*` quartiles, `player_error` · F5 `report_open/submit{reason}` · F8–F10 admin actions (via `audit_log`, not events). All anonymous; no cross-site identifiers (SECURITY §12).

PART 08

Database

Source document: DATABASE.md · v1.0.2 · 2026-09-03

SYCONIA — Database Specification (v1.1.0 — backend-only concern, unchanged)

PostgreSQL 16+ lives exclusively in the backend service (Drizzle ORM). The Android client never touches this database (no embedded DB beyond task-justified local caching per ARCHITECTURE §2/D-014). Schema, migrations, roles, retention policies below are unchanged from v1.0.2.

Field	Value
Document	DATABASE.md · v1.1.0 · 2026-09-03 (Android platform migration)
Status	Target schema [REQUIRED] — no database exists yet; this document is the authoritative implementation spec for drizzle-kit migrations.

Conventions: `snake_case` identifiers; UUID PKs (`gen_random_uuid()`); `created_at/updated_at` `timestampz` `NOT NULL DEFAULT now()`; soft-state enums as Postgres enums; all FKs `ON DELETE` explicit; all timestamps UTC. Money features absent by design (no payments — PRD §3.2). **No media blobs, ever.**

1. Entity overview

```

sources —< videos >— video_categories >— categories
      | \— video_tags >— tags
      | \— mapping_rules (normalized into above)
      |< watch_events —(rollup)—< daily_video_stats
      |< takedown_requests      daily_search_stats <— search_queries
      |< blocked_entries
      |< sync_runs
admin_users —< admin_sessions      search_queries
      |< audit_log                  system_settings (k/v)

```

2. Tables

2.1 sources — approved external content sources

Column	Type	Rules
id	uuid PK	default <code>gen_random_uuid()</code>
slug	text	<code>NOT NULL UNIQUE</code> , lowercase regex <code>^[a-z0-9-]{2,32}\$</code>
display_name	text	<code>NOT NULL</code> , 2-64 chars
manifest	jsonb	<code>NOT NULL</code> — host allowlist[], rate budget, capability set (ARCHITECTURE §6)
terms_verified_at	timestampz	<code>NULL</code> until operator verifies ToS/embed terms (LEGAL-COMPLIANCE §4)
terms_reference_url	text	<code>NULL</code> , https URL
is_enabled	boolean	<code>NOT NULL DEFAULT false</code>
priority	smallint	<code>NOT NULL DEFAULT 100</code> (lower = first)

Column	Type	Rules
breaker_state	enum(<code>closed</code> , <code>open</code> , <code>half_open</code>)	NOT NULL DEFAULT <code>closed</code>
created_at / updated_at	timestampz	NOT NULL defaults

Lifecycle: created by admin (code-reviewed adapter module must exist); disabled → hidden from ingestion and UI, existing rows retained (provenance) but excluded from listings.

2.2 `videos` — normalized metadata cache (the catalog)

Column	Type	Rules
id	uuid PK	
source_id	uuid	NOT NULL FK→sources(id) ON DELETE RESTRICT
source_video_id	text	NOT NULL; UNIQUE(source_id, source_video_id)
slug	text	NOT NULL UNIQUE — public URL id, regex <code>^[a-z0-9-]{3,96}\$</code> . Generation algorithm (normative): <code>slugify(title)</code> → keep the first 2-3 words (each ≤12 chars, stripped to <code>[a-z0-9-]</code> , no trailing hyphen) + <code>-</code> + 8-char base62 random suffix (crypto-random); collision on <code>UNIQUE(slug)</code> → regenerate suffix (max 3 attempts, then lengthen to 12 chars); slug is immutable after creation; non-latin titles fall back to the suffix alone (<code>sy-<12 chars></code>)
title	text	NOT NULL, 1-300 chars (source-provided; never fabricated)
description	text	NULL, ≤5000 chars
duration_seconds	integer	NULL CHECK (30-28800)
thumb_url	text	NOT NULL https, validated against source manifest at write
preview_url	text	NULL https (animated preview where source provides)
embed_url	text	NOT NULL https (official embed/player URL)
embed_type	enum(<code>iframe</code> , <code>player_api</code>)	NOT NULL DEFAULT <code>iframe</code>
capability_set	text[]	NOT NULL DEFAULT '{}' — shell capabilities (PRD2 §6)
metadata	jsonb	NOT NULL DEFAULT '{}' — preserved unknown source fields (never rendered raw)
published_at	timestampz	NULL
first_seen_at / last_seen_at	timestampz	NOT NULL defaults; last_seen bumped each sync
is_available	boolean	NOT NULL DEFAULT true
is_hidden	boolean	NOT NULL DEFAULT false — admin/takedown hide (sticky across syncs)
hidden_reason	enum(<code>admin</code> , <code>takedown</code> , <code>policy</code>)	NULL when visible
views_total	bigint	NOT NULL DEFAULT 0 (from rollups)
views_24h	bigint	NOT NULL DEFAULT 0 — job-maintained (hourly trending job, PRD2 §3.1)
views_7d	bigint	NOT NULL DEFAULT 0 — job-maintained rolling 7-day sum (supports <code>most_watched</code> / <code>rising</code> sorts and cursors, PRD2 §2.2/ §4)
content_hash	text	NOT NULL — sha256(normalized core fields) for drift detection

Indexes: UNIQUE(slug); UNIQUE(source_id, source_video_id); GIN `search_vector` (generated tsvector over title, weighted A, description B) with trigger refresh; GIN trigram on title (`pg_trgm gin_trgm_ops`); BTREE (is_available, is_hidden, published_at DESC); BTREE (source_id, last_seen_at DESC); BTREE (views_total DESC); BTREE (views_7d DESC); BTREE (views_24h DESC). Lifecycle: upserted by sync; pruned to `unavailable` after 30d absent from source feed (configurable) unless hidden-for-takedown (retained as suppression record). Nothing is ever hard-deleted except by explicit admin purge (audited). **Cross-source duplicate policy (normative):** the same external media exposed via two different sources remains **two distinct catalog entries** (each carries its own provenance, embed, and takedown state — per-source suppression is the compliance unit); `content_hash` is recorded for a future optional grouping/dedup feature `[PROPOSED]` only; no v1 merging.

2.3 categories / 2.4 tags — closed local taxonomy

categories	tags
id uuid PK	id uuid PK
slug text NOT NULL UNIQUE	slug text NOT NULL UNIQUE
name text NOT NULL 2-48	name text NOT NULL 2-48
description text ≤280 NULL	description text ≤280 NULL
hero_asset_path text NULL (brand-styled, local only)	is_featured boolean DEFAULT false (Tags index page)
sort_order integer NOT NULL DEFAULT 0	usage_count integer NOT NULL DEFAULT 0 (denormalized, trigger-maintained)
is_visible boolean NOT NULL DEFAULT true	created_at/updated_at
created_at/updated_at	Index: (usage_count DESC), UNIQUE(slug)
Indexes: UNIQUE(slug), (is_visible, sort_order)	

2.5 video_categories / 2.6 video_tags — join tables

`video_id` uuid FK→videos ON DELETE CASCADE, `category_id/tag_id` FK ON DELETE CASCADE; PK (video_id, category_id/tag_id); indexes on the reverse side (taxonomy listing queries); attach/detach only via mapping rules or admin action (audited).

2.7 mapping_rules — source-term → local-taxonomy governance

Column	Type	Rules
id uuid PK		
source_id	uuid FK→sources ON DELETE CASCADE	NOT NULL
direction	enum(category , tag)	NOT NULL
pattern	text NOT NULL 1-64	literal or regex
is_regex	boolean NOT NULL DEFAULT false	regex validated at admin save
local_category_id / local_tag_id	uuid FK	exactly one NOT NULL (CHECK mutual exclusion)
priority	smallint NOT NULL DEFAULT 0	first match wins
is_active	boolean NOT NULL DEFAULT true	
hit_count / last_hit_at	integer / timestamptz	maintained by pipeline (gap analysis, PRD2 \$7)

2.8 watch_events — anonymous viewing events (raw; retention 90d)

id uuid PK · session_id uuid NOT NULL (cookie `sy_sid`, not a person) · video_id uuid FK→videos ON DELETE CASCADE NOT NULL · event enum(`start`, `q25`, `q50`, `q75`, `end`) NOT NULL · watched_at timestamptz NOT NULL DEFAULT now(). Indexes: (video_id, watched_at DESC); (watched_at) for purge scans. **No IP, no UA string, no identifiers beyond rotating session uuid.**

2.9 daily_video_stats — rollup (indefinite retention)

id uuid PK · video_id uuid FK ON DELETE CASCADE NOT NULL · day date NOT NULL · views_24h int · quartile_avg numeric(4,3) · trending_score numeric(10,4) · computed_at timestamptz. UNIQUE(video_id, day); index (day DESC, trending_score DESC).

2.10 search_queries — query log (retention 90d)

id uuid PK · query text NOT NULL (1-120) · result_count int NOT NULL · was_relaxed boolean NOT NULL DEFAULT false · created_at. Indexes: (created_at); trigram GIN on query for trending-aggregation. `daily_search_stats` (day PK, total, zero_result_count, top_queries jsonb) rollup.

2.11 takedown_requests — compliance queue

Column	Type	Rules
id	uuid PK	
video_id	uuid FK→videos	NULLABLE if reporter cites a source URL not yet in catalog
source_url_claimed	text	https; used when video_id NULL
reporter_name	text	NULL (optional)
reporter_email	text	NULL, RFC-valid when present
reason	enum(<code>copyright</code> , <code>underage</code> , <code>nc /*non-consensual*/</code> , <code>other_legal</code> , <code>wrong_meta</code> , <code>broken</code>)	NOT NULL
details	text	≤1000
status	enum(<code>new</code> , <code>under_review</code> , <code>actioned</code> , <code>rejected</code> , <code>escalated</code>)	NOT NULL DEFAULT <code>new</code>
action	enum(<code>hidden</code> , <code>blocked_source_wide</code> , <code>reported_to_source</code> , <code>none</code>)	NULL until resolved
received_at / resolved_at / resolved_by	timestamptz / timestamptz / uuid FK→admin_users	
Indexes: (status, received_at) — queue SLA queries (PRD2 §9 alert).		

2.12 blocked_entries — suppression records (sticky)

id · source_id FK NOT NULL · source_video_id text NOT NULL · scope enum(`video`, `pattern`) · pattern text NULL · reason enum(takedown,policy) NOT NULL · created_by uuid FK→admin_users NOT NULL · created_at. UNIQUE(source_id, source_video_id) where scope=video. Sync must consult this table before every insert/update (FR-8); E2E T-31 proves stickiness.

2.13 admin_users

id uuid PK · username text NOT NULL UNIQUE (3–32) · password_hash text NOT NULL (argon2id) · is_active boolean NOT NULL DEFAULT true · created_at · last_login_at NULL. Seeded from `ADMIN_PASSWORD_HASH` env on first boot only.

2.14 admin_sessions

id uuid PK · admin_user_id FK ON DELETE CASCADE NOT NULL · token_hash text NOT NULL UNIQUE (sha256 of signed cookie value) · ip_prefix text NULL (truncated) · user_agent_hash text NULL · created_at · last_seen_at · expires_at NOT NULL (CHECK expires_at > created_at; 8h idle / 24h absolute enforced by service layer). Purged nightly.

2.15 audit_log — every admin mutation (append-only)

id · admin_user_id FK NOT NULL · action text NOT NULL (enum-like whitelist: `video.hide`, `video.unhide`, `category.create`, ... full list in API.md §8) · entity_type · entity_id · diff jsonb (before/after, secrets excluded) · request_id text · created_at. Index (admin_user_id, created_at DESC), (entity_type, entity_id). **No updates/deletes by application policy; DB role has no UPDATE/DELETE grant on this table.**

2.16 sync_runs — pipeline observability

id · source_id FK NOT NULL · started_at/finished_at NOT NULL/NUL · status enum(running,success,partial,failed) NOT NULL · items_seen/added/updated/failed int NOT NULL DEFAULT 0 · error text NULL · duration_ms int. Index (source_id, started_at DESC).

2.17 system_settings — typed feature flags (PRD2 §8)

key text PK · value jsonb NOT NULL · updated_by uuid FK→admin_users NULL · updated_at. Reads cached 60s; writes audited.

2.18 interaction_events — anonymous product analytics (raw; retention 90d)

id uuid PK · session_id uuid NOT NULL (rotating cookie, not a person) · event text NOT NULL (server-enforced whitelist: `age_ack`, `page_view`, `rail_impression`, `card_open`, `search_submit`, `suggest_select`, `filter_apply`, `report_open`, `nav_drawer_open`, `nav_back_used`, `player_error` — API.md §4.7b) · video_id uuid **FK→videos ON DELETE CASCADE, NULL** (linkage unified with `watch_events` — the client sends `videoSlug`, the server resolves it to `video_id` at insert; unknown slug → event dropped silently and counted) · context jsonb NOT NULL DEFAULT '{} ' (bounded enum/string fields ≤64 chars, validated) · created_at timestampz NOT NULL DEFAULT now(). Indexes: (event, created_at DESC); (created_at) for purge scans; (video_id, created_at DESC). **No IP, no UA, no identifiers beyond the rotating session uuid.** Nightly rollup into `daily_stats` aggregates (events per type per day) precedes the 90-day purge (mirrors `watch_events` lifecycle).

3. Relationships summary

- sources 1—N videos (RESTRICT delete: provenance integrity)
- videos N—N categories/tags (via joins, mapping-rule-driven)
- videos 1—N watch_events → rollups 1—N daily_video_stats
- takedown_requests N—1 videos (nullable) · blocked_entries N—1 sources/admin_users
- admin_users 1—N admin_sessions / audit_log

4. Search configuration

- Generated column: `search_vector tsvector GENERATED ALWAYS AS (setweight(to_tsvector('english', coalesce(title, '')), 'A') || setweight(to_tsvector('english', coalesce(description, '')), 'B')) STORED + GIN.`
- `CREATE EXTENSION pg_trgm` (idempotent migration) + GIN trgm index on `videos.title`, `search_queries.query`.
- All search SQL parameterized through Drizzle (SECURITY.md §7 — injection prevention).

5. Index strategy rationale

Query path	Index
Home rails (trending/new/ most watched)	(is_available,is_hidden,published_at DESC); (views_7d DESC); (views_24h DESC); (views_total DESC); rollup (day,trending_score)
Category listing	join reverse index + (is_visible, sort_order)
Search	GIN tsvector; GIN trgm
Slug lookups	UNIQUE(slug)
Sync upserts	UNIQUE(source_id, source_video_id)
Stale pruning	(source_id, last_seen_at DESC)
SLA queue	(status, received_at)
Purge scans	(watched_at), (created_at) on 90d tables

6. Data lifecycle & retention

Data	Retention	Mechanism
videos rows	while available + 30d grace; hidden-takedown rows indefinite	sync prune job
watch_events (raw)	90d default (30-180 tunable)	nightly purge job (audited)
interaction_events (raw)	90d (same window as watch_events)	same purge job
search_queries (raw)	90d	same
rollups	indefinite (aggregate)	—
admin_sessions	expiry + 7d	nightly purge
sync_runs	180d	purge job
audit_log	indefinite (compliance)	append-only

Backups: PITR on managed Postgres (Neon) or nightly base + WAL on VPS; restore drill quarterly (SOP.md §8).

Restore targets: RPO ≤ 15min, RTO ≤ 2h.

7. Permissions & roles (DB level)

Role	Grants
syconia_app	SELECT/INSERT/UPDATE on business tables; no DELETE except via purge job role; UPDATE/DELETE denied on <code>audit_log</code> ; no DDL
syconia_jobs	purge + rollup grants incl. targeted DELETE on retention tables; no DDL
syconia_migrate	DDL for migrations only, run in CI/CD, never at runtime
syconia_admin_read (optional break-glass)	SELECT-only for incident ops

No `SUPERUSER` at runtime; connection strings scoped per role (DEPLOYMENT.md §5).

8. Migration policy

drizzle-kit generate → reviewed SQL in PR → CI applies to ephemeral DB + runs integration tests → deploy applies to prod before traffic shift → forward-only (no down-migrations in prod; rollback = redeploy previous build with compatible schema; destructive changes ship as two-phase expand/contract). Gate G-4 in CI-CD.md §4.

9. Constraints recap (invariants)

1. UNIQUE(source_id, source_video_id) — dedup.
2. UNIQUE(slug) — stable URLs.
3. blocked_entries consulted on every upsert — FR-8.
4. audit_log append-only at grant level.
5. No media columns anywhere.
6. All FK actions explicit.
7. All enums closed sets.
8. CHECK constraints on bounded fields (duration, char lengths, session expiry).

PART 09

API

Source document: API.md · v1.0.2 · 2026-09-03

SYCONIA — API Specification (v1.1.0 — contracts unchanged; consumers updated)

Consumers: **Android app (primary)** via Retrofit/kotlinx-serialization against these exact contracts, and the **backend admin console** (web). Client consumption guidance: DTO mapping happens only in the app's data layer (never in UI/domain); cursor pagination via the same signed cursors (tamper→400); error envelopes map 1:1 to app E-states; retries with jitter+backoff on 5xx/timeout only (idempotent GETs); caching honors the PRD2 §5 TTL matrix at the repository layer; age attestation header per SECURITY §6A; beacons batch and flush on background. §4/§5 contract text below is authoritative and unchanged.

Field	Value
Document	API.md · v1.1.0 · 2026-09-03 (Android platform migration)
Status	Target contract [REQUIRED] . Base URL: same-origin /api . All endpoints HTTPS-only.

Conventions: JSON bodies; Zod-validated requests; RFC-7807-style error envelope `{ error: { code, message, requestId } }`; cursor pagination per PRD2 §4; every response carries `x-request-id`. **Global precondition:** all `/api/*` except `/api/health`, `/api/ready`, `/api/csp-report`, `/api/admin/login` require the signed age cookie (`sy_age_ok`) — enforced by middleware (403 `age_verification_required` otherwise).

1. Authentication levels

Level	Mechanism	Scope
P0 public-anonymous	signed age cookie	all content endpoints
P1 anonymous session	<code>sy_sid</code> cookie (uuid)	event beacons (correlation only)
P2 admin	HttpOnly session cookie (argon2 login)	<code>/api/admin/**</code>

2. Rate limits (per truncated IP unless noted)

`suggest` 60/min · `search/list` 30/min · `events` 120/min · `report` 5/h · `admin/login` 5/15min (then lockout) · others 60/min. 429 + `Retry-After`; burst 2× for 10s. Security detail: SECURITY.md §10.

3. Common error codes

`age_verification_required` 403 · `unauthorized` 401 · `forbidden` 403 · `not_found` 404 · `validation_failed` 422 (field details) · `rate_limited` 429 · `cursor_invalid` 400 · `source_unavailable` 503 (breaker) · `internal_error` 500.

4. Public content endpoints

4.1 GET /api/videos — catalog list

- **Purpose:** rails, listings, related-source lists. **Auth:** P0.
- **Query:** `rail=trending|new|most_watched|rising` · `category=<slug>` · `tag=<slug>` · `source=<slug>` · `related=<slug>` (related-rail continuation, PRD2 §2.5) · `duration=short|medium|long|extended` — half-open buckets `short` [0,300) · `medium` [300,900) · `long` [900,1800) · `extended` [1800,∞) seconds; boundary

values belong to the higher bucket · `sort=new|longest|most_watched` (**relevance is search-only** — undefined without `q`; rejected here with `validation_failed` sanitized to the rail/listing default) · default sort: rail-specific per PRD2 §2.2; listings default `new` · `cursor?` · `limit` (server-clamped 6-48).

- **200:** { `items: VideoCardDTO[≤48]`, `nextCursor: string|null`, `notice?: string` } where `notice` is an optional human-readable degradation banner key (e.g., `some_sources_unavailable`, `filters_cleared`) and `VideoCardDTO = { slug, title, durationSeconds|null, thumbUrl (proxied), sourceName, publishedAt|null, categories: string[] (slugs, ≤3), tags: string[] (slugs, ≤5) }`.
- **Behavior:** 30s micro-cache; queries hit indexes (DATABASE §5); hidden/unavailable excluded at SQL level.
- **Errors:** `validation_failed` (unknown enum → sanitized to default + 200 with `notice` field — never hard-fail browsing), `rate_limited`.
- **Timeout/retry:** server-side p50 budget 80ms; client retry ×2 (backoff 500ms/2s) on 5xx/network only — app repository layer / admin console fetch layer.

4.2 GET /api/videos/{slug} — watch payload

- **Auth:** P0. **200:** `WatchDTO = { slug, title, description, durationSeconds, publishedAt, viewCount, source: { slug, name, provenanceUrl }, embed: { url (validated vs manifest), type, capabilities: [] }, categories[], tags[], relatedCursor }`. **relatedCursor continuation contract (normative):** the Related rail is ordered by the stable composite key (`bucket, shared_tag_count, trending_score, id`) (composition PRD2 §2.5); `relatedCursor` is a signed cursor over that key; continuation calls `GET /api/videos?related=<slug>&cursor=<relatedCursor>` and walks the identical ordering — deterministic across requests; live exclusions (hidden/unavailable/blocked) are re-applied at each page. `viewCount = views_total` (semantics PRD2 §2.6; display rounding client-side).
- **Errors:** `not_found` — **canonical status rule (single source of truth, mirrored in SEO.md §5 and ERROR-STATES E-06):** hidden (admin/takedown) or removed items → **HTTP 404** with helpful E-06 UI (no existence leak, URL exits indexes); temporarily unavailable (probe pending, may return) → **HTTP 200** with E-06 UI + related rail; `source_unavailable` if breaker open for that source (payload still returned 200 with `embed:null` + `notice` so UI can render E-04 with related content).
- **Caching:** 600s ISR-aligned; purged by tag on hide.

4.3 GET /api/search?q= — search results page 1

- **Auth:** P0. **Query:** `q` (1-120), + filters as §4.1, `sort` (default relevance). **200:** { `items[], nextCursor, resultCount, relaxed: boolean` }.
- **Behavior:** zero-result relaxation chain PRD2 §3.3 (`relaxed:true` when applied); query logged to `search_queries`.

4.4 GET /api/search/suggest?q= — autocomplete

- **Auth:** P0. **200:** { `suggestions: [{ type: query|title|category|tag, label, slug?, thumbUrl?, score }] [≤8]` } (zero-query → trending queries). 30s cache; p95 <120ms SLO.

4.5 GET /api/categories / GET /api/categories/{slug} · 4.6 GET /api/tags / GET /api/tags/{slug}

- **Auth:** P0. **Categories (bounded, unpaginated by design):** the visible category set is admin-curated and closed (≤200 rows); the index response is the complete ordered list [{ `slug, name, description, videoCount, sortOrder` }] ordered (`sort_order, name`) — no cursor. Changing this bound requires a spec change, not a query.
- **Tags (paginated + filterable):** `GET /api/tags?q=&cursor=` — `q` (optional, 1-48 chars, prefix match, case/diacritic-folded) is the server-side `search-in-tags` mechanism used by S-06; page size fixed 48; default ordering (`usage_count DESC, name ASC`); response { `items: [{ slug, name, videoCount, isFeatured }], nextCursor` }. Tag detail { `slug, name, description, videoCount` }. **Errors:** `not_found`; unknown `q` characters normalized (never 422 for content).
- Both responses: visible-only taxonomy; `videoCount` is a cached estimate (60s). Listing response includes hero metadata for categories.

4.7 POST /api/events/watch — view beacons (P1)

- **Body:** { videoSlug, event: start|q25|q50|q75|end, sessionTs }; session from sy_sid cookie server-side. **202** always (fire-and-forget; malformed → dropped, logged). Batched client-side (≤10/beacon, navigator.sendBeacon on hide). Rate 120/min.

4.7b POST /api/events/interaction — product analytics beacons (P1)

- **Purpose:** the interaction events catalogued in PRD.md §10 (age_ack, page_view, rail_impression, card_open, search_submit, suggest_select, filter_apply, report_open, nav_*, player_error).
- **Body:** { events: [{ event: <whitelist enum>, ts, videoSlug?, rail?, context? }] } — batched ≤20, navigator.sendBeacon-capable; **event names outside the whitelist are dropped and logged** (never stored raw). No free-form properties beyond bounded enum/string fields (≤64 chars). videoSlug is resolved server-side to video_id at insert (FK integrity, DATABASE §2.18); unknown/deleted slug → event dropped silently and counted (event_drop_unknown_video) — never a client error.
- **Response: 202** always. Rate class: 120/min (shared with watch beacons). Persists to interaction_events (DATABASE §2.18; 90-day retention, nightly rollup, then purge).

4.8 POST /api/events/client-error

- **Body:** { code, route, sample: boolean } (no stacks in prod, sampled 20%). **202**.

4.8b POST /api/csp-report — Content-Security-Policy violation intake (age-exempt)

- **Purpose:** receives browser CSP reports from the report-uri directive (SECURITY.md §4). **Age-exempt** (like health/ready): reports must be receivable from any page state, including the age gate.
- **Behavior:** accepts application/csp-report JSON; stores a capped, sampled record (max 500/hour stored; remainder counted only); fields kept: document-uri path (no query), violated-directive, blocked-uri host — **no full URLs, no PII**. Responds **204 No Content** always (including malformed — dropped silently, counted). Rate 60/min/IP; outputs feed the CSP-violation dashboard + weekly review (SOP §11).

4.9 POST /api/report — takedown/issue entry (P0 + CSRF token)

- **Body:** { videoSlug, reason: copyright|underage|nc|other_legal|wrong_meta|broken, details?≤1000, contactEmail? }.
- **202:** receipt reference TKN-XXXXXX shown in UI + stored takedown_requests(new). **Errors:** validation_failed, rate_limited.
- **Behavior:** copyright / underage / nc immediately hide the item pending review (safe-harbor posture, LEGAL-COMPLIANCE §5) and purge CDN tags ≤60s.

4.10 GET /api/health / GET /api/ready

- health: 200 {ok:true} liveness. ready: checks DB SELECT 1 + breaker map; 503 with component detail (no secrets) — used by deploy gate & uptime monitor.

4.11 POST /api/contact — contact/general messages (P0 + CSRF)

- **Purpose:** the S-08 Contact form (SCREENS.md) — abuse, legal, privacy, and general messages that are not per-video reports (those use §4.9).
- **Body:** { subject: abuse|legal|privacy|general, message: 1–2000 chars, contactEmail?: RFC-valid } + hidden honeypot field website (present in the form, visually hidden, tabindex=-1, aria-hidden, autocomplete="off"; if non-empty the request is **accepted 202 and silently dropped** — logged contact_honeypot, no storage).
- **Behavior:** entries are persisted into takedown_requests (DATABASE §2.11) with reason=other_legal, status=new, video_id=NULL, details = "[{subject}] {message}" — one operational queue, no new table. Subjects abuse / legal surface in the A-08 queue with an amber (non-auto-hide) priority hint; they never auto-hide content (no video is referenced).
- **Response: 202** { reference: "CTN-XXXXXX" } (shown in UI confirmation panel). **Errors:** validation_failed (field details), rate_limited (5/h). CSRF: double-submit token + Origin check (SECURITY §6).

5. Admin endpoints (P2, all mutations audited)

Endpoint	Method(s)	Purpose	Notes
/api/admin/login	POST	{username,password} → session cookie	argon2 verify; logout; audit auth.login
/api/admin/logout	POST	destroy session	audit
/api/admin/overview	GET	KPIs, source health, queue age	30s cache
/api/admin/videos	GET	filter/search cache incl. hidden	cursor
/api/admin/videos/{id}/visibility	PATCH	{isHidden, reason}	purge tags; audit video.hide/unhide
/api/admin/videos/{id}/resync	POST	force adapter refresh	rate 6/min; audit
/api/admin/categories /.../{id}	GET POST PATCH	CRUD	slug immutable post-create; audit
/api/admin/tags /.../{id}	GET POST PATCH	CRUD + merge (mergeIntoId)	soft alias; audit
/api/admin/sources /.../{id}	GET PATCH	enable/disable, termsVerifiedAt	enable requires verified terms flag; audit
/api/admin/mappings /.../{id}	GET POST PATCH DELETE	mapping rules	regex validated; audit
/api/admin/takedowns /.../{id}	GET PATCH	queue + resolve {status, action}	hide-first; SLA timestamps; audit
/api/admin/blocks /.../{id}	GET POST DELETE	blocked_entries mgmt	FR-8 sticky; audit
/api/admin/settings	GET PATCH	typed flags (PRD2 §8)	schema-validated; audit
/api/admin/audit	GET	filtered audit log	read-only
/api/admin/sync	POST	trigger {sourceSlug}	CRON_SECRET or P2; idempotent; audit

Errors: 401/403 + validation_failed; all bodies Zod-validated; no bulk ops without explicit confirm:true.

5.1 Admin data contracts (normative — implementable without guessing)

Common rules: list responses { items: T[], nextCursor: string|null } (signed cursors, PRD2 §4); mutations return the updated entity; page size 25; every mutation requires the x-csrf-token header (SECURITY §6) and writes an audit_log row; destructive operations (mapping DELETE, tag merge, block DELETE, category/tag delete) additionally require confirm: true in the body → else **422**

confirmation_required. Server-side table sorting (A-03...A-10): every admin list accepts sort=<field>:<asc|desc>; whitelists — videos title|published_at|views_total|updated_at · categories sort_order|name|usage_count · tags usage_count|name · sources priority|slug · mappings priority|hit_count · takedowns received_at|status · audit created_at|action; any other field → validation_failed. Defaults: videos updated_at:desc, takedowns received_at:asc, audit created_at:desc, categories sort_order:asc, tags usage_count:desc, sources priority:asc, mappings priority:desc.

DTO	Fields (types)
AdminVideoRow	id uuid, slug, title, sourceSlug, durationSeconds int null, publishedAt iso null, isAvailable bool, isHidden bool, hiddenReason admin\ policy\ null, viewsTotal bigint, thumbUrl, categories slug[], tags slug[], updatedAt iso
AdminCategory	id, slug, name, description string null, isVisible bool, sortOrder int, usageCount int, updatedAt

DTO	Fields (types)
AdminTag	id, slug, name, description string null, isFeatured bool, usageCount int, updatedAt
AdminSource	id, slug, displayName, isEnabled bool, termsVerifiedAt iso null, termsReferenceUrl https null, priority int, breakerState closed\ open\ half_open, lastSync {status, itemsSeen, itemsAdded, itemsFailed, durationMs} null, capabilities string[]
AdminMapping	id, sourceSlug, direction category\ tag, pattern, isRegex bool, targetSlug, priority int, isActive bool, hitCount int, lastHitAt iso null
AdminTakedown	id, reference TKN-XXXXXX\ CTN-XXXXXX, video {slug,thumb} null, sourceUrlClaimed https null, reason enum, status enum, action enum null, receivedAt, resolvedAt iso null, reporterEmail null, notes null
AdminBlock	id, sourceSlug, sourceVideoId null, pattern null, scope video\ pattern, reason, createdAt, createdBy username
AdminAuditRow	id, adminUser, action (whitelist §8), entityType, entityId, requestId, createdAt; diff included detail-on-expand only
AdminOverview	kpis {sessions24h, watches24h, searchZeroResultRate, takedownQueueOldestHours}, sources[AdminSource], recentSyncRuns[≤8], queueAlerts[]

Mutation request bodies (Zod-validated): - POST /api/admin/login {username 3–32, password 8–128} → 200 { admin: {username}, csrfToken } + sy_admin session cookie + sy_csrf cookie (SECURITY §6). 401 unauthorized on bad credentials (attempt counter in response). - PATCH ../videos/{id}/visibility {isHidden: bool, reason?: admin|policy} (reason required when isHidden=true → 422) → AdminVideoRow; purges CDN tags video:{id} + listing tags. - POST ../videos/{id}/resync {} → 202 {syncRunId}; rate 6/min (429). - POST /api/admin/categories {name 2–48, slug? (auto-suggested from name, regex ^[a-z0-9-]{2,32}\$, immutable after create), description? ≤280, sortOrder ≥0, isVisible bool}; PATCH ../{id} partial (slug rejected with 422 slug_immutable). - POST /api/admin/tags {name 2–48, slug?, description?, isFeatured bool}; PATCH ../{id} partial **or** {mergeIntoId: uuid} → merge = alias + re-map join rows + soft-hide source tag (audited tag.merge); 422 if target == source. - PATCH ../sources/{id} {isEnabled?: bool, priority?: 0–1000, termsVerifiedAt?: iso, termsReferenceUrl?: https} — isEnabled=true with termsVerifiedAt=null → **422 terms_not_verified** (LEGAL-COMPLIANCE §4 gate). - POST /api/admin/mappings {sourceSlug, direction, pattern 1–64, isRegex bool (validated compiles), targetSlug, priority 0–1000, isActive} → triggers mapping-backfill job (ARCHITECTURE §5); PATCH/DELETE {confirm:true}. - PATCH ../takedowns/{id} {status: under_review|actioned|rejected|escalated, action?: hide_video|block_pattern|reported_to_source|none, notes? ≤1000} — actioned requires an action (422 otherwise); hide_video delegates to the visibility contract above; block_pattern delegates to the blocks contract. - POST /api/admin/blocks {sourceSlug, scope, sourceVideoId? (required if scope=video), pattern? (required if scope=pattern), reason}; DELETE ../{id} {confirm:true} (FR-8 suppression removal is audited). - PATCH /api/admin/settings — partial per the typed flags in PRD2 §8; trending_weights {w24,w7,wq} must sum to 1.0 ± 0.01 → 422 weights_invalid; retention 30–180. - POST /api/admin/sync {sourceSlug} → 202 {syncRunId} (idempotent per source; superseded runs abort cleanly). - GET /api/admin/audit filters {admin?, action?, entityType?, entityId?, from?, to?} — read-only, CSV export rate-limited 2/min.

6. External adapter architecture (outbound)

6.1 Policy

- Outbound calls only from the jobs/server plane through /lib/adapters/http.ts (SSRF seam, ARCHITECTURE §6). Client never calls sources directly.
- **Source candidacy rule:** a source is eligible only if it offers an official public API, feed, or embed program whose terms permit third-party embedding/aggregation of metadata. The operator must record terms_verified_at + reference URL per source before enabling (admin UI enforces). Scraping beyond documented endpoints, terms-gated endpoints, or circumvention of technical controls is prohibited. Candidate families: official webmaster/feed APIs and oEmbed-style providers (specific sources selected at M2 by the operator after terms review; adapter interface is source-agnostic).

- **No-automatic-grant rule:** possessing an API key, feed endpoint, or copy-paste embed snippet does **not** by itself grant redistribution, re-hosting, or metadata-aggregation rights. Permission to aggregate metadata and embed must be affirmatively established from each source's published terms (or written permission) before that source is enabled; where terms are silent or ambiguous, the source remains **disabled** pending counsel sign-off. Embedding always renders the source's own player — never re-hosted streams or downloads; the image proxy caches provider thumbnails for display only.

6.2 Adapter interface

```
interface SourceAdapter {
  manifest: { slug, hosts: string[], ratePerMin, capabilities: Capability[] }
  fetchPage(cursor?: string): Promise<{ rawItems: unknown[], nextCursor: string|null }>
  fetchItem(id: string): Promise<unknown>
  normalize(raw: unknown): NormalizedVideo // PRD2 §6 DTO, field-wise validation
  probe(item: NormalizedVideo): Promise<{ ok: boolean, embedState?: 'alive' | 'dead' | 'geo' }>
}
```

Timeout 10s, ≤2 retries with jitter, response cap 5MB, circuit breaker per source (§6.3 PRD2). Failure never crosses sources.

6.3 Normalization & source failure behavior

- Field-wise validation: a bad field drops that field (log `normalization_drift`), a bad item drops the item (count in `sync_runs.items_failed`), a bad page aborts the page only.
- Embed provenance: `embed.url` is the source's official embed URL only; shell re-validates against manifest hosts at render (defense in depth).
- Failure ladder (per video, at watch time): embed timeout 8s or error → adapter `probe` → if `dead/geo`: mark `is_available=false` + render E-04 with (Retry) (Alternate variant if `player_api` provides one) (Open at source) (Report). Breaker open for source → listings exclude that source's items automatically (soft degradation, notice chip “Some sources are temporarily unavailable”).

7. Embed/player integration notes

- Rendering: iframe with locked attributes (ARCHITECTURE §6). Autoplay: never with sound; poster-first on mobile; user gesture required before init on cellular [PROPOSED].
- Capability-driven chrome: shell renders fullscreen/theater/report/watermark always (ours); play/pause/seek/volume/captions/speed controls are the source player's own, surfaced natively unless `capabilitySet` declares shell-delegation (GESTURES §2).
- `player_error` beacon carries `{sourceSlug, code}` only.

8. Audit action whitelist

`auth.login`, `auth.logout`, `auth.fail`, `video.hide`, `video.unhide`, `video.purge`, `video.resync`, `category.create/update/delete`, `tag.create/update/merge/delete`, `source.update`, `mapping.create/update/delete`, `takedown.resolve`, `block.create/delete`, `settings.update`, `sync.trigger` — anything else is a 422 by contract.

9. Versioning & evolution

Internal API is versionless but additive-only within v1; breaking changes require `/api/v2` + deprecation window (≥90 days) documented in CHANGELOG.md. DTO changes update DATABASE.md + this file in the same PR (SOP §6 checklist).

10. Endpoint test traceability

Every endpoint maps to ≥1 row in TESTING.md §7 (T-10...T-29) and ≥1 Playwright API-level spec; contract tests validate Zod schemas both directions (request rejects, response shape).

PART 10

Security

Source document: SECURITY.md · v1.0.2 · 2026-09-03

SYCONIA — Security Architecture, Threat Model & Checklist

Field	Value
Document	SECURITY.md · v1.1.0 · 2026-09-03 (Android platform migration) · [REQUIRED] controls

1. Security objectives

Protect: visitors (privacy, discretion), the platform (integrity, availability), the operator (compliance posture), and partners/sources (no abuse of their services). Posture: assume hostile internet; zero-trust toward all external data (source metadata is untrusted input); least privilege everywhere.

2A. Android client security model (v1.1.0 — ADDS to, does not replace, the server sections)

- **No secrets in the app:** the client ships zero API keys/secrets; all privileged operations stay server-side. BuildConfig limited to non-secret endpoint config; verified by CI secret scan of APK contents (G-6).
- **Transport:** HTTPS-only (`network_security_config`: no cleartext, TLS 1.2+, system + (if justified at M5-T003) pinning decision recorded then — no unverified claims).
- **WebView (playback shell, D-013):** loads only manifest-allowlisted embed URLs (validated at API response and again before load); JS enabled only for embed function, no file access, no universal access from file URLs, third-party cookies/partitioned storage disabled in the shell where possible, safe-browsing enabled, external links intercepted → Custom Tabs/open-at-source with referrer hygiene.
- **Session/age state:** DataStore (non-sensitive flags) + Android Keystore for any token that must survive (admin is NOT in the app — admin console is backend web; the app has no authenticated surface at all: no accounts, no login).
- **Exported components:** none beyond the launcher activity; deep links (App Links) via verified `assetlinks.json` on the backend domain (SEO §1A); intent handling validates inputs.
- **Discretion:** FLAG_SECURE on the watch/player experience (blocks screenshots/recents preview — mapped from the web tab-mask behavior; exact scope decided at M3-T009 with a11y tradeoffs recorded); backup rules exclude all app data (`allowBackup=false` + no cloud backup of any identifier).
- **Logging:** never logs URLs-with-tokens, session ids, or user content; crash reports sampled, scrubbed (matches §12).
- **Release hygiene:** debug/release separation, minified release build, R8, signing via CI secrets only (never committed — CI-CD \$keystores). 1. Android app ↔ SYCONIA backend (HTTPS-only; WebView embeds additionally sandboxed per §2A). 2. Backend ↔ external source APIs (outbound, allowlisted). 3. Backend ↔ database (scoped roles). 4. Third-party embed content (inside the app's hardened WebView / web frame — untrusted). 5. Admin ↔ admin plane (authenticated web console on the backend).

3. Transport & HTTPS

- HTTPS everywhere, HSTS `max-age=63072000`; `includeSubDomains`; `preload` (submitted to preload list after launch); no plaintext listeners; HTTP → HTTPS 308 redirect at edge; TLS 1.2+ (1.3 preferred), modern cipher suite only; certificates managed by platform (DEPLOYMENT §3). Secure cookies flagged (`Secure`) exclusively.
- Internal service-to-service (jobs) still TLS when crossing hosts; DB connections TLS required.

4. Security headers (backend web surfaces — CSP is the centerpiece; the Android client's equivalents are §2A network/WebView controls)

```
Content-Security-Policy:
  default-src 'self';
  script-src 'self' 'nonce-{random}' 'strict-dynamic';
  style-src 'self' 'unsafe-inline'; /* token layer needs inline vars; no third-party styles */
  img-src 'self' data;; /* all thumbnails served via the /_next/image proxy
                        (same-origin); data: for inline placeholder art only */
  media-src 'none'; /* no media on our origin — ever */
  frame-src https://{source-host-allowlist}; /* per-manifest, from enabled sources only */
  connect-src 'self';
  font-src 'self';
  object-src 'none'; base-uri 'self';
  form-action 'self'; frame-ancestors 'self';
  upgrade-insecure-requests; report-uri /api/csp-report
Strict-Transport-Security: max-age=63072000; includeSubDomains; preload
X-Content-Type-Options: nosniff
Referrer-Policy: strict-origin-when-cross-origin
Permissions-Policy: camera=(), microphone=(), geolocation=(), payment=(), usb=(), interest-cohort=()
Cross-Origin-Opener-Policy: same-origin
X-Frame-Options: SAMEORIGIN /* SYCONIA pages are never embeddable elsewhere */
X-DNS-Prefetch-Control: off
Cache-Control: no-store /* on /api/admin/** and watch beacons only */
```

`frame-src` is generated from enabled sources' manifests — disabling a source removes it from CSP at the next deployment window; CSP violations are logged (report-only first on any change — SOP §7).

5. Injection prevention (web surfaces keep XSS controls; Android adds the following)

- Compose renders untrusted text as plain text by default (no HTML interpretation); any rich text from sources is sanitized server-side at ingestion (unchanged) and rendered via safe annotated/limited spans only.
- WebView: no `loadData` with untrusted HTML; URL validation before every load; JS bridge (if ever required) is `@JavascriptInterface`-minimal and reviewed — none exists in v1 by default.
- React/JSX text interpolation everywhere (auto-escaping); `dangerouslySetInnerHTML` is banned by lint rule (CI gate G-8) — legal pages are rendered from React MDX components, not raw HTML strings.
- Source-provided text (titles, descriptions) treated as untrusted: normalized at ingestion (charset normalization, control-char strip, length clamps) and rendered as text nodes; the rare rich field passes a strict server-side sanitizer (allowlist: `p br strong em a[rel]`) before storage.
- URL fields validated twice (ingestion + render) against manifest host allowlists (https, no userinfo, standard ports, no `javascript:/data:` schemes possible by construction).
- CSP as second line (§4). No third-party scripts at all — analytics is first-party.

6. Session & attestation contracts (v1.1.0: web cookies retained for the backend console; the Android app uses header attestation — no cookies)

6A. Android app: no accounts, no login, no cookies. (a) **Age attestation:** first-run 18+ gate stored in DataStore; API requests from the app carry a signed-at-build-time-NO — a simple, non-forged-for-value `x-sy-age: affirmed` header plus the server-side app-client identification via API key rotated per release; final mechanism (including replay considerations) is an M1-T011/M2-T010 security-review deliverable — this document does not claim it exists yet. (b) **Anonymous session id:** UUID v4 in DataStore, 30-day expiry, no renewal, rotated by Clear-session-traces (same policy as the former `sy_sid` cookie). (c) Public report/contact from the app use the same endpoints with rate limits + honeypot equivalents.

6B. Backend web console (unchanged from v1.0.2): State-changing endpoints are admin-only (cookie `SameSite=Strict` + per-session CSRF token + Origin check) and public `POST /api/report` + `POST /api/contact`

(double-submit token + Origin check + rate limit). Age cookie is `SameSite=Lax` (never authorizes writes). Beacons are idempotent inserts with no privilege.

Cookie contracts (normative): - **Age cookie** `sy_age_ok`: `HttpOnly`, `Secure`, `SameSite=Lax`, 12 months. Payload format: `<exp-epoch-seconds>.<hex-hmac-sha256(exp, AGE_SECRET)>` — verified server-side (expiry + signature); malformed/expired/forged = absent (403 path). The `localStorage` mirror is a non-authoritative UX hint only (the server never reads it). - **Admin session cookie** `sy_admin`: `HttpOnly`, `Secure`, `SameSite=Strict`, 8h idle / 24h absolute. Payload: opaque 256-bit random token; `admin_sessions` stores only `sha256(token)`; no role/claim data in the cookie. - **CSRF issuance/rotation**: on successful login the server returns `{ csrfToken }` in the body **and** sets a readable (non-`HttpOnly`) `sy_csrf` cookie; every admin mutation must echo it in the `x-csrf-token` header (compared to the session-bound value). Token is rotated on every login and invalidated on logout/session expiry. Public report/contact use the classic double-submit pattern (token cookie + header echo) with no session binding. - **Admin lockout scope**: the failure counter is maintained **per username AND per truncated IP** — either counter reaching 5 within 15 minutes locks both keys for 15 minutes (audited `auth.fail`); attempts against a nonexistent username still count toward the IP counter (no username enumeration).

7. SQL injection prevention

Drizzle ORM parameterizes every query (no string-built SQL); search uses `tsvector`/`trigram` operators with bound parameters; dynamic sort/filter keys are enum-mapped server-side (never interpolated identifiers); DB roles cannot execute DDL (DATABASE §7); logs never contain raw SQL with user input.

8. SSRF protection (adapter plane)

- Single HTTP wrapper (ARCHITECTURE §6): manifest host allowlist per adapter; URL parsing (scheme `https`, host suffix match, no userinfo, port 443); DNS resolution validated against private/link-local CIDRs (IPv4+IPv6) before connect and on every redirect hop (cross-host redirect = abort); 10s timeout, 5MB body cap; no user-supplied URL ever fetched (report forms store, never fetch).
- Image proxy (`next/image`): `remotePatterns` mirror the union of enabled manifests; no wildcard hosts.

9. Input validation & output sanitization (summary)

All external input (query params, bodies, source payloads) validated by Zod at the boundary with strict schemas (types, enums, lengths 1–300/120/1000/2000, formats). Output: React escaping; JSON responses typed by DTO contract (API.md §4); error envelopes leak no internals (message + code + requestId only).

10. Rate limiting & abuse prevention

Per truncated-IP sliding windows (API.md §2). Additional guards: age-cookie HMAC-signed (forgery → 403), cursors HMAC-signed (tamper → 400), admin lockout (5/15min, audited), report endpoint honeypot field + submit-time throttle, suggest endpoint bounded (8), beacon batching caps. Layer 7 DDoS: platform WAF/CDN (DEPLOYMENT §6) + graceful `Retry-After` responses; static ISR pages keep origin load minimal.

11. Secrets management

- Secrets only via environment variables (validated at boot); never in code, never client-side, never in logs. Local dev: `.env.local` (git-ignored; CI secret-scan gate G-6 blocks commits matching secret patterns). Rotation runbook: SOP §10 (keys rotate without downtime: dual-validity window for HMAC secrets).
- Admin credentials seeded from `ADMIN_PASSWORD_HASH` (argon2id, 19MiB/t=2/p=1 minimum) — plaintext passwords never stored or logged.

12. Privacy controls (architecture-level)

No accounts; anonymous rotating `sy_sid` (30d) for aggregate analytics only; IPs truncated (v4 /24, v6 /48) in rate-limit keys — never stored in events; UA not persisted (capability class only); DNT respected (events disabled); "Clear session traces" control (UX-FLOWS §14); access logs strip query strings on watch routes; raw events purged at 90d (DATABASE §6); no third-party trackers/analytics/fonts (self-hosted OFL fonts); privacy policy states all of this truthfully.

13. API-source validation (upstream trust)

Every adapter payload is untrusted: Zod-validated field-wise (PRD2 §6), size/duration plausibility-checked, embed URLs allowlist-checked at ingestion **and** render (defense in depth), unknown fields quarantined to JSONB never rendered raw. Terms verification gate before any source is enabled (API.md §6.1; LEGAL-COMPLIANCE §4). No source HTML is ever parsed for playback URLs — official embed endpoints only (anti-scraping posture + ToS compliance).

14. Dependency & supply-chain security

Backend lockfile-only installs (`npm ci`); Android dependency verification + pinned versions; weekly audits both stacks (`npm audit` + OSV/dependency-check) + automated PRs (SOP §11); CI gate G-5 blocks High/CRIT advisories; pinned action hashes in CI; SBOM generated per release [PROPOSED] ; no runtime `eval` -class code; fonts from audited SIL-OFL sources (Fraunces, Inter); icons via lucide-react (ISC license); brand assets are project-proprietary (guidelines PDF §"Confidential & Proprietary") — license compliance recorded per dependency in the release record.

15. Threat model (STRIDE summary)

Threat	Vector	Control
Spoofing	Forged age/admin cookies	HMAC signing; argon2 + logout; SameSite
Tampering	Cursor forgery; DB tampering via SQLi; embed URL swap	Signed cursors; parameterization + scoped roles; double URL validation
Repudiation	Admin denies action	Append-only audit_log (no UPDATE/DELETE grants)
Information disclosure	Content before age gate; PII in logs; error leakage	Server-side gate; truncation rules; opaque errors + requestIds
Denial of service	L7 floods; source hammering	Rate limits; ISR/CDN absorption; adapter rate budgets + breakers
Elevation of privilege	Admin API access without session	Middleware guard + session checks + audit
Supply chain	Malicious dep/advisory	Lockfiles, audits, pinned CI
Clickjacking	SYCONIA framed elsewhere	frame-ancestors 'self' + XFO
Magecart-class	Third-party script injection	CSP strict-dynamic; zero third-party scripts

16. Incident response (summary — full runbook SOP §9)

Severity classes S1-S3; on-call channel; containment-first doctrine (kill-switches: disable source, maintenance mode); forensic timestamps from audit_log + structured logs; disclosure obligations assessed per LEGAL-COMPLIANCE §8; post-mortem template in SOP §9.4.

17. Production security checklist (gate — PRE-RELEASE §8 references this)

☐ HTTPS + HSTS preload verified ☐ CSP verified against live frame-src needs (report-only first) ☐ all headers present on every route (automated header test) ☐ age gate enforced server-side (pen-test case T-70) ☐ admin: logout + audit + noindex verified ☐ rate limits active in prod ☐ secrets scanned + rotated post-first-deploy ☐ dependency audit clean ☐ DB roles verified (no superuser runtime) ☐ backups encrypted + restore drill done ☐ CSP/report endpoint monitored ☐ pen-test pass (OWASP WSTG-lite scope) ☐ privacy policy matches actual data flows.

PART 11

Performance

Source document: PERFORMANCE.md · v1.0.2 · 2026-09-03

SYCONIA — Performance & Optimization Strategy

Field	Value
Document	PERFORMANCE.md · v1.1.0 · 2026-09-03 (Android platform migration) · [REQUIRED] budgets & tactics

1. Targets (v1.1.0 — Android field/lab + backend API)

Android app (measured on mid-tier device, API 26+): | Metric | Budget | Owner | |---|---|---| | Cold startup | $\leq 2.0s$ to first content (app open $\rightarrow$ home content), $\leq 1.2s$ warm | App module, baseline profiles | | P95 frame time | $\leq 16ms$ steady scroll; ≤ 800 dropped frames per 10k-item scroll session | Lazy lists, image pipeline | | Search suggestions | $\leq 150ms$ tap $\rightarrow$ results on cache hit (network p95 $\leq 120ms$ API-side) | Search feature | | Watch open | stage reserved instantly (zero layout jumps); embed init $\leq 600ms$ after intent | Player shell | | ANR / crash | ANR-free golden journeys; crash-free sessions $\geq 99.5\%$ | Stability | | App size | APK $\leq 25MB$ / AAB download-size $\leq 15MB$ baseline (reviewed per release) | Build, R8, asset discipline | | Memory | no OOM on 10k-item session; Coil memory cache bounded | Imaging | | Battery | no main-thread network/decode; no wake locks; WorkManager-only background | Architecture |

Backend API (unchanged): suggest p95 $\leq 120ms$ · list p95 $\leq 300ms$ · TTFB (web surfaces) $\leq 300ms/120ms$ cached · error rate $< 2\%$. Core Web Vitals apply **only to the remaining web surfaces** (legal/share/admin) and are demoted from primary targets (they are asserted where Lighthouse still runs on the backend track).

2. Loading strategy (v1.1.0 — Android; web bullets at section end apply to backend surfaces only)

- **Rendering:** route-strategy table (ARCHITECTURE §4): ISR for cacheable surfaces, SSR+streaming for search, SG for legal. Streaming order: shell $\rightarrow$ header $\rightarrow$ primary content region $\rightarrow$ below-fold rails (Suspense boundaries per rail).
- **Critical path:** inline token CSS variables + critical layout in the document; fonts self-hosted, `font-display: swap`, subset latin, preloaded (2 families $\times$ 2 weights max on first load).
- **Images:** every thumbnail through the optimization proxy with `remotePatterns` allowlist; AVIF/WebP negotiation; correct `sizes` per grid (2 $\rightarrow$ 6 col) + `fetchpriority="high"` on the LCP element only; lazy below fold; 30d immutable cache (URL-hash versioned).
- **Player:** stage box reserved (aspect-ratio) — zero CLS; embed iframe lazy-initialized on first intent (poster-first); below-fold related content streamed after stage.
- **Prefetch:** nav intent (hover/press $\geq 150ms$) prefetch; viewport prefetch for next cursor page when `saveData=false` and idle; drawer links prefetch on drawer open.
- **Fonts/icons:** bundled variable fonts (single file/family); Material Symbols loaded as needed (no icon-font sprites, no bundled icon bitmaps).

3. JavaScript budget & islands

- Server Components by default; client islands only: header/drawer, search combobox, player shell, feed pagination, admin tables, forms, toasts. Target: public route client JS $\leq 120KB$ compressed (home), $\leq 180KB$ (watch incl. shell) — enforced in CI bundle-size gate (G-9).
- `motion/react` used via `LazyMotion` + `domAnimation` feature bundle (no full `domMax` on public routes).
- App repository layer caches cursor pages (staleTime 60s, PRD2 §5) preventing refetch storms on back-navigation.

4. Animation performance law

Transform/opacity only (DESIGN-SYSTEM §9); no animating layout properties; compositor-friendly (`will-change` transient); ≤ 12 staggered nodes per region; skeletons/loops pause off-screen; reduced-motion honored everywhere; player chrome overlays GPU-composited.

5. Caching architecture (layers — TTL matrix normative in PRD2 §5)

CDN for web surfaces (tag-purge ≤ 60 s for hides — invariant retained) → API micro-caches (30s) → Postgres (prepared statements, hot indexes DATABASE §5) → app repository cache (TTLs from PRD2 §5). Cache-key discipline: no user-specific variance on public data (anonymous homogeneity); admin plane always private/no-store. Cache-key discipline: no user-specific variance on public pages (anonymous homogeneity = cache heaven); admin plane always private/no-store.

6. Database performance

Indexes match query paths (DATABASE §5); rollups keep aggregate reads $O(\text{day})$; pagination via cursors — no OFFSET scans; sync jobs batch upserts (≤ 500 statements/tx) and run off-peak; connection pooling (10–20) via pooler; statement timeouts 5s (list) / 500ms (suggest, via prepared hot path); `pg_stat_statements` reviewed weekly (SOP §11).

7. Third-party/embed performance containment

Embeds load only after user intent (poster-first) — keeps cold watch-page LCP ours; `iframe loading="lazy"`; no source scripts on our origin (CSP `script-src self`); adapter fetches budgeted (rate per manifest) so jobs never stampede; breaker prevents retry storms.

8. Rate/traffic shaping under load

ISR absorbs anonymous reads; only search/suggest/events hit origin — all rate-limited (SECURITY §10); CDN rules cache suggest responses 30s at edge for repeated prefixes in bursts; maintenance mode static page at edge for S1 events.

9. Observability (v1.1.0: first-party RUM beacon retained — metrics now app-side: startup, cold/warm, frame drops, API latency per endpoint class, crash-free sessions; web vitals only for web surfaces)

- RUM beacon (first-party): LCP/INP/CLS/TTFB per route class, sampled 100% (aggregate, anonymous) → daily rollups on admin dashboard.
- Lab: Lighthouse CI on preview deployments per PR (budgets above fail the build — G-9); bundle analyzer diff posted on oversized PRs.
- Alerts: p95 TTFB > 600ms 15min; API p95 breach 15min; error rate > 2%.

10. Performance acceptance criteria

1. Home on throttled 4G/mid-Android: LCP ≤ 2.0 s, CLS ≤ 0.02 , interactive without long tasks.
2. Watch page: no CLS from stage; embed init ≤ 600 ms after intent.
3. Search typing: suggestions ≤ 120 ms p95.
4. 10k-item category page scroll: no dropped frames >5% on mid-tier (trace verified).
5. Bundle budgets green in CI.
6. All budgets asserted in E2E perf suite (TESTING §7 T-60...T-65) and PRE-RELEASE §7.

PART 12

SEO

Source document: SEO.md · v1.0.2 · 2026-09-03

SYCONIA — Web Discoverability (scope-reduced v1.1.0)

Platform migration scope decision (D-018): SYCONIA's public discovery surface is now the **native Android app**; crawler-based discovery SEO for public catalog pages is **retired with the web UI**. This document now governs: (1) the remaining backend web surfaces — legal/info pages (still indexable, §6 decision unchanged), the minimal `/watch/[slug]` **share/OG preview pages** (noindex, honest OG tags, "Open in app" + open-at-source), and the admin console (noindex); (2) **Android App Links** (`assetlinks.json`, verified deep links `syconia://` → https share URLs), share URL shape, and web-to-app continuity. Sitemaps cover legal pages only; `Website/SearchAction`, `CollectionPage/ItemList` and `VideoObject`-on-our-domain artifacts are **retired** (an honest `VideoObject` may appear on share pages pointing at the source embed). RTA labelling continues on web surfaces; in-app content rating + Play data-safety disclose adult scope honestly. T-66...T-69 map to these reduced checks.

Field	Value
Document	SEO.md · v1.1.0 · 2026-09-03 (Android platform migration) · [REQUIRED]

Reality note: adult-content discoverability in general web search is constrained by SafeSearch and platform policies; this strategy maximizes what is legitimately indexable while following search-engine guidelines strictly (no cloaking, no sneaky redirects — brand-discretion measures that alter presentation, not content vs crawler, are documented in §7).

1. Technical foundations

- **Canonical:** `SITE_URL` absolute, self-referencing on every indexable page; `rel=canonical` strips cursor/pagination params (page 1 canonical for parameterized listings); trailing-slash consistent.
- **robots.txt:** allow all except `/admin`, `/api`, `/offline`, `/search` (parameterized search excluded per guidelines); sitemap reference included.
- **Sitemaps:** `sitemap.xml` index → home, categories index + all visible categories, tags index + featured tags (long-tail tags only if ≥ 10 videos), watch pages (indexable set: available, visible, ≥ 1 taxonomy, not noindex-flagged); $\leq 50k$ URLs/sitemap, split by type; `lastmod` from `updated_at`; refreshed on sync (daily) — not on every request.
- **Indexing directives:** parameterized/filter URLs, cursor pages, offline, admin, 404 → noindex; legal pages indexable; watch pages indexable by default with admin per-item override.
- **Hreflang:** single-locale (`en`) in v1 — explicit `lang="en"`, no hreflang noise.
- **HTTPS + HSTS** (SECURITY §3); single origin; no mixed content (CSP `upgrade-insecure-requests`).

2. Metadata system (centralized `/lib/seo`)

- **Title template:** `%s — SYCONIA` · default: `SYCONIA — The Beauty of the Inward Experience` (official spelling only).
- **Description:** unique per page type; watch pages compose from source-provided title + neutral brand frame (truncated 155 chars, no explicit strings beyond source metadata — descriptive, non-promotional).
- **OG/Twitter:** `og:title/description/type=video.other/image` (proxy thumbnail 1200×630 crop), `og:site_name=SYCONIA`, `twitter:card=summary_large_image`; neutral preview mode [PROPOSED] (privacy share previews use brand card instead of thumbnail — off by default).

- **Favicons/app icons:** official assets (32px favicon, 180 apple-touch from app icon, 192/512 manifest icons from app icon).
- **Pagination markup:** `rel="next/prev"` semantics via crawlable “Load more” fallback links to `?page=n` variants (canonicalized to page-1) — compliant infinite-scroll pattern.

3. On-page standards

- One `<h1>` per page (serif, descriptive); heading hierarchy strictly nested (h1→h2→h3, no skips); landmark structure (`header/nav/main/footer`); breadcrumbs on depth ≥ 2 pages with visible text + markup.
- Internal linking: related rail (contextual), tag/category chips, breadcrumb — every indexable page reachable ≤ 3 clicks from home.
- Text content: category/tag pages carry curated editorial descriptions (admin-managed, real copy — never lorem) to qualify as substantive pages.

4. Structured data (JSON-LD, server-rendered)

Page	Schema
All	<code>WebSite</code> (+ <code>SearchAction</code> → <code>/search?q={search_term_string}</code>)
Breadcrumbs	<code>BreadcrumbList</code>
Watch	<code>VideoObject</code> (name, description, thumbnailUrl via proxy, uploadDate=publishedAt, duration ISO8601, embedUrl = source embed — honest: player on source domain) — only when metadata complete; never fabricated fields
Category/Tag	<code>CollectionPage</code> + <code>ItemList</code> (paged subset)

Validation: schema validator in CI for representative fixtures (G-10); no markup on `noindex` pages.

5. Adult-content policy compliance

- Meta robots `rating/RTA` label (`<meta name="rating" content="RTA-5042-1996-1400-1577-RTA">` standard self-label) — declared honestly for family-safe filters.
- No cloaking: crawler and user receive identical content/links; discretion veil (DESIGN-SYSTEM §11) is presentation styling applied equally to all renderers with JS; `<noscript>` fallbacks keep content list-visible.
- No doorway/redirect chains; canonical watch-item status rule (mirrored from API.md §4.2): **hidden (admin/takedown) and removed items return a genuine HTTP 404** with the helpful E-06 UI; **temporarily unavailable items return HTTP 200** with E-06 UI + related rail (item may return) **and emit `noindex, follow`** for the duration of unavailability (directive removed automatically when availability is restored and ISR revalidates — never a stale noindex on a healthy page, never misleading metadata on an unplayable one). Parameterized/cursor URLs `noindex`.

6. Page/URL quality rules

Legal/info indexing decision (normative, resolves the former "optional" policy): all legal and informational pages — Terms, Privacy, DMCA, 2257, Cookies, About, Contact — are **indexable with self-referencing canonicals** (compliance surfaces; consistent with §1's indexing directives). No legal page carries `noindex` in v1. Slugs: lowercase, hyphenated, stable forever (DATABASE unique). No ID-noise in URLs. Redirects: 301 map managed in code for renamed taxonomies (admin rename creates redirect pair, audited). Dead links purged from sitemap within a sync cycle.

7. Discretion vs SEO boundary (documented decision)

Tab-title masking (UX-FLOWS §14) applies to already-departed tabs (visibility change) — never to crawlers (no JS-detection of bots). Share previews remain honest per-page OG images in v1. If the neutral-preview flag is enabled later, it applies to all user agents equally (no UA sniffing).

8. Monitoring & KPIs

Indexation count trend, crawl errors (source of truth: search console class tooling), CTR by page type, watch-page organic entry share, sitemap freshness lag ≤ 24 h. Alerts: indexation drop $> 20\%$ week-over-week.

9. Acceptance criteria

1. Every indexable page: unique title+description, canonical, one h1, valid JSON-LD.
2. Sitemap valid, fresh, excludes noindex/admin.
3. robots correct incl. sitemap.
4. RTA label present.
5. Structured-data CI fixtures green.
6. No mixed content; HTTPS-only.
7. Removed videos 404; renamed taxonomy 301s. Verified in TESTING §7 T-66...T-69 and PRE-RELEASE §6.

PART 13

Accessibility

Source document: ACCESSIBILITY.md · v1.0.2 · 2026-09-03

SYCONIA — Accessibility Requirements (WCAG 2.2 AA)

Field	Value
Document	ACCESSIBILITY.md · v1.1.0 · 2026-09-03 (Android platform migration) · [REQUIRED] — conformance target: WCAG 2.2 Level AA principles (product law; PRD §9) applied via Android accessibility APIs + guidance (Compose semantics, TalkBack, font scaling)

1. Commitment & scope

All public and admin surfaces conform to WCAG 2.2 AA. Third-party embed players are outside our DOM; we therefore (a) provide every capability we can at the shell level, (b) prefer sources whose players have their own accessibility where choice exists, (c) document residual gaps honestly (§8) rather than claim conformance we cannot control.

2. Focus, traversal & non-pointer access (WCAG 2.1.1/2.1.2/2.4.3/2.4.7/2.4.11 via Android)

- Every flow completable with TalkBack + swipe navigation, D-pad/keyboard (external keyboards, TV-style remotes where supported), and switch access — CI-enforced journeys (TESTING §6).
- Compose: sensible traversal order (semantic grouping), `focusable/` `focusProperties` management, focus restoration after dialogs/drawer, no focus traps (back always exits topmost layer); visible focus indication on external-keyboard interactions.
- Skip mechanism: first-content "Skip to main content" semantics honored via heading/navigation semantics; landmark roles via `semantics { }` (navigation/main/contentDescription).
- Every flow (F1-F5) completable keyboard-only — CI-enforced journeys (TESTING §6).
- No keyboard traps: modals/drawer trap focus while open and return focus on close; ESC exits topmost layer.
- Visible focus always: 2px Champagne ring + 2px Obsidian offset on all interactive elements; never `outline: none` without replacement.
- Skip link "Skip to content" first tabbable element; landmark regions (`header/nav/main/footer`).
- Shortcuts (`/` , `?` , F, T) never fire while typing; documented in the `?` overlay (GESTURES §5).
- Focus not obscured by sticky elements (2.4.11): header auto-hides when focus would pass beneath; toasts pause on focus.

3. Semantics & screen readers (1.3.x, 4.1.x — TalkBack-first; also Voice Access)

- Semantic Compose first: roles emerge from components (Button, NavigationBar, Scaffold); `Modifier.semantics / contentDescription` only where meaning is not conveyed by content; decorative art `clearAndSetSemantics { }` (hidden).
- Labels: every control has a programmatic label; icon-only buttons carry `contentDescription`; live regions → `LiveRegionMode.Polite/Assertive` (suggestion counts, "12 more videos loaded", toasts, player failure announcements).
- Cards: single clickable with accessible name "{title}, {duration}, {source}"; custom actions minimized.
- Admin console (web, backend): real tables/ARIA unchanged from v1.0.2.
- Player: stage `contentDescription` labeled region; watermark hidden; failure overlay is a dialog with focus handling.
- Page/task titles unique & descriptive; `locale` correct.

- Semantic HTML first (`button` / `a` / `nav` / `dialog`); ARIA only where semantics are insufficient (combobox search, drawer dialog, live regions).
- Labels: every control has a programmatic label; icon-only buttons carry `aria-label`; decorative art `aria-hidden`.
- Live regions: suggestion count, “12 more videos loaded”, toast region (`role="status"`), error announcements (`aria-live="polite"` / `assertive` for player failure).
- Cards: single link with accessible name = “{title}, {duration}, {source}”.
- Tables (admin): real `<table>` with `<th scope>`, caption, sortable headers `aria-sort`.
- Player stage: `role="region"` labelled; watermark hidden; failure overlay is a labelled dialog.
- Page titles unique & descriptive; `lang="en"`.

4. Contrast & color (1.4.1/1.4.3/1.4.11)

Token table (DESIGN-SYSTEM §4) guarantees: body (Alabaster) 18.9:1, secondary $\geq 4.5:1$, tertiary $\geq 4.5:1$ ($\geq 14\text{px}$ only); gold-on-dark rule per DESIGN-SYSTEM §4 — Ostiole Gold `#C5A059` (8.1:1) and Champagne Gold `#E6D3A0` (13.4:1) on Obsidian both pass AA for normal-size text and may be used for text accents, links and labels; the large-only restriction applies to light surfaces only; focus ring $\geq 3:1$ against adjacent, non-text UI (icons/badges) $\geq 3:1$. Verified by unit test over computed values + axe on all states.

5. Font scaling & layout resilience (1.4.4/1.4.10/1.4.12): usable at 200% font scale (sp-based type; no fixed-height text containers; wrapping toolbars) and at small-compact widths; text truncation never removes meaning (marquee/ellipsis + full content via detail views); player controls scale with sp.

Usable at 200% zoom and 320px width: no horizontal scroll, no clipped controls (fluid layouts, wrapping toolbars). Text-spacing overrides (line-height/letter/word) never break layouts. Player remains operable at 200% (controls scale with rem).

6. Motion, timing, media (2.2.x/2.3.x): honor Android reduced-motion/removal of animations (`Settings.Global.ANIMATOR_DURATION_SCALE` / `TRANSITION_ANIMATION_SCALE` detection + `AccessibilityManager`) → no shimmer/pulse loops, transitions $\leq 100\text{ms}$ opacity-only, no shared-element expansions. No auto-updating content except toasts (pausable, 4s). No time limits. No autoplay-with-sound ever (player policy GESTURES §6).

`prefers-reduced-motion` fully honored (DESIGN-SYSTEM §9): no shimmer loops, no pulse, transitions $\leq 100\text{ms}$ opacity-only, no shared-element expansions. No auto-updating content except toasts (pausable, 4s). No time limits anywhere. No autoplay-with-sound ever (player policy GESTURES §6).

7. Input modalities & targets (2.5.x): touch targets $\geq 48\text{dp}$ (controls/nav rows) with $\geq 8\text{dp}$ spacing; all functionality reachable without complex gestures (swipes have button equivalents — drawer closes via X/back; seek via native embed controls); no path-based gestures; labels include visible text where icon meaning may be ambiguous.

Targets $\geq 44 \times 44$ (controls) / 48 (nav rows); spacing $\geq 8\text{px}$ between adjacent targets (2.5.8). Pointer gestures: all functionality reachable without complex gestures (swipes have button equivalents — drawers close via X/ESC, seek via native controls); no path-based gestures. Component labels include visual text where icon meaning may be ambiguous.

8. Embed-player residual gap statement (honest — unchanged in intent): inside third-party embeds (WebView) we cannot control source-player semantics.

Mitigations: capability-driven shell controls are fully accessible; TalkBack users interact with the embed region via its native accessibility where the source provides it; where a source player lacks adequate accessibility, the shell surfaces "Open at source" with the same information density. Gap reviewed annually per source; documented in the in-app accessibility statement (/about section) + legal web page.

Inside third-party iframes we cannot control source-player semantics. Mitigations: capability-driven shell controls are fully accessible; keyboard users interact with the embed region via its native accessibility; where a source player lacks adequate accessibility, the shell surfaces "Open at source" with the same information density. Gap reviewed annually per source; documented in the accessibility statement page [REQUIRED] (/about section), which also states our conformance target and feedback channel.

9. Testing & governance (TESTING §6)

axe-core zero-critical on every page state; keyboard journeys in CI; TalkBack (primary) + Voice Access + Switch Access scripted manual passes per release (web console: NVDA/VoiceOver retained); contrast unit tests from tokens; a11y regressions block releases (G-3). Accessibility statement published; feedback route monitored with 5-business-day response target.

10. Acceptance criteria

1. Full user journey via TalkBack and via external keyboard on a compact device.
2. axe zero critical across matrix.
3. Reduced-motion honored on all animations (visual regression).
4. 200% zoom + text-spacing usable.
5. Screen-reader script passes on core surfaces.
6. Statement published with feedback channel.
7. All WCAG 2.2 AA criteria pass or carry documented §8 gap notes.

PART 14

Testing

Source document: TESTING.md · v1.0.2 · 2026-09-03

SYCONIA — Test Strategy & Complete Test Matrix

Field	Value
Document	TESTING.md · v1.1.0 · 2026-09-03 (Android platform migration) · [REQUIRED]
Platform	Android (Kotlin/Compose) + backend (Node/TS) · v1.1.0
Stack	Android: JUnit · Turbine (Flow) · MockK/assertk · Compose UI tests (createAndroidComposeRule) · Espresso · kotlinx-serialization contract tests · Macrobenchmark (startup/scroll) · screenshot/visual tests · Playwright kept for the backend web console + API plane · axe equivalents via Compose semantics + manual TalkBack passes · detekt/ktlint (Android lint chain)

1. Principles

1. No mock data in production code (product law); test fixtures are confined to `/tests/fixtures` and clearly synthetic — they test behavior, never ship.
2. External sources are represented in tests by **contract-accurate stub adapters** (recorded fixture responses replaying real API shapes) — the stub lives in test scope only.
3. Every feature ships with its four states tested (loading/empty/error/offline).
4. Matrix below is the traceability source of truth: PRs add/extend rows, never delete coverage.

2. Levels (v1.1.0)

- **Domain unit (Android):** use cases, ranking math consumption, cursor handling, E-state mapping — pure Kotlin, fast JVM tests.
- **ViewModel tests:** Turbine Flow assertions; state reduction (loading/success/empty/error/offline/retry/pagination/refresh); event side-effects.
- **Repository/data tests:** Retrofit services against contract-accurate recorded fixtures; DTO→domain mappers; cache TTL behavior; error mapping.
- **Compose UI tests:** every design-system component × states; semantics/content descriptions; touch-target sizes; navigation flows; four-states per feature.
- **Instrumentation:** WebView shell policy (allowlist loads, blocked intents), Coil image pipeline, DataStore/Keystore behaviors, deep links.
- **Backend unit/integration (retained):** services, adapters, validators against ephemeral Postgres (drizzle migrations in CI) — schema, EXPLAIN asserts, retention/purge jobs, breaker, age/attestation middleware, admin session lifecycle.
- **E2E:** Compose-driven app journeys on emulator matrix + Playwright (retained) for backend web console and API contract journeys.
- **Manual device passes:** TalkBack, font-scale 200%, external keyboard, dark/light system, foldables/tablet layout passes per release (\$9).

3. Device & window matrix (v1.1.0 — replaces the browser matrix for the app; backend web console keeps a Chrome/Firefox/WebKit smoke matrix)

Device class	Roles
Compact phone (small minSdk-era devices, 360dp width)	full journey E2E, a11y, perf

Device class	Roles
Medium phone (Pixel-class)	full E2E + Macrobenchmark (startup/scroll)
Large phone / small tablet (expanded width)	layout-adaptation tests (lists→grids, rail↔grid)
Tablet + foldable (expanded)	two-pane/adaptive behavior where specced
Landscape	player/orientation behaviors (GESTURES)
Emulators in CI (API 26...current); physical-device manual passes per release. Backend console: Chromium + Firefox + WebKit smoke (Playwright, retained).	

4. Route coverage table (every route ≥1 E2E)

Route	Tests
/	T-01 age-gate gate flow · T-02 rails render+impressions · T-03 hero CTA · T-04 card→watch transition · T-05 cold-catalog empty state
/search	T-06 query+filters round-trip · T-07 suggest select · T-08 zero-result relaxation · T-09 back/forward state+scroll restore
/api/videos	T-10 contract · T-11 cursor tamper 400 · T-12 hidden exclusion · T-13 breaker soft-degradation
/api/videos/{slug}	T-14 DTO · T-15 opaque 404 hidden/unavailable · T-16 no-age-cookie 403
/api/search(+/ suggest)	T-17 relevance ordering · T-18 rate limit 429 · T-19 injection payload safety
/api/categories tags(/...)	T-20 visible-only · T-21 counts
/watch/[slug]	T-22 poster→init · T-23 milestones beacon · T-24 failure ladder · T-25 geo block · T-26 hidden→E-06 · T-27 watermark/provenance/report present
/legal/*, /about, / contact	T-28 render + contact form validation/submit
/offline, 404, error	T-29 offline banner flow · T-30 404 did-you-mean
/admin/**	T-31 takedown hide→public 404→sync-sticky (FR-8) · T-32 lockout · T-33 audit rows for every mutation · T-34 sources enable-gate (terms) · T-35 mapping backfill

5. Feature/interaction matrix (selection; full grid maintained alongside specs)

Search (F-04): suggest keyboard combobox (arrow/enter/esc), debounce, relaxation chain, trend fallback — T-36...T-39. New endpoints (API §4.7b/§4.8b): interaction-event whitelist enforcement (unknown event dropped+logged, never stored) — T-87; csp-report age-exempt intake, sampling cap, 204-always, malformed tolerated — T-88. Contact endpoint (API §4.11): honeypot silent-drop, field validation, queue routing, rate limit — T-89. Admin contracts (API §5.1): DTO shapes both directions, sort whitelists + defaults, `confirmation_required` on destructive ops, `terms_not_verified` enable block, weight-sum validation, slug immutability — T-90. Player (F-08): capability-driven chrome rendering (per flag set — parametrized), keyboard F/T/ESC, failure ladder incl. alternate embed, buffering chip, autoplay muted-only policy, background unload, rotate chip — T-40...T-48 (per GESTURES §9). Navigation: drawer open/close/swipe/esc/focus-return, back-arrow semantics table (UX-FLOWS §13) on every screen pair — T-49...T-52. Gestures: tap/double-tap/long-press/drag/swipe behaviors with `player_api` stub vs `iframe` stub — T-53...T-56. States: per-screen skeleton geometry (CLS assert), empty states, error E-XX rendering, offline — T-57...T-59. Performance: budgets (PERFORMANCE §1) on home/search/watch — T-60...T-65 (Lighthouse CI + trace asserts). SEO: metadata/canonical/JSON-LD/robots/sitemap/RTA — T-66...T-69. Security: age bypass attempts (direct API, cookie forgery,

header spoof), CSP headers on all routes, admin IDOR attempts (user A session → other tenant n/a but role escalation paths), rate limits, SSRF attempts against adapter client (private CIDR/host-suffix trick payloads) — T-70...T-77. Database: migration up on clean + populated DB; index usage EXPLAIN; retention purge; audit append-only (UPDATE denied) — T-78...T-81. Validation: every Zod schema property-based tests (fast-check) — T-82. Build/deploy: `next build` zero-warning gate, bundle budgets, migration dry-run, smoke on staging — T-83...T-85. Regression: golden journeys suite (F1-F5) on every PR — T-86. E2E stability: retries ×1 only; flaky tests quarantined with issue, never deleted silently.

6. Accessibility testing

- axe-core on every E2E page state (including modals/drawer/player overlays) — zero critical violations.
- Keyboard-only journeys: full F1-F5 flows without pointer (CI-enforced).
- Screen-reader passes (NVDA + VoiceOver) per release on: age gate, drawer, search combobox, watch page, report modal, admin table — script checklist in `/tests/a11y/manual.md` [REQUIRED] artifact.
- Contrast asserted from token table (DESIGN-SYSTEM §4) in unit tests (parses computed values).
- Reduced-motion: visual-regression snapshots with and without the media query.

7. Consolidated traceability index

Requirements → tests: PRD FR-1...FR-10 → T-16/T-70 (FR-1), T-49...T-52 (FR-2), T-10/T-11 (FR-3), T-06...T-09 (FR-4), T-22/T-27 (FR-5), T-24/T-27 (FR-6/9), T-33 (FR-7), T-31 (FR-8), SSR/streaming checks (FR-9), CI G-7 (FR-10). NFRs → PERFORMANCE/SECURITY/SEO/ACCESSIBILITY suites as listed above.

8. Visual regression

Playwright screenshots per breakpoint for: home, search, category, watch, all states (E-01...E-07), admin dashboard/tables, and the **Storybook primitive gallery** (DESIGN-SYSTEM §10 mandates a Storybook entry per primitive — the gallery is an internal tooling surface, not a public route) — diff threshold 0.1%; brand-fidelity guard (logo/clear-space/spacing) via layout-box asserts.

9. Release manual checklist (per PRE-RELEASE.md)

iOS Safari + Android Chrome device passes: age gate, drawer, search, player matrix incl. documented divergences (GESTURES §7), offline behavior, zoom 200%, dynamic type. Signed off in release record (CHANGELOG entry).

10. Definition of done (feature-level)

Unit+component+integration green · E2E row(s) added & green · 4 states covered · a11y clean (axe+keyboard) · budgets green · docs updated (SCREENS/UX-FLOWS/this file) · no placeholder code (G-7) · audit hooks if mutating admin ops.

PART 15

CI/CD

Source document: CI-CD.md · v1.0.2 · 2026-09-03

SYCONIA — CI/CD Pipeline & Quality Gates

Field	Value
Document	CI-CD.md · v1.1.0 · 2026-09-03 (Android platform migration) · [REQUIRED]
Platform (v1.1.0)	GitHub Actions: android track (Gradle: JDK 17/21 → detekt+ktlint → unit → build → Compose/UI tests on emulator → AAB) + backend track (Node 20, retained pipeline) → Vercel/Docker deploy; portable per DEPLOYMENT §7

1. Branching & flow

Trunk-based: `main` protected (1 approving review + all gates). Feature branches → PR → CI (full) → preview deployment (Vercel) → E2E against preview → squash merge → staging auto-deploy → tagged release `vX.Y.Z` → production deploy (manual approval for major, auto for patch during business hours). Hotfix path: `hotfix/*` → same gates, expedited review, tagged `vX.Y.Z+fix`.

2. Environments

Env	Data	Purpose
ephemeral (per-CI-run)	migrated clean Postgres + stub adapters	unit/integration/contract
preview (per-PR)	staging DB (anonymized real schema, source stubs or limited live probe)	E2E, Lighthouse, visual
staging	staging DB + disabled-egress adapters (no live source calls) + real auth	acceptance, smoke
production	prod DB + enabled sources	live

Rule: production secrets never present in CI or preview; source adapters live only in production (and explicitly whitelisted staging smoke with disposable keys).

3. Pipeline stages (every PR)

Android track (every PR touching /android): 1. **setup** — JDK + Android SDK, Gradle cache (`gradle/actions/setup-gradle`), wrapper validation. 2. **static** — detekt + ktlint (+ forbidden-API conventions: no framework imports in domain, no Retrofit/Room in UI, tokens-only colors). 3. **unit** — JVM tests (domain/viewmodel/repositories). 4. **build** — `assembleDebug` + `bundleDebug`/release AAB (CI-only signing), R8 checks, APK size budget artifact. 5. **instrumented** — Compose UI + instrumentation on emulator matrix (API 26/current). 6. **screenshot/visual** — Compose screenshot tests vs approved baselines (0.1% diff policy retained). 7. **security** — secret scan incl. APK contents, dependency audit (Gradle + OSV), license check.

Backend track (retained, every PR touching /backend): 1. **setup** — `npm ci`, Node 20 cache. 2. **lint** — ESLint (+ custom rules). 3. **typecheck** — `tsc --noEmit` strict. 4. **unit** — Vitest (+ property tests). 5. **integration** — Postgres container → drizzle migrations → service/handler tests + EXPLAIN asserts. 6. **build** — Next backend build (fail on warnings). 7. **contract** — Zod DTO both-direction tests. 8. **e2e** — Playwright (console + API). 9. **perf** — API budgets. 10. **security** — `npm audit` High+, gitleaks, header/CSP contract, SSRF suite. 11. **preview deploy** — Vercel preview.

Never committed: keystores, signing passwords, service-account JSONs, map passwords — signing exists only in CI environments (G-6 extended to `*.jks|*.keystore|keystore.properties`).

Nightly (main): full matrix (all viewports + device-emulated mobile), dependency drift report, link check, visual drift report.

4. Quality gates (blocking, mapped G-1...G-12)

Gate	Check	Failure action
G-1 lint	detekt+ktlint zero (android) · ESLint zero (backend)	block
G-2 types	Kotlin strict compiler warnings-as-errors · tsc strict clean	block
G-3 tests	unit+integration+E2E green	block
G-4 migrations	generate → no drift vs schema; apply on populated DB succeeds (expand/contract verified for destructive)	block
G-5 audit	no High/Critical advisories (defer only via owner-approved exception with expiry)	block
G-6 secrets	scan repo+diffs	block
G-7 no-placeholder gate	grep blocks <code>TODO</code> , <code>FIXME</code> , <code>TBD</code> , <code>XXX</code> , <code>HACK</code> , <code>mock</code> , <code>dummy</code> , <code>fake</code> , <code>lorem</code> , <code>placeholder</code> , <code>coming soon</code> , <code>not implemented</code> in production paths (<code>android/**</code> Kotlin sources + backend <code>app/</code> , <code>lib/</code> , <code>components/</code> , <code>drizzle/</code> , <code>scripts/</code>) — allowlist file for legitimate words in docs/tests with review	block
G-8 design-system lint	raw hex only in tokens file; no banned APIs (§3.2)	block
G-9 budgets	APK/AAB size + startup (Macrobenchmark) + API p95 + (backend web bundle where applicable)	block
G-10 web-surface fixtures	OG/share-page + legal metadata, JSON-LD (VideoObject on share pages), assetlinks.json validation	block
G-11 E2E smoke on staging	golden journeys post-deploy	auto-rollback trigger
G-12 changelog	release notes updated for user-facing changes	block on release PRs

5. Release process (summary — full SOP in SOP.md §7)

tag → CI full run → migration dry-run vs prod snapshot → deploy (migrations first, forward-only) → G-11 smoke (health/ready, age gate, home, search, watch, admin login) → announce + CHANGELOG → observe 30min (error-rate dashboard). Rollback: redeploy previous tag (schema-compatible invariant); destructive migrations always two-phase (DEPLOYMENT §6).

6. Deployment artifacts & provenance

Build provenance: commit SHA, lockfile hash, migration set recorded in release notes; preview URLs reproducible; container path publishes image digests (DEPLOYMENT §7).

7. Cron/workflow jobs (GitHub Actions scheduled)

`sync-sources` (per platform cron + `CRON_SECRET` endpoint), `rollup-daily` (00:30 UTC), `purge-expired` (01:00 UTC), `sitemap-refresh` (post-sync), nightly test matrix, weekly dependency PRs, monthly restore drill (staging) — all report to ops channel; failures page on-call for job class `pipeline`.

8. Access & audit of CI

Least-privilege GitHub roles; OIDC-based cloud auth (no long-lived deploy keys); workflow files reviewed like code; release approvals logged. Secrets: GitHub Environments (prod approval required).

PART 16

Deployment

Source document: DEPLOYMENT.md · v1.0.2 · 2026-09-03

SYCONIA — Production Deployment & HTTPS Configuration

Field	Value
Document	DEPLOYMENT.md · v1.1.0 · 2026-09-03 (Android platform migration) · [REQUIRED]

1. Topology (v1.1.0)

Backend service: Vercel (backend-only Next.js: API + admin console + legal/share web surfaces) + **Neon Postgres** (PITR) + **Upstash Redis** (rate limiting) + platform cron → job endpoints. Unchanged from v1.0.2 except the public web UI no longer exists. **Android distribution (honestly scoped — nothing invented):** v1 targets **internal APK + internal testing track** (installed via signed artifact; `.ai` task M5-T006 decides Play/open distribution with operator sign-off — B-003-class decision). No release process beyond internal sideload/testing is claimed. Signing keys live only in CI/machine keystores — never in the repo (CI-CD G-6). Versioning: `versionCode` monotonic + `versionName` semver aligned with releases; staged rollout/Play listing defined only if/when Play distribution is chosen (recorded as a new decision then).

Alternative path (§7): Docker images on a VPS behind Caddy/Traefik — for jurisdictions/hosts where the primary path is unavailable (adult-content policy of the host must permit the service — see §2; never misrepresent the service to any provider, per LEGAL-COMPLIANCE §3).

2. Provider & policy prerequisites (pre-deployment gate)

- Host/CDN/DB providers whose Acceptable Use Policies permit adult (legal, 18+) content — verified and recorded before signup (operator checklist; providers chosen truthfully, service described accurately).
- Domain registered with registrar permitting adult use; DNSSEC enabled.
- Legal pages live (F-10) and RTA label present — deployment to production is blocked by PRE-RELEASE gate §12 without them.

3. HTTPS configuration (normative)

- TLS termination at platform edge; TLS 1.2 minimum (prefer 1.3), modern ciphers only (e.g. `TLS_AES_128_GCM_SHA256`, ECDHE curves), OCSP stapling where applicable.
- HSTS `max-age=63072000`; `includeSubDomains`; `preload` from day one (SECURITY §4); preload submission after 2 stable weeks.
- HTTP→HTTPS 308 redirect at edge; apex↔www canonicalized (single host); no mixed content (CSP upgrade rule).
- Certificates auto-managed/renewed by platform; expiry monitored (alert <21 days) — manual CSR flows forbidden.

4. Environment variables (validated at boot — ARCHITECTURE §12)

Production set via provider secret stores: `DATABASE_URL`, `DATABASE_POOL_URL`, `AGE_SECRET`, `CURSOR_SECRET`, `SESSION_SECRET`, `CRON_SECRET`, `ADMIN_USERNAME`, `ADMIN_PASSWORD_HASH` (argon2id), `SOURCE_<SLUG>_KEY...`, `SITE_URL=https://syconia.example` (operator's real domain), `SITE_NAME=SYCONIA`, `LOG_LEVEL=info`, `RATE_LIMIT_*`. Boot validator fails closed on missing/weak values (secret length ≥ 32, URLs https-only).

5. Database deployment

- Migrations: drizzle-kit generate in CI → reviewed SQL → apply at deploy pre-step (forward-only; expand/contract for destructive changes) — CI-CD G-4.
- Roles provisioned per DATABASE §7 (app/jobs/migrate/admin-read); connection via pooler; TLS enforced; statement timeout defaults set at role level.
- Backups: PITR window $\geq 7d$ + logical dump weekly to encrypted object storage; restore drill monthly on staging (SOP §8). RPO $\leq 15\text{min}$, RTO $\leq 2h$.

6. Release & rollback runbook (summary)

Deploy = migrations → app rollout → G-11 smoke (health/ready, age gate, home/search/watch golden path, admin login) → 30-minute watch window (error rate, p95, breaker states). Rollback = redeploy previous image/tag (schema forward-compatible invariant maintained); CDN cache purge of affected tags; incident ticket if user-visible (SOP §9).

7. Docker/VPS alternative (container specification)

Multi-stage build: deps → build (Next standalone output) → runtime (non-root user, `NODE_ENV=production`, healthcheck `/api/health`, exposed 3000). Reverse proxy (Caddy recommended: automatic HTTPS via ACME, same header set enforced at proxy too). Process manager: systemd or container orchestration; jobs via system cron hitting `CRON_SECRET` endpoints. Images published with immutable digests; SBOM attached `[PROPOSED]`.

8. Post-deploy verification checklist (first boot + every release)

☐ `/api/health` 200 · `/api/ready` 200 (DB + breakers) · headers present (SECURITY §17 test) · age attestation enforced on API + web surfaces (T-70 class probe) · admin login works + lockout active · rate limits live (429 probe) · legal sitemap/robots resolve · assetlinks.json valid · CSP report endpoint receiving · uptime monitor registered (60s) · error-rate dashboard live · rollback artifact (previous image/tag) verified present · current APK/AAB installs on a clean device (smoke journey green).

9. Operational calendar

Daily: takedown queue check (SLA), dashboards glance. Weekly: dependency PRs, unmapped-terms triage, `pg_stat` review. Monthly: restore drill, dependency audit report, capacity review. Quarterly: pen-test refresh, key rotation (SOP §10), provider AUP re-verification.

PART 17

Error & Recovery States

Source document: ERROR-STATES.md · v1.0.2 · 2026-09-03

SYCONIA — Error-State Taxonomy & Recovery (v1.1.0 — taxonomy unchanged; Compose rendering)

Platform mapping: states render in Compose (LoadingState/EmptyState/ErrorState/OfflineBanner components; skeleton shimmer → Compose shimmer honoring reduced-motion); HTTP codes still originate from the API (contract unchanged); "offline" additionally covers airplane/metered transitions via ConnectivityManager observation. No fake content ever fills a state.

Field	Value
Document	ERROR-STATES.md · v1.1.0 · 2026-09-03 (Android platform migration) · [REQUIRED] catalogue — every async surface maps to ≥1 E-XX

1. Universal state laws

- Every async region implements all four states: **loading (skeleton)** · **empty** · **error** · **offline** — designed, branded, tested (TESTING §5).
- Skeletons match target geometry exactly (zero CLS on resolve); shimmer 1.6s; ≤3 skeleton blocks per region.
- Errors are always: region-scoped (never nuke the page), code-correlated (digest/requestId shown small), recoverable (Retry preserves user state), and dead-end-free (a safe exit to parent/related content).
- Empty states are editorial (serif line + one sans action + emblem line-art) — never blank, never apologetic filler, never fake data.
- Copy tone per DESIGN-SYSTEM §12; no technical jargon to users (codes for support correlation only).

2. Catalogue

Code	Surface	Trigger	Presentation	Recovery path
E-01	Home page	rails API 5xx x2	Stage: emblem line-art + “The garden is momentarily closed.” + Retry	Retry → home revalidate; drawer nav unaffected
E-02	Home/ category cold catalog	zero visible items (new deploy)	“The gallery is being curated.” + CTA → Categories/Tags (if also empty → status link)	Operator: run sync (A-06)
E-02b	Filtered listing — zero matches	filters/sort applied yield empty set (catalog itself non-empty)	Distinct state: “No videos match the current filters.” + Clear filters action (restores URL to unfiltered listing) + count of relaxed-filter hint (“Without duration filter: N”)	Clear filters; remove chips; filters are never auto-relaxed (PRD2 §3.3)
E-03	Search zero results	0 matches incl. relaxation	“Nothing matched ‘{q}’.” + relaxed attempts (if any, labelled “Close matches”) + Trending rail + “Try:” chips	Edit query; chips; back preserves query
E-04	Search/list API error	5xx/network	Inline panel “Something interrupted the search.” + Retry (query preserved in field & URL)	Retry; drawer exit; offline banner if cause

Code	Surface	Trigger	Presentation	Recovery path
E-05	Global offline	offline event / fetch network fail	Slim persistent header banner “Offline — showing cached pages” + per-region inline fallbacks; banner links to /offline (S-11). v1 cannot intercept hard navigations (no service worker) — SW-based interception is [PROPOSED] with F-21	Auto-detect online → “Back online” toast + refresh visible regions
E-06	Watch — item gone	slug hidden (admin/takedown) or removed	HTTP 404 + full-page: “This selection is no longer available.” + Related rail + Back (canonical status rule, API.md §4.2)	Related; back arrow; report if user believes error
E-06b	Watch — temporarily unavailable	slug is_available=false (probe pending, may return)	HTTP 200 + same E-06 composition + Related rail (item may return)	Related; back arrow; report broken
E-07	Watch — playback failure	embed timeout 8s / error / breaker	Stage overlay ladder: Retry → Alternate source variant (if provided) → Open at source + Report ; digest shown	Ladder; item flagged degraded; pipeline re-probe
E-08	Watch — geo/unsupported	probe geo / player refuses region	“This selection isn’t available in your region.” + Related	Related; no circumvention links (policy)
E-09	Suggest dropdown	error/timeout	Silent dropdown close; field keeps text; icon subtle warn	Type continues; ESC clears
E-10	Report form	validation/rate limit	Inline field errors; 429 → “You’ve sent several reports recently — try again later.”	Fix fields; retry after window; contact page link
E-11	Contact form	same as E-10	same	same
E-12	Thumbnails	proxy error/broken URL	Branded placeholder tile (emblem pattern, deterministic per slug) — layout intact	Pipeline probe replaces URL
E-13	Admin tables	API error	Table error row + Retry (filters preserved)	Retry; re-login if 401
E-14	Admin action	mutation failure	Toast (error) + row stays unchanged; digest	Retry action; audit shows attempt only on success
E-15	Admin login	bad creds/lockout	Field error + counter; lock panel with countdown	Wait; recovery via operator procedure (SOP §10)
E-16	Route 404	unmatched	S-09: “Lost in the bloom.” + trending + did-you-mean chip	Buttons; no auto-redirect
E-17	Route 500	render crash	S-10 boundary: “Something interrupted the moment.” + Retry + Home + digest	Retry revalidates; beacon auto-sent
E-18	Source degraded (sitewide)	breaker OPEN for ≥1 enabled source	Slim chip on listings “Some sources are temporarily unavailable” (dismissible per session); affected items auto-excluded	Auto on breaker recovery; admin A-06 manual reset
E-19	Rate limited (user)	429 on content APIs	Gentle inline “Easy does — too many requests.” + auto-backoff retry (client)	Client honors Retry-After ; no user action needed
E-20	Maintenance mode	operator switch	Static edge page: emblem + “SYCONIA is briefly tending the garden. Back soon.” + status note	Operator disables; TTFB-static

3. Loading-state specification (per surface)

Home: hero block + card-row skeletons (12) streamed. Search: field live, grid skeleton 12. Watch: exact stage box + title/meta/tag skeletons. Drawer: none (static). Admin: table rows skeleton 10 + KPI card skeletons. Suggest: 3 dropdown lines. All shimmer paused under `prefers-reduced-motion` (static 12% veil).

4. Retry semantics (normative)

Network-class errors: 1 silent auto-retry (800ms, jittered) then manual button. 5xx: manual only (avoid stampede). 429: client honors `Retry-After`, exponential backoff, max 3. Beacons: queued offline, flushed on reconnect (cap 50, drop oldest). All retries preserve scroll anchor, inputs, and URL.

5. Offline behavior detail

Banner + cached navigation (client history); visible regions render last-good data with “as of HH:MM” stamps; mutations (report, contact) queue-and-warn; failed **client-side** navigations render E-04 inline with a link to `/offline` (S-11); **hard** navigations while offline show the browser's own offline error in v1 (no service worker — interception arrives only with F-21 `[PROPOSED]`; a documented, accepted v1 limitation). Service-worker caching `[PROPOSED]` (F-21) upgrades this without UX change.

6. Error taxonomy (internal codes ↔ events)

`ERR_NETWORK` · `ERR_API_5XX` · `ERR_VALIDATION` · `ERR_RATE_LIMIT` · `ERR_CURSOR` · `ERR_AGE_GATE` · `ERR_AUTH` · `ERR_FORBIDDEN` · `ERR_NOT_FOUND` · `ERR_SOURCE_TIMEOUT` · `ERR_SOURCE_BREAKER` · `ERR_EMBED_DEAD` · `ERR_EMBED_GEO` — each maps to beacon `code`, log level, and dashboard facet (PRD2 §9). None contain user data.

PART 18

Operations — SOP

Source document: SOP.md · v1.0.2 · 2026-09-03

SYCONIA — Standard Operating Procedures (Development, Testing, Deployment, Maintenance)

Field	Value
Document	SOP.md · v1.1.0 · 2026-09-03 (Android platform migration) · Owner: Roshan

1. Local development setup [REQUIRED] (v1.1.0 — Android client + backend)

Android app: 1. Prerequisites: JDK 17+ (Temurin), Android Studio (current stable) with SDK platform for `targetSdk` + build-tools, emulator/device (API 26...current), Git. 2. Open `/android` in Android Studio → Gradle sync (wrapper-provisioned Gradle; never a system Gradle). 3. Run configurations: `app` (debug variant) — local backend endpoint or recorded-contract mode. 4. Verify: app launches → age gate → honest empty/offline states (no fake data). **Backend:** 1. Node 20+, npm 10+, PostgreSQL 16 local (or Neon branch). 2. `cd backend` → `npm ci`. 3. `.env.local` per `.env.example` (secrets 32+ chars dev-only; `ADMIN_PASSWORD_HASH` via `npm run hash-password`). 4. `npm run db:migrate` → `npm run dev`. 5. Verify `/api/health` 200; `/admin/login` lockout counter active. **Fixtures:** adapters and app repository tests run against **recorded contract fixtures** by default (`SOURCE_MODE=fixed` / local fixture JSON); live egress only explicitly with your own keys (never commit them).

2. Repository conventions

- Trunk-based; branch `feat|fix|chore|docs/...`; conventional commits (`feat(player): ...`).
- Docs live with code: any behavior change updates the paired spec (PRD2 §13 mapping) **in the same PR**.
- Reviewer checklist (every PR): gates G-1...G-12 context · four states covered · a11y · budget diff · audit hooks on admin mutations · no placeholder code (G-7 is blocking) · spec deltas linked.
- Never commit: secrets, `node_modules`, `.env*`, build output (gitignore enforced), or unofficial logo recreations.

3. Coding standards

Kotlin: explicit API mode on domain/core modules; no Android imports in domain; Compose state hoisting per MVVM/UDF; TypeScript strict on backend; no `any`; tokens only (G-8, both stacks); imports ordered (ktlint/ESLint); error handling per ERROR-STATES taxonomy (no swallowed errors); every admin mutation wraps `audit()`; every external fetch via the adapter client (no direct fetch); Zod at every boundary; comments explain why, never narrate what; zero `TODO/FIXME/mock` markers (tracking issues instead).

4. Testing SOP

- Write tests with the feature, not after (TDD encouraged for services/adapters).
- Local minimum before push: lint + typecheck + unit + affected integration.
- E2E run on preview automatically; never merge with red or quarantined-silent suites.
- Fixture policy: contract-accurate source fixtures recorded once (`scripts/record-fixtures`, live mode, reviewed) — they are test artifacts, never shipped as app data.
- Flaky protocol: 1 retry → quarantine with issue → fix within 2 sprints → never delete coverage.

5. Design QA loop (with the cloned UI/UX Pro Max skill)

- Skill location: `/.skills/ui-ux-pro-max` (cloned 2026-09-03, v2.13.0; MIT; design-intelligence database + design-system generator CLI).
- Usage: consult for palette/typography/UX-heuristic checklists during component work; **brand tokens and guidelines in ``/branding/`` + `DESIGN-SYSTEM.md` always override generic skill suggestions** (the skill informs craft, not brand).
- Cadence: before each primitive PR, run the skill's heuristic scan on the component states; attach summary to PR.

6. Documentation change SOP

Specs are versioned with releases. Behavior change = paired doc update (same PR). New screen/flow/state = update SCREENS/UX-FLOWS/ERROR-STATES + test matrix rows. Docs review is part of G-12 on release PRs. CHANGELOG entry mandatory for user-visible or ops-visible changes.

7. Release SOP (detail behind CI-CD §5)

1. Freeze: open release branch; full CI green; nightly matrix green.
2. Migration review: drizzle SQL read line-by-line; destructive = two-phase plan.
3. Staging deploy + PRE-RELEASE dry run (staging-scope rows).
4. Tag `vX.Y.Z` → production deploy (migrations first) → G-11 smoke → 30-min watch.
5. Complete PRE-RELEASE.md for the release; archive to `/docs/releases/`; sign-off GO/NO-GO.
6. Post-release: CHANGELOG published; 24h dashboard review scheduled.

8. Backup & restore SOP

- Backups: managed PITR ($\geq 7d$ window) + weekly encrypted logical dumps to object storage (30d retention).
- Monthly restore drill (staging): restore latest dump into scratch DB → run integration suite against it → record timing/artifact in `/docs/releases/drill-YYYYMM.md`.
- Emergency restore: prioritize watch-path tables (videos, taxonomy, blocks) — RTO 2h; comms per §9.

9. Incident management

- Severities: **S1** site down / data loss / security breach (page on-call, 15min ack) · **S2** major feature degraded / source breaker open >30min / SLA breach risk (1h ack) · **S3** minor (next business day).
- Containment-first: kill-switches (disable source, maintenance mode E-20), rollback runbook (DEPLOYMENT §6).
- Comms: status note on dashboard; user-facing notice only for S1 (maintenance page).
- Forensics: structured logs + `audit_log` + beacons (all PII-free by design); preserve job/CI logs.
- Post-mortem (S1/S2, blameless, 48h): timeline, root cause, action items → CHANGELOG/docs updates.

10. Credentials & rotation SOP

- Admin password: `npm run hash-password` → update env secret → verify login → old session invalidation (rotate `SESSION_SECRET` if compromise suspected).
- HMAC secrets (`AGE/CURSOR/SESSION`): dual-validity rotation window — deploy accepts old+new for one release cycle, then drop old.
- Source API keys: per-source env; rotation on provider schedule or suspicion; never in repo/logs.
- Quarterly calendar entry: rotate + re-scan (G-6) + record in audit log via settings change.

11. Maintenance cadence

Weekly: dependency PRs (audit-driven), unmapped-terms triage (A-07), `pg_stat_statements` review, CSP violation review. Monthly: restore drill, capacity review (connections/disk), provider AUP re-verification.

Quarterly: key rotation, pen-test refresh, brand quality gate (DESIGN-SYSTEM §14) re-audit, docs accuracy sweep. Annually: accessibility statement refresh, threat-model review.

12. Content-compliance operations (daily rhythm)

1. Takedown queue (A-08) — oldest first; SLA 48h (target 24h); critical reasons (underage/nc/copyright) auto-hidden on arrival — verify each within 4h.
2. Verify public absence after action (row → “View public” must 404).
3. Log resolution + audit; block records for recurring patterns.
4. Escalation path for unlawful-content reports: preserve record → report to source platform → legal counsel per docs/LEGAL-COMPLIANCE §6.

13. Definition of production-ready (per feature)

Four states + tests + ally + budgets + docs + audit hooks + observability events + no placeholders — all verified by the paired PRE-RELEASE rows.

PART 19

Pre-Release Checklist

Source document: PRE-RELEASE.md · v1.0.2 · 2026-09-03

SYCONIA — Production-Readiness Checklist (PASS/FAIL Gate)

Field	Value
Document	PRE-RELEASE.md · v1.1.0 · 2026-09-03 (Android platform migration)
Rule	Release ships only when every line below is PASS . Any FAIL blocks release; N/A requires written justification by the owner (Roshan) recorded in the release record. Evidence column cites the artifact (CI run URL, dashboard, screenshot, report).

Legend: ☐ pending · ✓ PASS · ✗ FAIL · ☐ N/A(+justification). This template is completed per release and archived in `/docs/releases/ [REQUIRED] artifact`.

1. Build & static quality (v1.1.0)

☐ Android: Gradle wrapper validated · detekt+ktlint zero · Kotlin warnings-as-errors clean · `assembleRelease` / AAB built in CI · R8 mapping artifact archived · APK/AAB size budget green — G-9 ☐ Backend: `npm ci` clean · build zero errors **and zero warnings** · `tsc --noEmit` strict clean ☐ No-placeholder gate G-7 green across **android/** + backend production paths (no TODO/FIXME/mock/dummy/lorem)

2. Tests

☐ Unit suite green — G-3 ☐ Integration suite green (migrations applied on clean + populated DB) ☐ App journey matrix green on emulator set (compact/medium/expanded; API 26...current) + backend console smoke (Chromium/Firefox/WebKit) ☐ Player interaction matrix (GESTURES §9) executed incl. documented divergences ☐ Visual regression: zero unapproved diffs ☐ Flaky quarantine list reviewed (nothing silently skipped)

3. Database

☐ Migrations generated, reviewed, applied to staging → then prod (forward-only; expand/contract for destructive) ☐ Index usage verified on hot paths (EXPLAIN artifacts) ☐ Retention/purge jobs ran successfully on staging ☐ Backup + PITR verified; **restore drill passed within last 30 days** ☐ DB roles verified (no superuser at runtime; audit_log append-only grants)

4. API & integrations

☐ `/api/health` + `/api/ready` 200 in prod ☐ Contract tests green (all endpoints, both directions) ☐ Age-gate enforcement probe: content APIs 403 without cookie; with forged cookie 403 (T-70) ☐ Each enabled source: terms verified (admin record) + first sync success + breaker healthy ☐ Rate limits verified live in prod (429 + Retry-After) ☐ Adapter SSRF suite green (private CIDR/host-suffix payloads rejected)

5. Security (SECURITY §17 fully re-run)

☐ HTTPS + HSTS active; SSL Labs-equivalent grade A ☐ All security headers present on every route (automated header test artifact) ☐ CSP verified incl. exact frame-src allowlist; report-only phase completed before enforcement change ☐ Admin: logout, session expiry, audit rows for mutations, `/admin` noindex ☐ Secret scan clean; secrets rotated post-initial-deploy ☐ `npm audit` zero High/Critical — G-5 ☐ Pen-test (OWASP WSTG-lite scope) — no open High findings ☐ Privacy policy matches actual data flows (review vs SECURITY §12)

6. SEO

☐ Titles/descriptions unique per template; canonicals correct ☐ Sitemap valid + fresh; robots correct; RTA label present ☐ JSON-LD fixtures validated (G-10) ☐ Redirect map for renamed taxonomy live ☐ Zero broken internal links (crawler run artifact)

7. Performance

☐ Lighthouse CI budgets green (mobile: perf ≥ 90 , a11y ≥ 95 , BP ≥ 95 , SEO 100) — G-9 ☐ Lab CWV: LCP ≤ 2.0 s, CLS ≤ 0.02 on home/search/watch (throttled) ☐ RUM pipeline receiving (verify first events in dashboard) ☐ p95 API latencies within SLO for 48h on staging load test

8. Accessibility (ACCESSIBILITY §10)

☐ axe zero critical across page matrix ☐ Keyboard-only golden journeys pass ☐ Reduced-motion visual checks pass ☐ 200% zoom / 320px reflow pass ☐ Screen-reader manual script (NVDA/VoiceOver) signed off ☐ Accessibility statement published

9. Brand & UI quality gate (DESIGN-SYSTEM §14 — every line)

☐ Logo fidelity (official assets; no recreations) ☐ clear space honored ☐ no wordmark < 96 px ☐ colors from tokens only ☐ 2-family typography ☐ gold-accent law ☐ glass ≤ 3 surfaces ☐ favicon/app icon correct ☐ watermark correct ☐ ostiole loader present ☐ empty/error states branded ☐ no generic-SaaS / no tube-site styling ☐ responsive audits at 320/375/390/430/768/1024/1280/1440/1920 clean

10. States & content integrity

☐ All E-XX states rendered correctly (catalogue walkthrough artifact) ☐ Zero placeholder/mock content in prod (manual spot-check + G-7) ☐ Legal pages live with final reviewed copy (Terms, Privacy, DMCA, 2257, Cookies) ☐ Contact/report paths deliver (test takedown generates queue item + receipt)

11. Console & network hygiene

☐ Zero console errors on golden journeys (all browsers) ☐ Zero failed network requests (except intentionally blocked/security tests) ☐ No 404 assets; fonts/icons load from self-hosted origin ☐ CSP violation log clean after 48h soak

12. Environment & configuration

☐ All env vars validated at boot (fail-closed test) ☐ Production secrets unique per environment; no reuse from staging ☐ `SITE_URL` correct (final domain); canonical host redirects ☐ Uptime monitor + alert channels verified (test alert fired & received)

13. HTTPS & production config

☐ HTTP→HTTPS 308; apex↔www canonicalized ☐ HSTS preload submission scheduled (2-week mark) ☐ CDN cache rules + purge paths verified (hide → public disappearance ≤ 60 s) ☐ Maintenance mode tested

14. Documentation

☐ Docs suite current (any spec deltas merged before release — SOP §6) ☐ Runbooks (SOP §7/§9/§10) reviewed; on-call informed ☐ CHANGELOG release entry complete ☐ Release record archived (/docs/releases/vX.Y.Z.md)

15. Legal & compliance (docs/LEGAL-COMPLIANCE.md gates)

☐ Age gate verified end-to-end (fresh device) ☐ Takedown SLA workflow rehearsed; designated agent info current ☐ Source terms verification records complete for all enabled sources ☐ Jurisdictional risk review refreshed (target markets list) ☐ Business representation truthful (no decoy naming on legal surfaces) — C-2 resolved

16. Rollback readiness

☐ Previous release artifact redeployable (verified on staging) ☐ Migration reversibility strategy documented for this release ☐ Cache-purge path for rollback tested ☐ On-call owner + rollback decision-maker identified (release window)

Sign-off: Owner (Roshan) __ · **Date** _ · **Release tag** __ · Overall: ☐ GO ☐ NO-GO

PART 20

Agent Instructions & Governance

Source document: AGENT.md · v1.0.2 · 2026-09-03

SYCONIA — Autonomous AI Coding-Agent Execution Instructions

Field	Value
Document	AGENT.md · v1.1.0 · 2026-09-03 (Android platform migration)
Audience	AI coding agents (and humans) implementing this repository. Read this file fully before writing any code.
Policy	§2.1 Zero-Placeholder / Zero-Dummy Implementation Policy — permanent , added 2026-09-03

1. Mission

Implement the SYCONIA platform exactly as specified by the documentation suite (index: [docs/DOCUMENTATION-INDEX.md](#) (see §)). The repository currently contains **only** brand assets ([/branding/](#)) and documentation — everything else is to be built. Do not improvise scope: the specs are the contract.

2. Non-negotiable laws (violation = work rejected)

- 1. No mock/placeholder/dummy data or logic.** No `TODO`, `FIXME`, `TBD`, `XXX`, `HACK`, `coming soon`, `not implemented`, no lorem, no fake catalog entries, no seeded “sample videos”, no stubbed service that pretends success. If a piece is not implementable yet (e.g., no approved source key), implement the real mechanism with an honest empty/degraded state (ERROR-STATES E-02/E-18) — never fabricate content. Tests may use recorded fixtures; production code may not. **Full expansion: §2.1 (permanent policy).**
- 2. No media storage.** Never download, cache, proxy, or reference video media. Playback = official source embed URLs only (ARCHITECTURE §6). CI gate greps for media-file writes.
- 3. No authentication features for users.** No signup/login/password/Google flows — the only auth is the admin panel (env-seeded, argon2).
- 4. No payments/premium/creator/dev-API features.** Out of scope permanently for v1 (PRD §3.2).
- 5. Age gate is server-enforced.** No content HTML/API response without the signed cookie (FR-1). Never bypass “for testing” — use the test harness.
- 6. Brand fidelity.** Use official [/branding/](#) assets only; never recreate the logo; colors/typography/spacing/motion only via tokens (DESIGN-SYSTEM); CI lint blocks raw hex.
- 7. Every async surface ships all four states** (loading/empty/error/offline) from the ERROR-STATES catalogue.
- 8. All admin mutations audited; takedown blocks are sticky across syncs (FR-8).**
- 9. Accessibility is a feature:** keyboard operability, focus visibility, reduced-motion, axe-clean.
- 10. Docs stay true:** if reality must diverge from a spec, update the spec in the same PR with justification (SOP §6). Never let docs drift.

2.1 ZERO-PLACEHOLDER / ZERO-DUMMY IMPLEMENTATION POLICY (permanent)

Production implementation **must not contain** placeholders, dummy implementations, fake content, fabricated data, temporary UI, unfinished logic, or deceptive “looks implemented” behavior. This applies to everything, including but not limited to:

2.1.1 Content — No lorem ipsum; no placeholder copy; no generic fake descriptions; no fabricated titles, names, metadata, statistics, ratings, counts, dates, durations, categories, tags, or other production content; no invented provider/source information; no fake API responses presented as real data; no fabricated database

records; no hard-coded sample records pretending to be production records; no misleading “example” content rendered in production UI unless the specification explicitly requires an actual example.

2.1.2 UI — No placeholder UI; no fake cards, thumbnails, avatars, posters, charts, or metrics; no decorative elements pretending to be functional controls; no buttons, links, filters, menus, tabs, search controls, pagination, player controls, or notifications that visually exist without their specified behavior; never build an interface merely to make a screen appear complete.

2.1.3 Images / media — No placeholder images; no stock/demo images as fake production media; no fabricated adult-content thumbnails/posters; no fabricated media metadata presented as real source data; never invent media URLs, stream URLs, embed URLs, provider IDs, thumbnails, posters, or artwork — only authorized, specification-compliant source data. If a real source is unavailable because the authorization/provider gate is still open, implement the correct empty/unavailable state (E-02/E-18) rather than inventing media.

2.1.4 Logos / branding — No placeholder or fake logo; no recreated/approximated SYCONIA logo while an official asset exists; no substitute brand mark; no random icon in place of an official asset — use the official / branding/ assets per DESIGN-SYSTEM §2–3.

2.1.5 Icons — No emoji or random Unicode symbols as fake icons; no arbitrary iconography where the design system specifies an icon; use the approved icon system (Material Symbols on Android per DESIGN-SYSTEM §7 v1.1.0) or official project assets; every icon must have an intentional semantic or functional purpose.

2.1.6 Code — No `TODO` / `FIXME` / `XXX` / `HACK` markers; no commented-out unfinished implementation; no empty function bodies unless explicitly required by a framework/interface contract and documented as such; no fake return values (`null`, `[]`, `{}`, `false`, `true`, `"TODO"`, `"Coming soon"`, `"Not implemented"`) used to bypass required implementation; no hard-coded values simulating backend behavior when real logic is required; no swallowed errors or ignored exceptions (`catch {}` to hide failures is forbidden); no disabling validation to make tests pass; no bypassing authentication/authorization/security controls; no mock service secretly wired into production behavior; no development-only shortcuts in production paths; no dead code implying incomplete functionality; no unreachable “future implementation” branches; no commented-out code kept as a substitute for implementation.

2.1.7 Backend / database / API — No fake endpoints, fake repositories, fabricated payloads, hard-coded API responses, placeholder IDs, fake source/provider records, fake video records, or fake user/admin records (controlled test fixtures outside production are the only exception, §2.1.9). Schemas, migrations, repositories, services, validation, DTOs, errors, and handlers must implement the actual specification — no API contract that exists only visually.

2.1.8 Legitimate states are NOT placeholders — Real loading/skeleton, empty, error, offline, source-unavailable, authorization-gated, and permission-denied states (ERROR-STATES catalogue) are **required** implementations, must represent genuine application state, and must never contain fake production data. No videos → show the specified empty state. Provider not yet authorized → show the specified gated/unavailable state. Never insert fake videos to make a page look populated.

2.1.9 Test data vs production data — Fixtures, mocks, factories, and seeded dev data are allowed **only** inside automated tests/development infrastructure (TESTING §1): isolated from production runtime, never presented as real content, never silently imported into production services, never used to conceal missing implementation. Production code uses real contracts and real data sources.

2.1.10 No “temporary” production implementations — Never use “temporary”, “for now”, “later”, “replace this”, “will implement”, “coming soon”, “stub”, “placeholder”, “mock for now”, “fake for demo” (or equivalents) as a substitute for completing required functionality. If a requirement cannot legitimately be implemented because an external dependency, authorization, credential, provider decision, or specification gate (e.g., G-04) is unresolved: (1) do not fabricate the missing functionality or data; (2) implement the correct documented gated/unavailable/error state; (3) follow the corresponding specification and this file; (4) clearly report the blocked dependency to the developer; (5) never silently downgrade the requirement.

2.1.11 Completeness gate (before declaring ANY task complete) — Run a repository-wide quality scan for: `TODO`/`FIXME`/`HACK`/`XXX` markers · placeholder text · fake/dummy/demo content · fake API responses · mock services in production paths · placeholder images/media/logos/icons · unfinished or empty implementations ·

hard-coded simulated backend behavior · commented-out unfinished code · dead/incomplete branches · disabled validation/security checks · non-functional UI controls · fabricated production data (`npm run ci:no-placeholder-gate` (backend) · `./gradlew verifyNoPlaceholders` (android), G-7). Do not claim completion while any prohibited item remains.

2.1.12 No cosmetic completion — Never optimize for “the screen looks finished.” A feature is complete only when: UI · interaction behavior · data contract · backend/API/database behavior (where required) · validation · loading/error/empty/offline states · accessibility · security requirements · passing tests · documentation consistency are **all** implemented. A visually polished but functionally fake feature is INCOMPLETE.

2.1.13 Not a prohibition on legitimate artifacts — This policy does not prohibit: loading indicators, skeleton loaders, empty/error/offline states, accessibility labels, test fixtures/mocks, development tooling, deterministic test data, or framework-required stubs/interfaces (documented). The rule targets unfinished, deceptive, fabricated, or placeholder implementation being treated as completed production functionality.

3. Stack (exact — do not substitute)

Android client (v1.1.0): Kotlin · Jetpack Compose · Material 3 (SYCONIA-themed) · Clean Architecture · MVVM/UDF · Coroutines/Flow · Hilt · Navigation Compose · Retrofit/OkHttp/kotlinx-serialization · Coil · DataStore (Room only task-justified) · WebView embed shell (playback, gated B-001) · JUnit/Turbine/MockK/Espresso/Compose UI tests/Macrobenchmark · detekt/ktlint · fonts: Fraunces + Inter (OFL, bundled from branding/fonts).

Backend service: Node.js 20+ · TypeScript 5 strict · Next.js (backend-only role: API + admin console + legal/share web) · PostgreSQL 16+ · Drizzle ORM (+ drizzle-kit) · Zod · Vitest/Playwright (backend tests).

4. Build order (milestones — PRD §12; complete each before the next)

M0 (done): documentation suite (this baseline). **M1 — Foundation:** repo scaffold (/app per ARCHITECTURE §3) · token layer + primitives (DESIGN-SYSTEM §10, incl. Storybook entries) · middleware (age gate + headers + request-id) · global chrome (S-00) · age gate (S-01) · routing for all public screens · legal pages with real copy drafts · error/offline/404 pages · E2E smoke + axe wired. **M2 — Catalog:** Drizzle schema/migrations (DATABASE) · adapter framework + http client (SSRF seam) + first source adapter after operator terms-verification (API §6) · sync job + sync_runs · mapping rules engine · home/search/categories/tags screens wired to real data (or honest E-02) · cursor pagination · suggest endpoint · analytics beacons + events tables. **M3 — Watch experience:** player shell (capability-driven chrome) · poster→init flow · watermark · metadata/tags/description · related rail · failure ladder E-07/E-08 · report flow + takedown tables · player interaction suite (GESTURES §9). **M4 — Admin:** admin auth (argon2, lockout, sessions) · dashboard KPIs · videos/categories/tags/sources/mappings/takedowns/settings/audit screens (A-01...A-10) · CDN tag purge path ≤60s invariant test. **M5 — Hardening:** perf budgets green · SEO artifacts · security checklist (SECURITY §17) · full PRE-RELEASE run · release record. Each milestone ends: all gates G-1...G-12 green, PRE-RELEASE rows for its scope PASS.

5. Task protocol (per work unit)

1. Inspect the relevant specification/documentation first; then inspect the existing implementation before changing it; reuse real existing project infrastructure where appropriate (never scaffold a parallel fake path).
2. Read the paired spec sections (screen → SCREENS+UX-FLOWS+ERROR-STATES; endpoint → API; table → DATABASE).
3. Write the real implementation + tests (four states) + doc deltas. 3. Run the full gate set locally (§6 commands). 4. Open PR with reviewer checklist (SOP §2). 5. Address CI failures completely — never weaken a test to pass it; if a test is wrong, fix the test and the spec together. 6. Before reporting completion, run the §2.1.11 completeness scan; report genuinely blocked items (with their gates) instead of pretending they are complete — never invent missing requirements, never invent production data, never substitute fake functionality for an unresolved dependency.

6. Commands (canonical)

Android (from /android): `./gradlew assembleDebug` · `./gradlew detekt ktlintCheck` · `./gradlew testDebugUnitTest` · `./gradlew connectedDebugAndroidTest` · `./gradlew bundleRelease` · `./gradlew verifyNoPlaceholders` (G-7 android scan). **Backend (from /backend):** `npm ci` · `npm run dev` · `npm run lint` · `npm run typecheck` · `npm run test` · `npm run test:integration` · `npm run test:e2e` · `npm run build` · `npm run db:migrate/db:generate` · `npm run hash-password` · `npm run ci:no-placeholder-gate` · `npm run perf:api`.

7. Design guidance sources (priority order)

1. `/branding/syconia-brand-guidelines.pdf` + `DESIGN-SYSTEM.md` (brand — absolute).
2. `SCREENS/UX-FLOWS/GESTURES` (behavior — absolute).
3. `/skills/ui-ux-pro-max` (craft heuristics — advisory only; brand tokens override any suggestion). Never import skill data into app code.

8. Forbidden actions summary

Adding user auth · adding payments · storing/serving media · scraping beyond official APIs · recreating the logo · hard-coded colors · `dangerouslySetInnerHTML` · client-side source API calls · weakening gates · placeholder anything · deleting tests to pass · changing brand spelling/naming · fabricating analytics numbers (dashboards render honest zeros, A-02) · emoji/Unicode as fake icons (§2.1.5) · non-functional decorative controls (§2.1.2) · mock services wired into production (§2.1.9) · cosmetic completion (§2.1.12).

9. Environment handling

All secrets from env (validated by `/lib/env.ts` fail-closed). Dev adapters default to recorded fixtures (`SOURCE_MODE=fixed`). Never log secrets or full IPs. Never enable a source in code without the admin terms-verification record (API §6.1).

10. Definition of done (every unit)

Feature works against real data path (or honest empty state) · four states · tests green new+existing · a11y clean · budgets green · lint/type clean · no placeholders (gate green) · specs updated · audit hooks where applicable · observability events emitted · **§2.1.11 completeness scan clean** · not cosmetically complete (§2.1.12): interaction, validation, security, and data contracts all real.

11. When blocked

If a spec is ambiguous or conflicting: stop, document the question in the PR/issue, propose the resolution aligned with the docs' priority order (brand guidelines → product laws PRD §3/§8 → architecture → craft skills). Never resolve ambiguity by inventing scope.

PART 22

Legal & Compliance

Source document: docs/LEGAL-COMPLIANCE.md · v1.0.2 · 2026-09-03

SYCONIA — Legal & Compliance Specification

Field	Value
Document	docs/LEGAL-COMPLIANCE.md · v1.0.2 · 2026-09-03 · Audience: operator (Roshan) + counsel
Purpose	The compliance frame referenced by PRD §5, SECURITY.md §12, DEPLOYMENT.md §2 and PRE-RELEASE.md §15. This is a specification of obligations and controls, not legal advice — final copy and jurisdictional strategy require qualified counsel.

1. Service characterization (truthful)

SYCONIA is an adult (18+) media discovery platform that presents third-party content via those parties' official embed mechanisms, with no hosting, production, or distribution of media files by SYCONIA. Every surface where the business is described — legal pages, footers, host/registrar/payment-adjacent paperwork — must use this accurate characterization. Discreet **product UX** (restrained branding, neutral tab title, no explicit UI imagery) is legitimate presentation; misrepresentation **to institutions** is not (see §3).

2. Age control

- Mandatory 18+ self-certification gate, server-enforced (signed cookie), before any content (PRD F-01; SECURITY §10).
- Jurisdictional reality: an increasing number of jurisdictions (e.g., several U.S. states, the UK's Online Safety Act framework, various EU national regimes) impose age-assurance duties that self-certification may not satisfy for adult sites accessible in those markets. Controls specified: (a) architecture hook for a certified age-verification provider [PROPOSED] phase-2; (b) admin geo-policy capability (country/state-level block or gate-hardening) via `system_settings` [REQUIRED] mechanism, enabled per operator's counsel decision per market; (c) documented review cadence quarterly (DEPLOYMENT §9).
- The operator maintains a target-markets list with per-market posture (open / hardened gate / blocked) — reviewed with counsel and recorded in release records.

3. Business representation policy (conflict C-2 resolution)

The supplied brand guidelines' §5 ("Corporate Decoy Deployment") directs presenting a false mainstream identity to financial auditors, processors, and regulators. **This project explicitly rejects that strategy:** misrepresenting the nature of a business to financial institutions or regulators can constitute fraud and violates the project's own Brand Safety mandate (master spec §17). Required correction wherever such direction would surface: merchant descriptors, incorporation papers, host registrations, and app-store/processor disclosures must truthfully describe an adult-media platform. Discretion (neutral naming of holding entities is permissible only where the descriptor remains accurate and permitted by the counterpart's rules) — never deception.

4. Third-party content sources

- Eligibility: sources offering official APIs/feeds/embed programs whose terms permit third-party metadata aggregation + embedding. Before enabling: operator records terms reference URL + verification date (admin Sources gate — API §6.1, SCREENS A-06).
- **No automatic grant:** an API key, public feed, or embeddable snippet is not itself a licence to redistribute, re-host, or aggregate; per-source terms must affirmatively permit the use we make of them, and silence or ambiguity disables the source until resolved (API.md §6.1).

- Prohibited: circumventing paywalls/geoblocks or technical measures; bulk scraping outside documented programs; misrepresenting our client to the source.
- Attribution & provenance: every watch page shows "Provided by {source}" (PRD F-07). Embeds honor source branding/controls (we do not strip attribution — embed terms generally require it).
- Rate respect: adapter rate budgets + circuit breakers (ARCHITECTURE §6) keep usage within documented limits.

5. Copyright / DMCA posture

- Designated agent page (`/legal/dmca`) with agent contact (operator fills before production — PRE-RELEASE §15 gate).
- Takedown intake: public report path + email channel; reasons include `copyright`; copyright claims auto-hide pending review (safe-harbor posture, API §4.9).
- SLA: action within 48h (target 24h); repeat-infringer policy documented (source-level blocks via `blocked_entries` patterns); full log in `takedown_requests` + `audit_log` (DATABASE §2.11–2.12).
- Counter-notice procedure documented in DMCA copy.

6. Prohibited content policy (zero tolerance)

No content that: involves minors in any way; depicts non-consent or real violence; is unlawful in the operator's or viewers' jurisdictions; infringes rights not covered by DMCA. Controls: critical report reasons auto-hide immediately; escalation path = preserve record → report to source platform → counsel; law-enforcement cooperation policy in Terms. Watch-page report reasons encode this taxonomy (API §4.9).

7. 2257 / provenance statement

SYCONIA produces no content and stores no media; the `/legal/2257` page states this accurately and links each enabled source's own compliance/2257 statement where available (stored in source manifest). This statement is a provenance disclosure — it must never imply SYCONIA maintains 2257 records it does not have.

8. Privacy regulation posture

No accounts; minimal first-party analytics; truncated IPs; 90-day raw-event retention; DNT honored; no third-party trackers (SECURITY §12). Privacy policy must mirror actual flows (verified at PRE-RELEASE §5/§15). Cookie notice: first-party cookies only (`sy_age_ok`, `sy_sid`, admin session) — consent posture per target-market counsel (likely "strictly necessary + inform" model; no tracking cookies to consent to).

9. Jurisdictional notes (operator checklist — counsel-confirmed before launch)

- Target markets list + per-market posture (§2). - Blocking capability tested (geo-policy mechanism). - RTA label deployed (SEO §5). - Age-assurance obligations review per market. - Consumer-law terms review (Terms/Privacy enforceability). - Record-keeping for takedown/log retention aligned with obligations.

10. Content-review workflow integration

All compliance operations are product features, not side files: takedown queue (A-08), blocks (FR-8 sticky), audit trail, SLA alerts (PRD2 §9), daily ops rhythm (SOP §12). Compliance artifacts (agent info, market list, drills) live in `/docs/releases/` records.

PART 23

Documentation Index & Changelog

Source document: docs/DOCUMENTATION-INDEX.md · v1.0.2 · 2026-09-03

SYCONIA — Documentation Index

Version 1.1.0 (Android platform migration) · 2026-09-03 · Owner: Roshan · Consolidated PDF: SYCONIA-PROJECT-SPECIFICATION.pdf · **Baseline:** native Android client (Kotlin/Compose/M3) + Node/TS backend service (ARCHITECTURE.md §0; .ai/DECISIONS D-010...D-019)

Reading order (recommended)

1. **README.md** — orientation, stack, index of indexes.
2. **PRD.md** — what SYCONIA is; product laws; conflicts register (§17).
3. **ARCHITECTURE.md** / **DATABASE.md** / **API.md** — how it is built.
4. **SCREENS.md** / **UX-FLOWS.md** / **GESTURES.md** / **DESIGN-SYSTEM.md** — what it looks like and how it behaves.
5. **Quality block** — SECURITY / PERFORMANCE / SEO / ACCESSIBILITY / ERROR-STATES.
6. **Delivery block** — TESTING / CI-CD / DEPLOYMENT / PRE-RELEASE / SOP.
7. **Governance** — AGENT (build executor), docs/LEGAL-COMPLIANCE, CHANGELOG.

Complete document register

#	Document	Path	Purpose
1	Master PRD	PRD.md (see §)	Product requirements, scope laws, feature specs, conflicts register
2	Advanced spec	PRD2.md (see §)	Ranking math, cursors, cache matrix, adapter contract, SLOs, risks
3	SOP	SOP.md (see §)	Dev/test/release/maintenance/incident procedures
4	Agent instructions	AGENT.md (see §)	Laws + milestones M1-M5 for AI coding agents
5	Screens	SCREENS.md (see §)	22 screen specs (public + admin) with layouts/states/a11y
6	UX flows	UX-FLOWS.md (see §)	IA, navigation rules, 15 workflows, back-arrow semantics
7	Design system	DESIGN-SYSTEM.md (see §)	Brand assets, tokens, typography, motion, components
8	Gestures	GESTURES.md (see §)	Touch/mouse/keyboard + player interaction model
9	Architecture	ARCHITECTURE.md (see §)	Hybrid 3-plane architecture, stack, env, invariants
10	Database	DATABASE.md (see §)	17-table schema, indexes, lifecycle, retention, roles
11	API	API.md (see §)	Public/admin endpoints + external adapter contracts
12	Security	SECURITY.md (see §)	Threat model, CSP/SSRF/privacy, checklist
13	Performance	PERFORMANCE.md (see §)	CWV budgets, loading, caching, containment
14	SEO	SEO.md (see §)	Technical/on-page/structured-data + adult-policy compliance
15	Testing	TESTING.md (see §)	Strategy, browser matrix, traceability (T-01...T-86)
16	CI/CD	CI-CD.md (see §)	Pipeline stages, gates G-1...G-12, release flow
17	Error states	ERROR-STATES.md (see §)	E-01...E-20 catalogue + retry/offline semantics

#	Document	Path	Purpose
18	Accessibility	ACCESSIBILITY.md (see §)	WCAG 2.2 AA requirements + embed gap statement
19	Deployment	DEPLOYMENT.md (see §)	Topology, HTTPS, env, rollback, ops calendar
20	Pre-release	PRE-RELEASE.md (see §)	PASS/FAIL production gate (16 sections)
21	README	README.md (see §)	Project overview + documentation index
22	Changelog	CHANGELOG.md	Version history (1.0.0 documentation baseline)
23	This index	DOCUMENTATION-INDEX.md (see §)	Register + reading order
+	Legal compliance	LEGAL-COMPLIANCE.md (see §)	Age verification, sources/ToS, DMCA/2257 posture, jurisdictional notes
+	Brand assets	/branding/	Official logo variants + guidelines PDF ([EXISTING])

Maintenance rules

- Every behavioral change ships with its paired doc update in the same PR (SOP §6).
- This index, CHANGELOG, and the consolidated PDF regenerate on documentation releases (`npm run docs:pdf`).
- Status vocabulary across the suite: [\[EXISTING\]](#) verified in repo · [\[REQUIRED\]](#) to implement · [\[PROPOSED\]](#) future phase · [\[CONFLICT\]](#) documented conflict.

PART 24

README & Changelog

Source document: README.md · v1.0.2 · 2026-09-03

SYCONIA

The Beauty of the Inward Experience.

SYCONIA (pronounced sy-COHN-ee-uh, from syconium — the enclosed fig bloom) is a premium, dark-themed **adult media discovery and streaming application**. It stores no media: playback is delivered exclusively through the official embed players and APIs of approved third-party sources, wrapped in a cinematic, editorial, discreet brand experience. There are no accounts, no payments, no premium tiers — an anonymous 18+ age gate is the only barrier.

- **Developer credit:** Roshan
- **Documentation:** v1.1.0 (Android platform migration) — 2026-09-03
- **Status:** Documentation-complete, pre-implementation. **SYCONIA is now a native Android application** (platform migration from the former web-oriented baseline; see CHANGELOG.md §1.0.3 and .ai/DECISIONS.md D-010...D-019). No application code exists yet — nothing here claims implemented features.

Platform & stack (planned — see **ARCHITECTURE.md** (see §))

Layer	Choice
Client	Native Android · Kotlin · Jetpack Compose · Material 3 (themed from SYCONIA tokens)
Architecture	Clean Architecture (ui/domain/data) · MVVM + UDF · Coroutines/Flow
DI / Navigation	Hilt · Navigation Compose (App Links, predictive back)
Networking / Imaging	Retrofit + OkHttp + kotlinx-serialization · Coil (decisions D-011/D-012)
Playback	Hardened WebView embed shell (official source embeds only; gated by B-001/G-04) — D-013
Persistence	DataStore; Room only where task-justified; no local media ever — D-014
Backend service	Node.js 20+ · TypeScript strict · Next.js in backend-only role (public API, admin console, legal/share web surface, jobs) — D-010
Database / ORM	PostgreSQL 16+ · Drizzle ORM (backend concern only)
Fonts / brand	Fraunces + Inter (SIL OFL, bundled from branding/fonts/) · official brand assets only
Tests / CI	JUnit/Turbine/MockK · Compose UI tests · Espresso · Macrobenchmark · detekt/ktlint; Vitest/Playwright retained on backend; GitHub Actions dual track

Documented vs implemented vs gated (honest)

- **Documented:** the full v1.1.0 specification suite (below) — architecture, screens, flows, quality gates.
- **Implemented:** nothing. No app code, no backend code. `.ai/CURRENT-STATE.md` is the live truth.
- **Gated:** media-source integration (G-04/**B-001** — operator authorization; no provider invented), production hosting (B-003), final legal copy (B-002), Play/distribution choice (M5-T006 decision). SVG brand masters remain open (AG-001).

Documentation index

Product: [PRD.md](#) (see §) · [PRD2.md](#) (see §) · [UX-FLOWS.md](#) (see §) · [SCREENS.md](#) (see §) **Design:** [DESIGN-SYSTEM.md](#) (see §) · [GESTURES.md](#) (see §) · branding/ (asset manifest · icon system · category-art system)

Engineering: ARCHITECTURE.md (see §) · DATABASE.md (see §) · API.md (see §) · CI-CD.md (see §) · TESTING.md (see §) **Quality & ops:** SECURITY.md (see §) · PERFORMANCE.md (see §) · SEO.md (see §) · ACCESSIBILITY.md (see §) · ERROR-STATES.md (see §) · SOP.md (see §) · DEPLOYMENT.md (see §) · PRE-RELEASE.md (see §) **Agents & governance:** AGENT.md (see §) · CHANGELOG.md · docs/DOCUMENTATION-INDEX.md (see §) · docs/LEGAL-COMPLIANCE.md (see §) · .ai/ (execution-control system) **Consolidated:** docs/SYCONIA-PROJECT-SPECIFICATION.pdf

Repository layout

```
/branding/      Official SYCONIA brand assets + asset manifest + design tokens (identity truth)
/docs/          Documentation index, legal compliance spec, consolidated PDF, release records
/.ai/           75-record execution-control system (tasks, gates, audits, decisions)
/android/       [PLANNED] native Android client (Gradle multi-module – ARCHITECTURE §3)
/backend/       [PLANNED] backend service (API + admin console + legal/share web + jobs)
/.skills/       Cloned development aids (ui-ux-pro-max design skill; advisory only, git-ignored)
```

Development rules (summary)

Zero-placeholder policy (AGENT.md §2.1): no fake data/UI/media/logos/icons/markers — honest loading/empty/error/offline states instead. Official brand assets only. No media storage. Scope laws: no accounts, no payments, no creator surfaces, no public developer API. Gates B-001/B-002/B-003 are never bypassed or fabricated. Setup/build/test/lint/release procedures: SOP.md (see §) (they become executable when implementation begins — M0-T003 → M1-T001).

Changelog

All notable changes to the SYCONIA project are documented here. Format: Keep a Changelog; versioning: SemVer.

[1.0.2] — 2026-09-03 — Pre-Implementation Gap-Audit Patch

Applied the 8-group patch plan resolving the gap audit (G-01...G-34). No scope, architecture, brand, or legal changes; documentation-only.

Added / Resolved

- **API.md:** §5.1 complete admin data contracts (9 DTOs + all 16 mutation request schemas, sort whitelists, `confirmation_required`, `terms_not_verified`, `weights_invalid`, `slug_immutable`); §4.11 POST `/api/contact` (honeypot, queue routing, CTN references); `notice?` field on `/api/videos` 200 DTO; `relevance` restricted to search on `/api/videos` with explicit rejection semantics; duration buckets half-open `[0,300)/[300,900)/[900,1800)/[1800,∞)`; `related=<slug>` continuation param + stable `relatedCursor` key; taxonomy contract (categories bounded ≤ 200 unpaginated; tags `q=` prefix + cursor 48/page).
- **PRD2.md:** §2.5 related-rail composition (buckets A/B/C, exclusions, ≥ 4 rule, deterministic key); §2.6 view-count semantics (distinct session/day with $\geq q25$; display rounding); §2.7 stale-request/race/cancellation policy (query-key supersession, `AbortController`, suggest `seq` guard, single-flight mutations); §2.8 filters never auto-relaxed; §2.1 hero eligibility criteria.
- **GESTURES.md:** §6.9 formal player state machine (10 states, valid + invalid transitions); §8 v1 haptics policy (none); §10 formal state-machine appendix (age gate, takedown, source/breaker, network).
- **ERROR-STATES.md:** E-02b filtered-empty state; E-05/§5 v1 offline mechanism corrected (no SW — client-side nav E-04 + /offline link; hard-nav limitation documented, SW [PROPOSED] F-21).
- **SECURITY.md:** §6 normative cookie contracts (`sy_age_ok` signed payload format; `sy_admin` opaque token, hashed at rest; `sy_csrf` issuance/rotation), CSRF flows for admin + public forms, admin lockout scope (per username AND truncated IP).
- **SCREENS.md:** S-01 leave-site target (`https://www.wikipedia.org`, env `AGE_LEAVE_URL`); S-05 filtered-empty → E-02b; S-06 server-backed tag search + pagination; S-07 theater persistence (`sessionStorage`) + no-JS `<noscript>` fallback + S-07R honeypot field; S-08 legal indexing decision applied.

- **DATABASE.md:** slug generation algorithm (normative); cross-source duplicate policy (distinct entries per source; content_hash future-only); `interaction_events.video_id` FK unified with `watch_events` (server resolves slug→id).
- **ARCHITECTURE.md:** canonical jobs registry synchronized (+ mapping-backfill, + sitemap-refresh); `sy_sid` lifecycle (30d, no renewal, rotate on clear-traces).
- **SEO.md:** E-06b unavailable pages emit `noindex`, `follow` with automatic restoration; legal/info indexing decision (all indexable, canonicals).
- **TESTING.md:** T-89 (contact), T-90 (admin contracts) rows. `.env.example: AGE_LEAVE_URL`.
- **Unresolved by design:** G-04 (external-source selection) remains an operational M2 operator gate — no provider named, assumed, or integrated (per audit instruction).

[1.0.1] — 2026-09-03 — Documentation QA Audit & Corrections

Fixed (documentation defects found by QA audit)

- **DESIGN-SYSTEM.md** §4: all eight semantic-token contrast ratios were asserted, not computed; replaced with values computed per the WCAG relative-luminance formula (e.g., Ostiole Gold on Obsidian 6.9→8.1:1, secondary 7→9.9:1, primary 19.5→18.9:1). Documented branding-source discrepancy **B-1**: the brand-guidelines PDF's own contrast figures do not compute (Ostiole vs white "3.2:1" → 2.46:1 actual). Corrected the gold-as-text law: both golds pass WCAG AA normal-text contrast on Obsidian (8.1:1 / 13.4:1); large-only restriction now applies to light surfaces only; body text stays Alabaster for editorial hierarchy.
- **SCREENS.md** S-07: wrong cross-reference "GESTURES §8" → §6 (autoplay policy location).
- **Canonical watch-item status rule** resolved contradiction between **API.md** (opaque 404 for hidden) and **SEO.md** (200 for hidden): hidden/removed → HTTP 404 + E-06 UI; temporarily unavailable → HTTP 200 + E-06 UI + related (mirrored in API §4.2, SEO §5, ERROR-STATES E-06/E-06b, SCREENS S-07).
- **SECURITY.md** §4: CSP `img-src` tightened to `'self'` data: (all imagery is same-origin via the proxy). §14: corrected license claim — fonts are SIL OFL; icons (lucide-react) are ISC; brand assets are project-proprietary.
- **TESTING.md** §8: removed phantom `/system` route (not in any route table) → Storybook primitive gallery. Added test rows T-87/T-88.
- **CHANGELOG.md** /PDF cover: corrected suite count 23 → 24 documents.

Added (gaps closed by QA audit)

- **API.md** §4.7b `POST /api/events/interaction` — the PRD §10 interaction-event catalogue now has an endpoint contract (whitelist-enforced, 202, 120/min).
- **API.md** §4.8b `POST /api/csp-report` — the CSP `report-uri` referenced by SECURITY.md §4 is now a documented age-exempt endpoint.
- **DATABASE.md** §2.2: `videos.views_24h` / `videos.views_7d` job-maintained columns + indexes (PRD2 sorts/cursors previously referenced an undefined aggregate); §2.18 `interaction_events` table (90-day retention, nightly rollup); §5/§6 index + retention updates.
- **No-automatic-grant rule** (API.md §6.1, docs/LEGAL-COMPLIANCE.md §4): an API key or embed snippet is not itself a grant of redistribution/aggregation rights; ambiguous terms disable a source.
- **SCREENS.md** admin shell: explicit admin empty-state rule (honest zeros, never demo data).
- Consolidated PDF now includes all 24 documents (README.md and CHANGELOG.md added as Part 23).

Audit trail

- Full QA battery re-run post-correction: file existence, substantiveness, 79+ internal links, placeholder scan, label vocabulary, route/state coverage, brand-guidelines conformance, PDF↔Markdown correspondence with truncation detection — results recorded in the release record.

[1.0.0] — 2026-09-03 — Documentation Baseline

Added

- Complete project documentation suite (24 documents: the 23 mandated files plus docs/LEGAL-COMPLIANCE.md) at repository root and /docs :
- Product: PRD.md (master product requirements incl. conflicts register), PRD2.md (advanced specification: ranking, cursors, cache matrix, adapters, observability, risk register).
- UX/UI: SCREENS.md (22 screen specifications incl. admin panel), UX-FLOWS.md (15 workflows + navigation state machine), GESTURES.md (touch/mouse/keyboard/player interaction model with capability flags and platform divergences), DESIGN-SYSTEM.md (tokens, typography, motion, components, logo rules).
- Engineering: ARCHITECTURE.md (hybrid 3-plane architecture), DATABASE.md (17-table PostgreSQL schema, indexes, retention, roles), API.md (public + admin API contracts, adapter architecture), CI-CD.md (pipeline + quality gates G-1...G-12 incl. no-placeholder gate), TESTING.md (test strategy + traceability matrix).
- Quality & operations: SECURITY.md (threat model, CSP, SSRF/privacy controls, checklist), PERFORMANCE.md (CWW budgets, caching, loading), SEO.md, ACCESSIBILITY.md (WCAG 2.2 AA), ERROR-STATES.md (E-01...E-20 catalogue), SOP.md, DEPLOYMENT.md (HTTPS configuration), PRE-RELEASE.md (PASS/FAIL release gate).
- Governance: AGENT.md (AI coding-agent laws + milestone plan M1-M5), README.md, CHANGELOG.md, docs/DOCUMENTATION-INDEX.md, docs/LEGAL-COMPLIANCE.md.
- Consolidated specification PDF: docs/SYCONIA-PROJECT-SPECIFICATION.pdf (generated from this documentation).
- Brand asset inventory registered in /branding/ (primary logo, symbol-only, monochrome light, app icon, favicon, brand guidelines PDF) — copied from operator-supplied originals.
- Development aid cloned: ui-ux-pro-max skill v2.13.0 → /.skills/ (advisory design heuristics; brand docs override).
- Documentation repository initialized with git baseline.

Decisions recorded

- Stack locked: Next.js 15 App Router + TypeScript strict + PostgreSQL + Drizzle ORM + motion + TanStack Query + Tailwind v4 (token layer) + Zod.
- Fonts selected: Fraunces (serif) + Inter (sans) — both SIL OFL, satisfying the brand guidelines' typography direction legally.
- Conflicts register established (PRD §17): C-1 explicit-asset instruction vs non-explicit brand identity (brand identity wins; explicit material = source-provided thumbnails only, never authored in-repo); C-2 "Corporate Decoy" business misrepresentation rejected (truthful representation policy); C-3 out-of-scope business units excluded.
- Product laws: no user auth, no payments, no creator tools, no public dev API, no media storage, anonymous-first privacy posture, server-enforced 18+ age gate.

Not implemented (by design, this release)

- All application code, database, and deployments — this baseline is documentation-only; implementation begins at milestone M1 per AGENT.md §4.

[1.0.3] — 2026-09-03 — ANDROID PLATFORM MIGRATION (v1.1.0 baseline)

SYCONIA's implementation target migrates from the web-oriented baseline (Next.js full-stack) to **native Android (Kotlin + Jetpack Compose + Material 3, Clean Architecture, MVVM/UDF, Coroutines/Flow, Hilt, Navigation Compose)** with a retained **Node/TypeScript backend service** (public API, admin console, legal/contact/share web surfaces, ingestion jobs; PostgreSQL 16+/Drizzle unchanged, backend-only). Product scope, laws, gates and the zero-placeholder policy are unchanged. No application code exists — documentation/architecture migration only.

Migration classification (web-specific → disposition; full registry in `.ai/DECISIONS D-010... D-019`)

- **KEEP (product/platform-neutral):** all product features F-01...F-15/F-17/F-18; E-state taxonomy; DATABASE.md; API.md contracts; PRD2 math/cursors/TTLs; security server controls; admin console (as backend web); legal surfaces; G-04/B-001/B-002/B-003 gates; AGENT.md §2.1.
- **MODIFY:** AGENT (stack/commands) · SOP (Android+backend setup) · SCREENS (routes→destinations+deep links) · UX-FLOWS (system back, masking→FLAG_SECURE+label masking) · GESTURES (Compose/touch semantics, hardware keyboards) · DESIGN-SYSTEM (§5 fonts→Compose, §7 icons→Material Symbols D-015, §8 window-size classes, §13 M3 theme) · ACCESSIBILITY (Compose/TalkBack/font-scale) · TESTING (Android pyramid + retained backend tests) · CI-CD (dual android+backend tracks; G-gates re-mapped) · DEPLOYMENT (backend topology + honest Android internal-distribution scope) · PRE-RELEASE (build/test rows) · PERFORMANCE (Android budgets + API SLOs) · SEO (scope-reduced: web surfaces + App Links; discovery-web SEO retired — D-018) · PRD (§3.1, F-16, F-21, personas, NFR row) · ARCHITECTURE (client/server rewrite; backend-only Next.js — D-010).
- **REPLACE with Android equivalent:** Next.js routing→Navigation Compose; React components→Compose; React state→ViewModel+StateFlow; TanStack Query→repository/UseCase layer; Tailwind→M3 theme from tokens; browser storage→DataStore (+Keystore); cookies→attestation/session strategy (SECURITY §6A); favicon→adaptive launcher icon (branding pack + AG-001 note); viewport breakpoints→window-size classes; DOM a11y→Compose semantics; service-worker/PWA→retired (F-21); Lighthouse-first→Macrobenchmark/API budgets.
- **REMOVE as platform-specific:** PWA install/offline shell ([PROPOSED] item retired); public web discovery UI (superseded by the app; minimal share/OG web surface retained); web-specific rendering rows (ISR/SSR for public pages); lucide-react (Android equivalent per D-015).
- **BLOCKED (unchanged):** G-04/B-001 source authorization (M2-T008/T009, M2-GATE); B-002 legal finalization; B-003 hosting AUP; AG-001 SVG masters; AG-014 doc screenshots (pending real UI).

New decisions

D-010 platform architecture & backend retention · D-011 Retrofit/OkHttp/kotlinx-serialization · D-012 Coil · D-013 WebView embed shell · D-014 DataStore-first persistence (Room only task-justified; no local media) · D-015 Material Symbols icons · D-016 version strategy (pin-at-scaffold; minSdk 26; targetSdk Play-current) · D-017 app age attestation approach (mechanism finalized at M1-T011/M2-T010) · D-018 SEO scope reduction · D-019 milestone/task reconciliation model. Recorded in `.ai/DECISIONS.md`.

Artifacts

Canonical docs migrated in place (no duplicate doc system created). `.ai` execution system reconciled: 75 task records (71 active + 4 retired-with-successor), dispositions recorded per task; roadmap/gates/audits/checklist updated; PDF regenerated from the migrated suite.